Evidencias de seguridad de la actividad autónoma

Lenguaje de Programación II | Sesión 10 | PharmaBackend

Estudiante: Caleb David Asmat Briceño
Código: 202510208
Fecha de ejecución: 18 de octubre de 2026
Rama: feature/seguridad-pruebas-asmat
Repositorio: https://github.com/ADavid2507/PharmaDB

Preparación y orden de ejecución

Credenciales iniciales de desarrollo

```
admin / Admin2026*
vendedor / Vendedor2026*
almacen / Almacen2026*
supervisor / Supervisor2026*
inactivo / Inactivo2026*
```

IDs y datos identificados en las evidencias

Usuario admin: 1

Usuario vendedor: 2

Usuario almacen: 3

Roles ADMIN / VENDEDOR / ALMACENERO: 1 / 2 / 3

Cliente: 1. Producto: 28, Amoxicilina; stock 2 en la consulta de T-03.

A-01 Login de los cuatro usuarios

Grupo: Autenticación
Usuario o token: Sin token

Petición: POST /auth/login
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

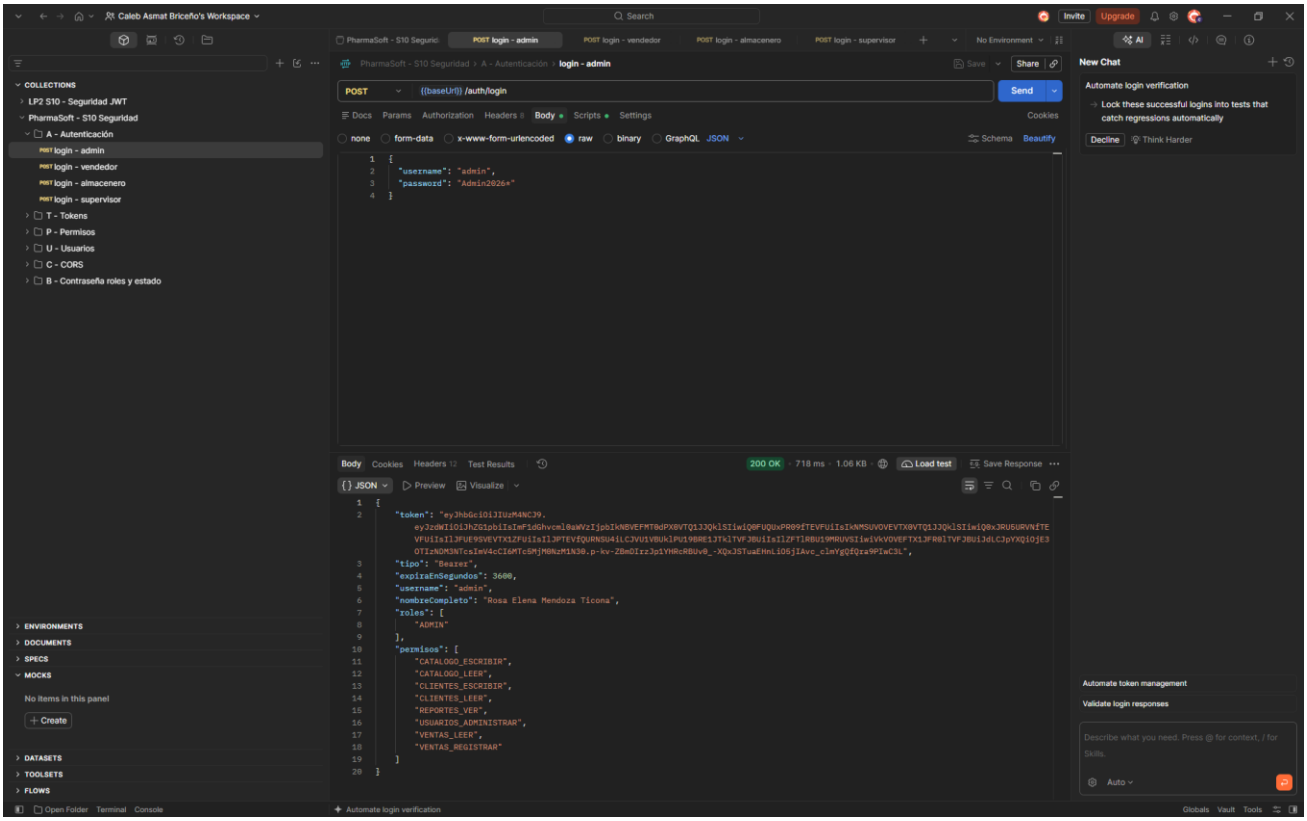
Resultado esperado: 200 en admin, vendedor, almacen y supervisor; roles y permisos correctos; supervisor suma VENDEDOR y ALMACENERO.

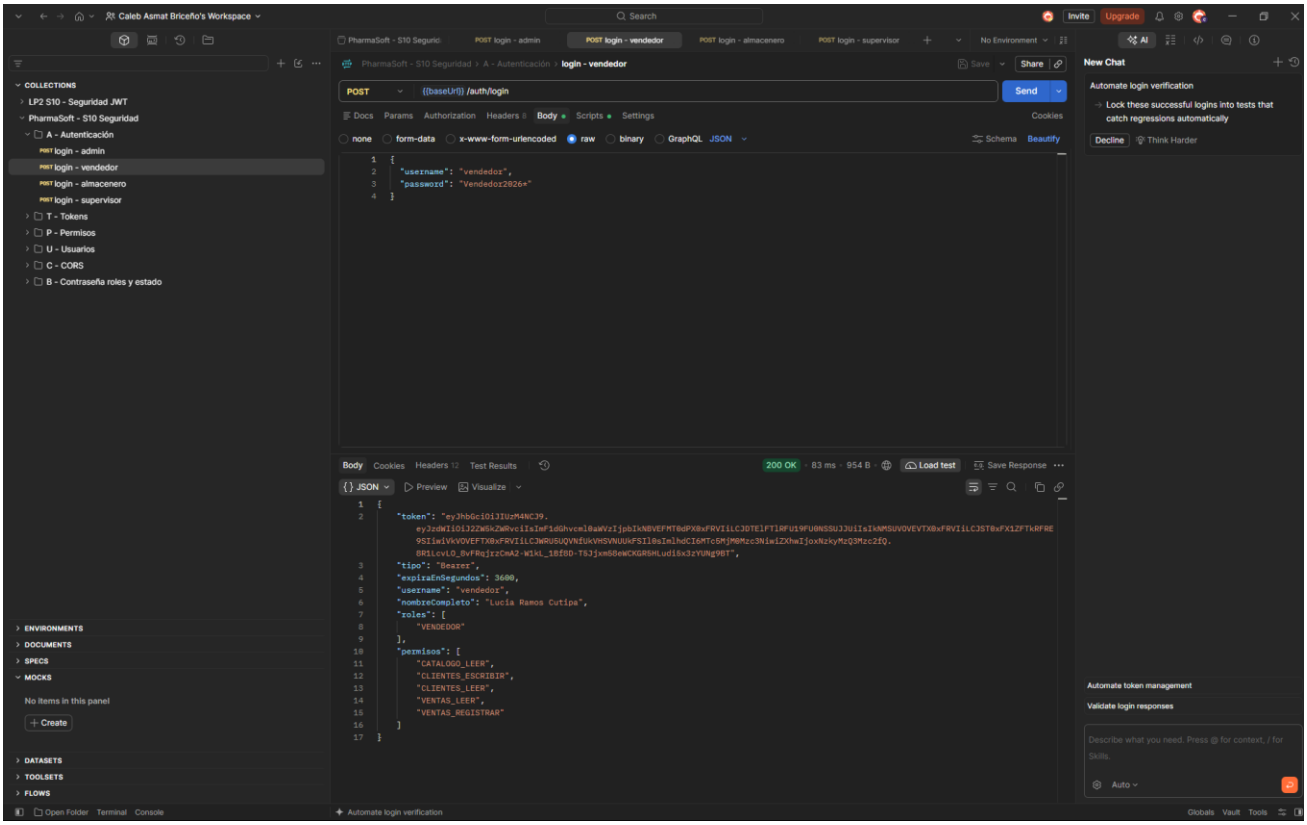
Precondición y datos utilizados: Credenciales iniciales de admin, vendedor, almacen y supervisor; cuentas activas.

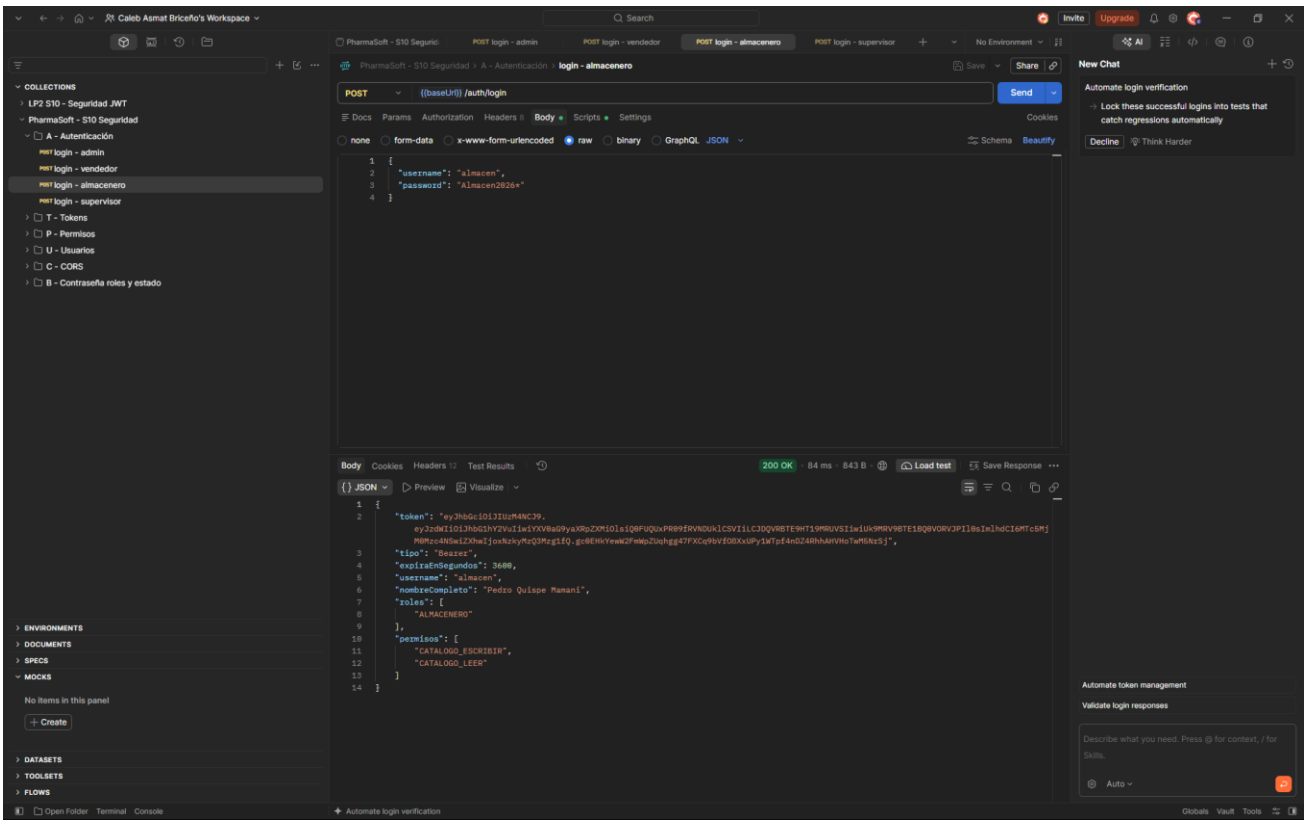
Resultado obtenido: 200 OK en los cuatro logins. ADMIN recibió ocho permisos, VENDEDOR cinco, ALMACENERO dos y supervisor seis, con ambos roles.

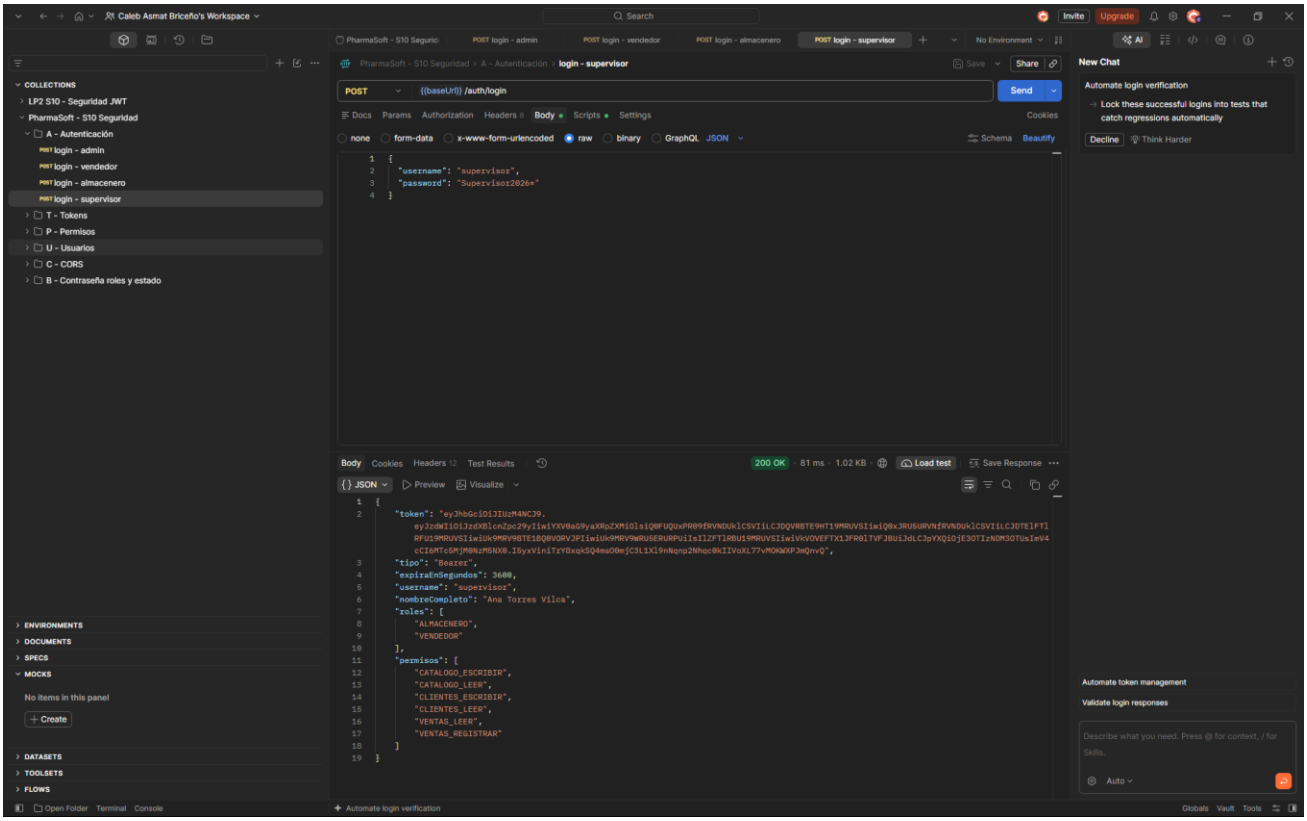
Estado: Pasa
Observaciones: Ninguna.

Evidencia: 4 capturas incrustadas en la sección A-01, en el orden de las operaciones.




Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
PharmaSoft - S10 Seguridad
POST login - admin
POST login - vendedor
POST login - almacenero
POST login - supervisor
No Environment
COLLECTIONS
LP2 S10 - Seguridad JWT
PharmaSoft - S10 Seguridad
A - Autenticación
login - admin
login - vendedor
login - almacenero
login - supervisor
T - Tokens
P - Permisos
U - Usuarios
C - CORS
B - Contraseña roles y estado
PharmaSoft - S10 Seguridad › A - Autenticación › login - vendedor
Save
Share
POST
{{baseUrl}} /auth/login
Send
Docs Params Authorization Headers 8 Body Scripts Settings
Cookies
none form-data x-www-form-urlencoded raw binary GraphQL JSON
Schema Beautify
{
"username": "vendedor",
"password": "Vendedor2026+"
}
Body Cookies Headers 12 Test Results
200 OK · 83 ms · 954 B
Load test
Save Response
{ } JSON Preview Visualize
{
"token": "eyJhbGciOiJIUzM4NCJ9.
eyJzdWIiOiJ2ZW5kZWRvciIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0xFRVIiLCJDTElFTlRFU19FU0NSSUJJUiIsIkNMSUVOVEVVTX0xFRVIiLCJSTkFRFE9SIiwiVkVOVEFTX0xFRVIiLCJWRUSUQVNfESCRIQlIsImlhdCI6MTc5MjM0Mzc3NiwiZXhwIjoxNzkyMzQ3Mzc2fQ.
8R1LcvLO_BvFRqjrzCmA2-W1kL_1Bf0D-TSJjxm6BeWCKGR6HLud16x3zYUNg9BT",
"tipo": "Bearer",
"expiraEnSegundos": 3600,
"username": "vendedor",
"nombreCompleto": "Lucia Ramos Cutipa",
"roles": [
"VENDEDOR"
],
"permisos": [
"CATALOGO_LEER",
"CLIENTES_ESCRIBIR",
"CLIENTES_LEER",
"VENTAS_LEER",
"VENTAS_REGISTRAR"
]
}
New Chat
Automate login verification
Lock these successful logins into tests that catch regressions automatically
Decline
Think Harder
Automate token management
Validate login responses
Describe what you need. Press @ for context, / for Skills.
Auto
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
Open Folder Terminal Console
Automate login verification
Globals Vault Tools


Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
PharmaSoft - S10 Seguridad
POST login - admin
POST login - vendedor
POST login - almacenero
POST login - supervisor
No Environment
COLLECTIONS
LP2 S10 - Seguridad JWT
PharmaSoft - S10 Seguridad
A - Autenticación
login - admin
login - vendedor
login - almacenero
login - supervisor
T - Tokens
P - Permisos
U - Usuarios
C - CORS
B - Contraseña roles y estado
PharmaSoft - S10 Seguridad › A - Autenticación › login - almacenero
Save
Share
POST
{{baseUrl}} /auth/login
Send
Docs Params Authorization Headers 8 Body Scripts Settings
Cookies
none form-data x-www-form-urlencoded raw binary GraphQL JSON
Schema Beautify
{
"username": "almacen",
"password": "Almacen2026+"
}
Body Cookies Headers 12 Test Results
200 OK · 84 ms · 843 B
Load test
Save Response
{ } JSON Preview Visualize
{
"token": "eyJhbGciOiJIUzM4NCJ9.
eyJzdWIiOiJhbGlhY2VuIiwiYXV0aG9yaXRpZXMiOlsiQUFUQUxPR09fRVNDUklCSVIiLCJOQVRBTE9HT19MRVSIiwiUk9MRV9BTE1BQ0VORVJPIl0sImlhdCI6MTc5MjM0Mzc4NSwiZXhwIjoxNzkyMzQ3Mzg1fQ.gc0EHkYewW2FmWpZUqhgg47FXCq9bVIO8XxUPy1WTpf4nDZ4RhhAhVHoTwM5NzSj",
"tipo": "Bearer",
"expiraEnSegundos": 3600,
"username": "almacen",
"nombreCompleto": "Pedro Quispe Mamani",
"roles": [
"ALMACENERO"
],
"permisos": [
"CATALOGO_ESCRIBIR",
"CATALOGO_LEER"
]
}
New Chat
Automate login verification
Lock these successful logins into tests that catch regressions automatically
Decline
Think Harder
Automate token management
Validate login responses
Describe what you need. Press @ for context, / for Skills.
Auto
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
Open Folder Terminal Console
Automate login verification
Globals Vault Tools


Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
PharmaSoft - S10 Seguri...
POST login - admin
POST login - vendedor
POST login - almacenero
POST login - supervisor
No Environment
AI
COLLECTIONS
LP2 S10 - Seguridad JWT
PharmaSoft - S10 Seguridad
A - Autenticación
POST login - admin
POST login - vendedor
POST login - almacenero
POST login - supervisor
T - Tokens
P - Permisos
U - Usuarios
C - CORS
B - Contraseña roles y estado
PharmaSoft - S10 Seguridad › A - Autenticación › login - supervisor
Save
Share
POST
{{baseUrl}} /auth/login
Send
Docs
Params
Authorization
Headers 8
Body
Scripts
Settings
Cookies
none
form-data
x-www-form-urlencoded
raw
binary
GraphQL
JSON
Schema
Beautify
{
"username": "supervisor",
"password": "Supervisor2026+"
}
Body
Cookies
Headers 12
Test Results
200 OK
81 ms
1.02 KB
Load test
Save Response
{ } JSON
Preview
Visualize
{
"token": "eyJhbGciOiJIUzM4NC39.
eyJzdWIiOiJzdXBlcnZpc29yIiwiYXV0aG9yaXRpZXMiOlsiQ0FUQUxPRzlfRVNDUklCSVIiLCJDQVRBTE9HT19MRUVSIiwiQ0xJRU5URVNfRVNDUklCSVIiLCJDTElFTlRFU19MRUVSIiwiUk9MRV9BTE1BQ0VORVJPIiwiUk9MRV9WRU5ERURPUiIsIlZFTlRBU19MRUVSIiwiVkVOVEFTX1JFR0lTVFJBUiJdLCJpYXQiOjE3OTIzNDM3OTUsImV4cCI6MTc5MjM0NzM5NX0.I6yxViniTzY8xqk5Q4msO0mjC3L1Xl9nNqnp2Nhqc0kIIVoXL77vMOWXP3mQnvQ",
"tipo": "Bearer",
"expiraEnSegundos": 3600,
"username": "supervisor",
"nombreCompleto": "Ana Torres Vilca",
"roles": [
"ALMACENERO",
"VENDEDOR"
],
"permisos": [
"CATALOGO_ESCRIBIR",
"CATALOGO_LEER",
"CLIENTES_ESCRIBIR",
"CLIENTES_LEER",
"VENTAS_LEER",
"VENTAS_REGISTRAR"
]
}
New Chat
Automate login verification
Lock these successful logins into tests that catch regressions automatically
Decline
Think Harder
Automate token management
Validate login responses
Describe what you need. Press @ for context, / for Skills.
Auto
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
Open Folder
Terminal
Console
Automate login verification
Globals
Vault
Tools

A-02 Mensajes de login fallido

Grupo: Autenticación
Usuario o token: Sin token

Petición: POST /auth/login
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

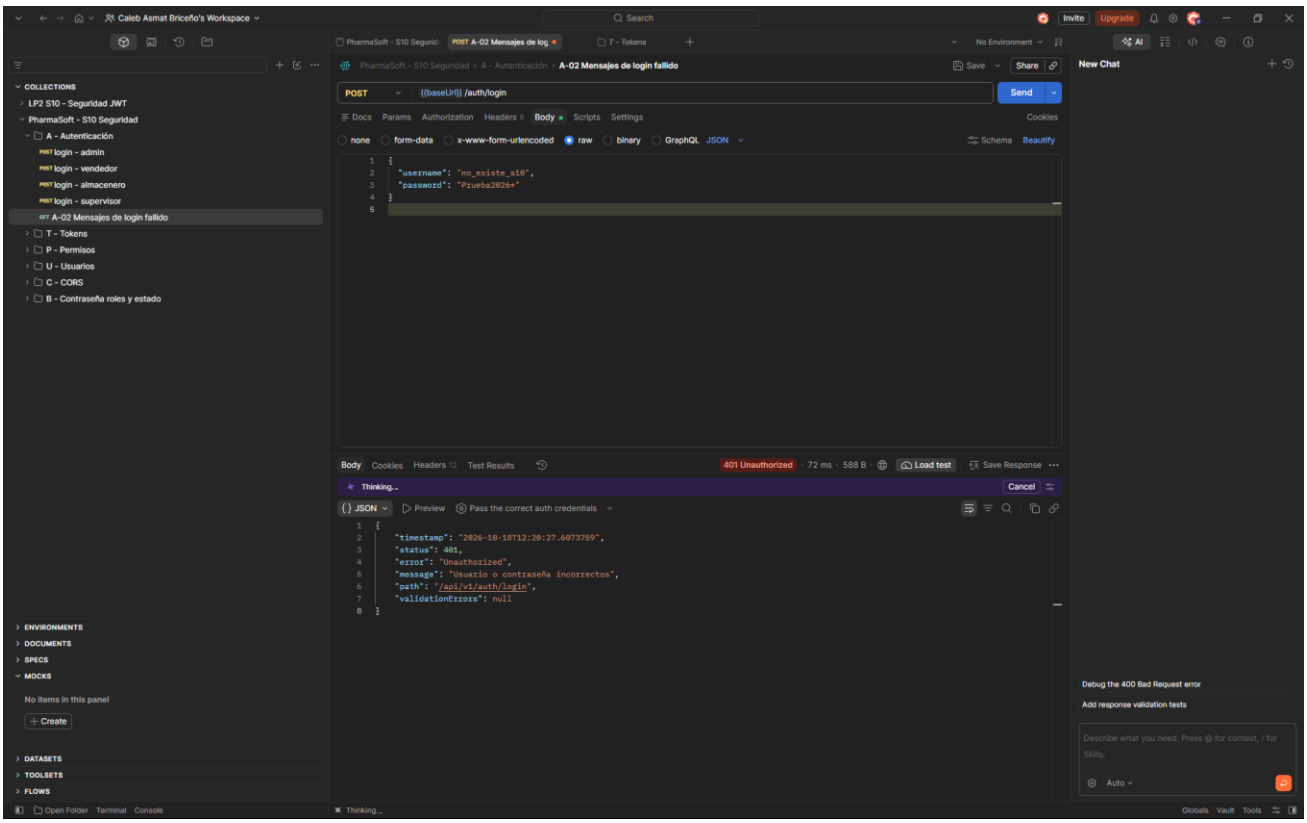
Resultado esperado: 401 con el mismo mensaje Usuario o contraseña incorrectos para usuario inexistente y contraseña incorrecta.

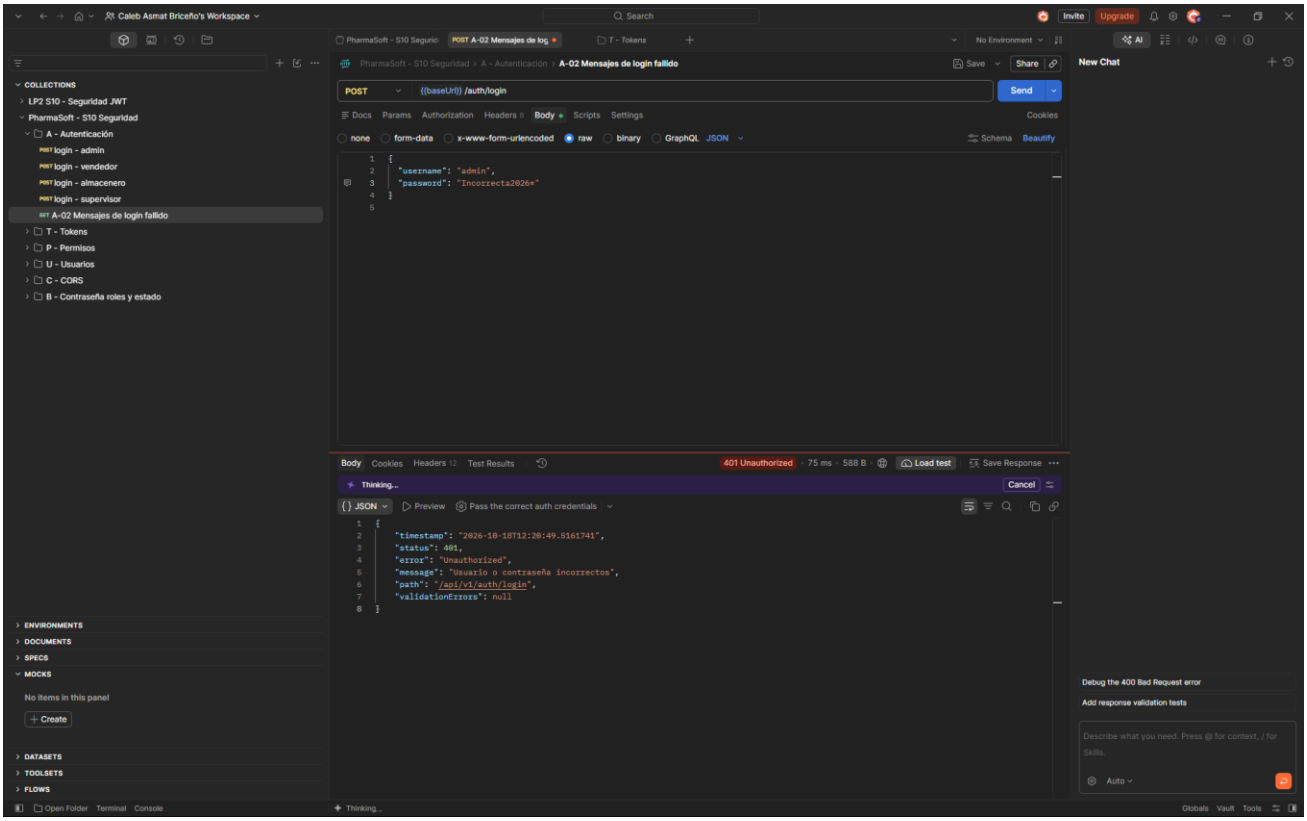
Precondición y datos utilizados: Login de no_existe_s10 con Prueba2026* y de admin con Incorrecta2026*.

Resultado obtenido: 401 Unauthorized en ambos intentos; mismo mensaje: Usuario o contraseña incorrectos.

Estado: Pasa
Observaciones: Ninguna.

Evidencia: 2 capturas incrustadas en la sección A-02, en el orden de las operaciones.




Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
LP2 S10 - Seguridad JWT
PharmaSoft - S10 Seguridad
A - Autenticación
login - admin
login - vendedor
login - almacenero
login - supervisor
A-02 Mensajes de login fallido
T - Tokens
P - Permisos
U - Usuarios
C - CORS
B - Contraseña roles y estado
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
Open Folder
Terminal
Console
PharmaSoft - S10 Seguridad › A - Autenticación › A-02 Mensajes de login fallido
Save
Share
POST
{{baseUrl}} /auth/login
Send
Docs
Params
Authorization
Headers 8
Body
Scripts
Settings
Cookies
none
form-data
x-www-form-urlencoded
raw
binary
GraphQL
JSON
Schema
Beautify
{
"username": "admin",
"password": "Incorrecta2026+"
}
Body
Cookies
Headers 12
Test Results
401 Unauthorized
75 ms
588 B
Load test
Save Response
Thinking...
Cancel
JSON
Preview
Pass the correct auth credentials
{
"timestamp": "2026-10-18T12:20:49.5161741",
"status": 401,
"error": "Unauthorized",
"message": "Usuario o contraseña incorrectos",
"path": "/api/v1/auth/login",
"validationErrors": null
}
Thinking...
Globals
Vault
Tools
New Chat
Debug the 400 Bad Request error
Add response validation tests
Describe what you need. Press @ for context, / for Skills.
Auto

A-03 Cuenta inactiva

Grupo: Autenticación
Usuario o token: Sin token

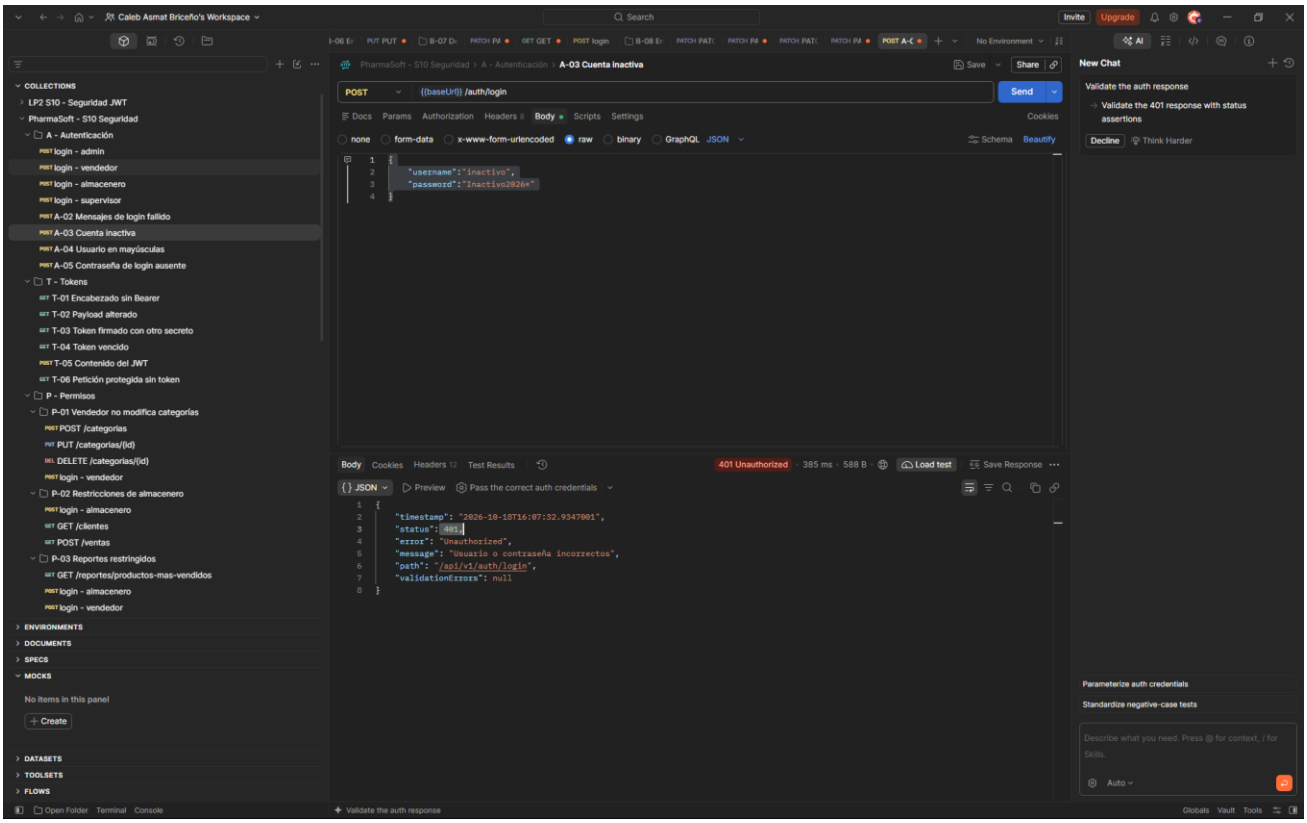
Petición: POST /auth/login
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

Resultado esperado: 401; Usuario o contraseña incorrectos, sin revelar que la cuenta existe.

Resultado obtenido: 401 Unauthorized; Usuario o contraseña incorrectos. La petición envía username inactivo y password Inactivo2026*.

Estado: Pasa
Observaciones: La captura comprueba el rechazo de la cuenta inactiva con el mismo mensaje genérico que los demás errores de autenticación.

Evidencia: 1 captura incrustada en la sección A-03, en el orden de las operaciones.



A-04 Usuario en mayúsculas

Grupo: Autenticación
Usuario o token: Sin token

Petición: POST /auth/login
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

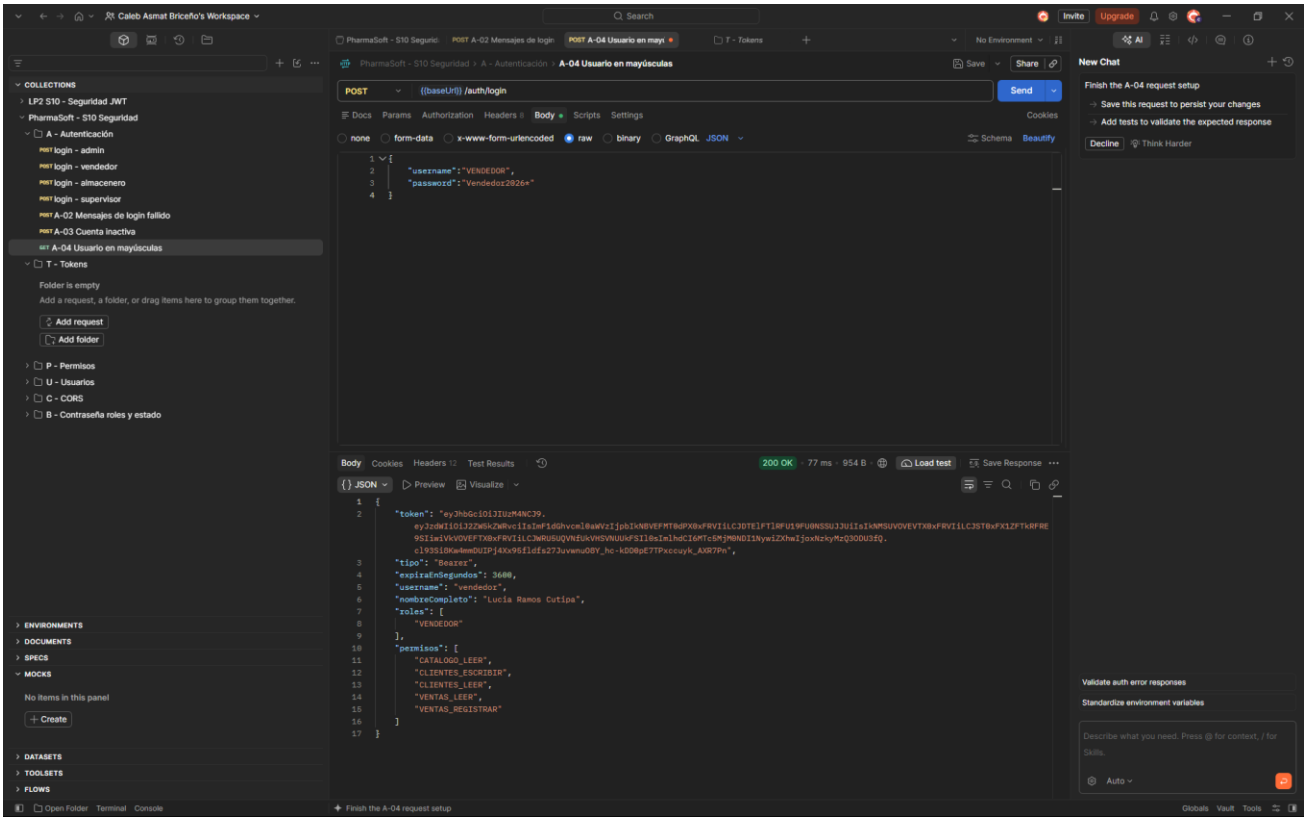
Resultado esperado: Regla adoptada: 200 con VENDEDOR y su contraseña correcta; la búsqueda actual no distingue mayúsculas.

Precondición y datos utilizados: Username VENDEDOR y contraseña Vendedor2026*.

Resultado obtenido: 200 OK; la respuesta identifica al usuario vendedor con rol VENDEDOR y sus cinco permisos.

Estado: Pasa
Observaciones: La búsqueda sin distinguir mayúsculas coincide con UsuarioRepository.findByUsernameIgnoreCase.

Evidencia: 1 captura incrustada en la sección A-04, en el orden de las operaciones.



T-01 Encabezado sin Bearer

Grupo: Token
Usuario o token: vendedor

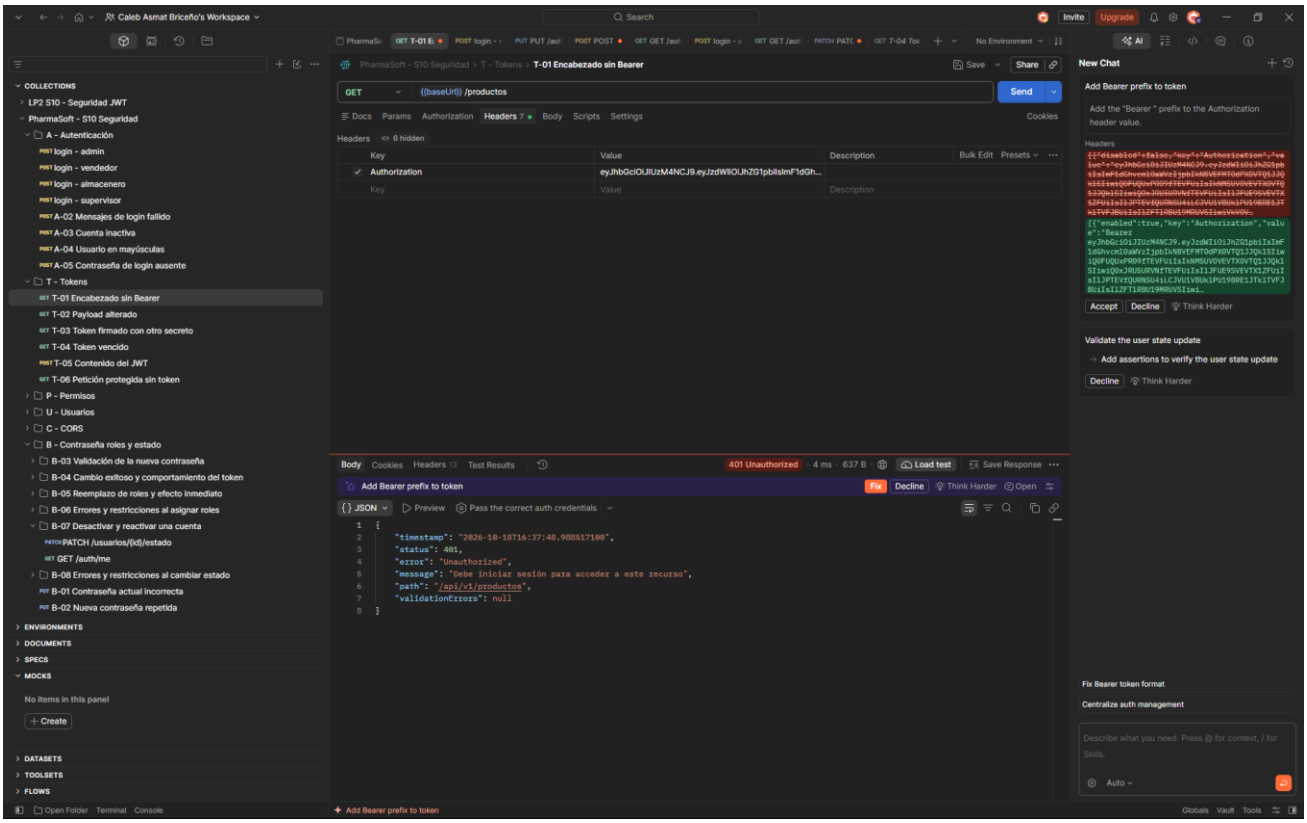
Petición: GET /productos
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

Resultado esperado: 401; Debe iniciar sesión para acceder a este recurso.

Resultado obtenido: 401 Unauthorized; Debe iniciar sesión para acceder a este recurso. Authorization está habilitado y contiene el JWT sin el prefijo Bearer.

Estado: Pasa
Observaciones: La casilla del encabezado está marcada. La captura acredita el rechazo del JWT enviado sin Bearer.

Evidencia: 1 captura incrustada en la sección T-01, en el orden de las operaciones.



T-02 Payload alterado

Grupo: Token
Usuario o token: vendedor

Petición: GET /productos
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

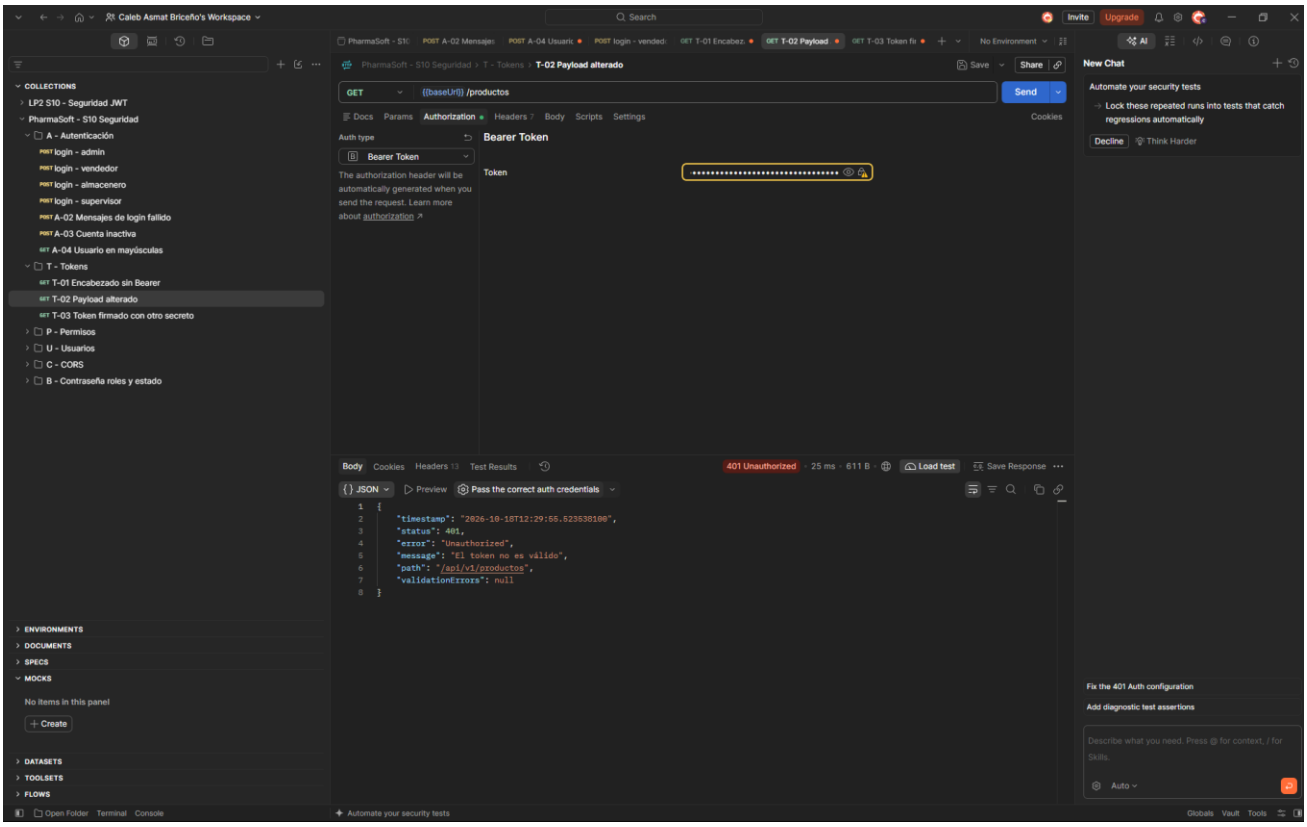
Resultado esperado: 401; El token no es válido.

Precondición y datos utilizados: GET /productos con Bearer Token modificado, cuyo valor aparece oculto.

Resultado obtenido: 401 Unauthorized; El token no es válido.

Estado: Pasa
Observaciones: La imagen muestra el rechazo del token inválido; su contenido está oculto.

Evidencia: 1 captura incrustada en la sección T-02, en el orden de las operaciones.



T-03 Token firmado con otro secreto

Grupo: Token
Usuario o token: vendedor

Petición: GET /productos
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

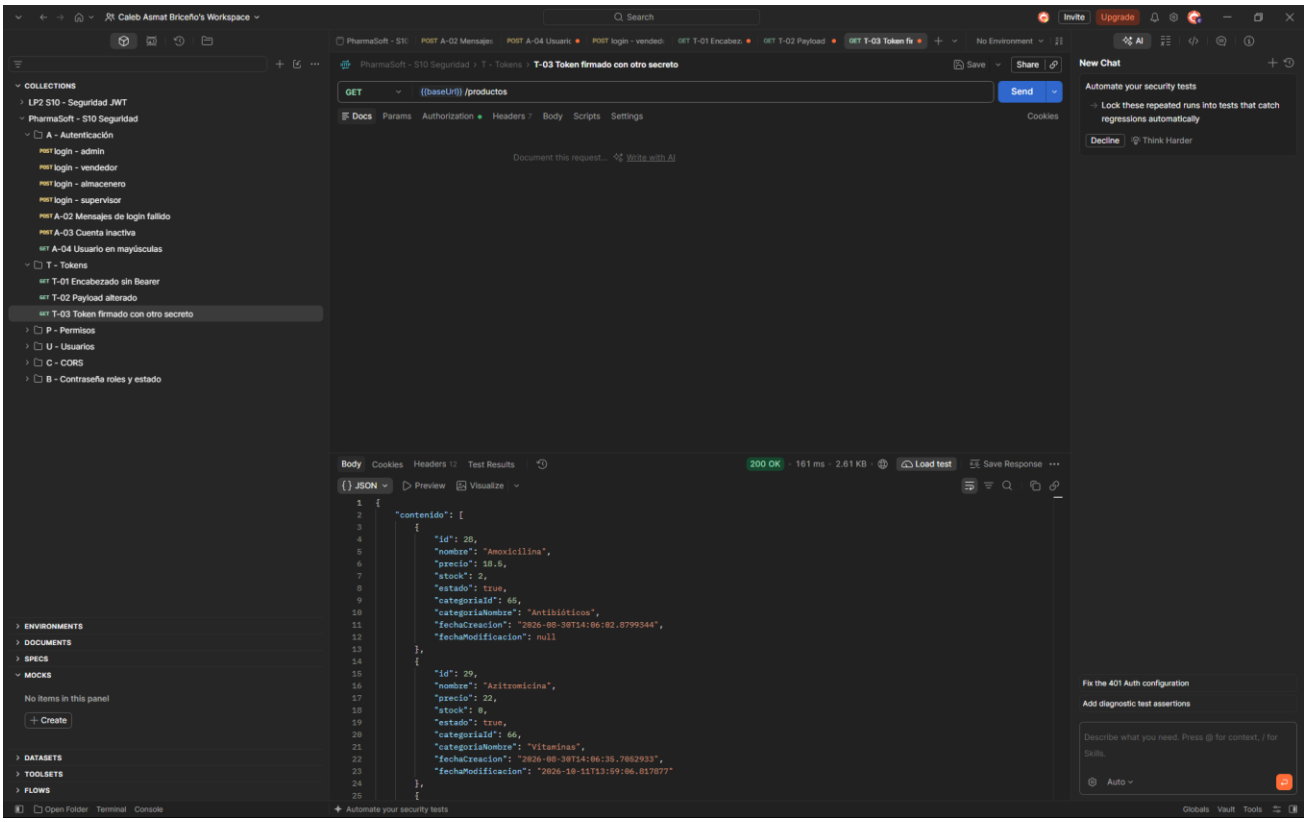
Resultado esperado: 401; El token no es válido al usar un JWT emitido antes del cambio de secreto.

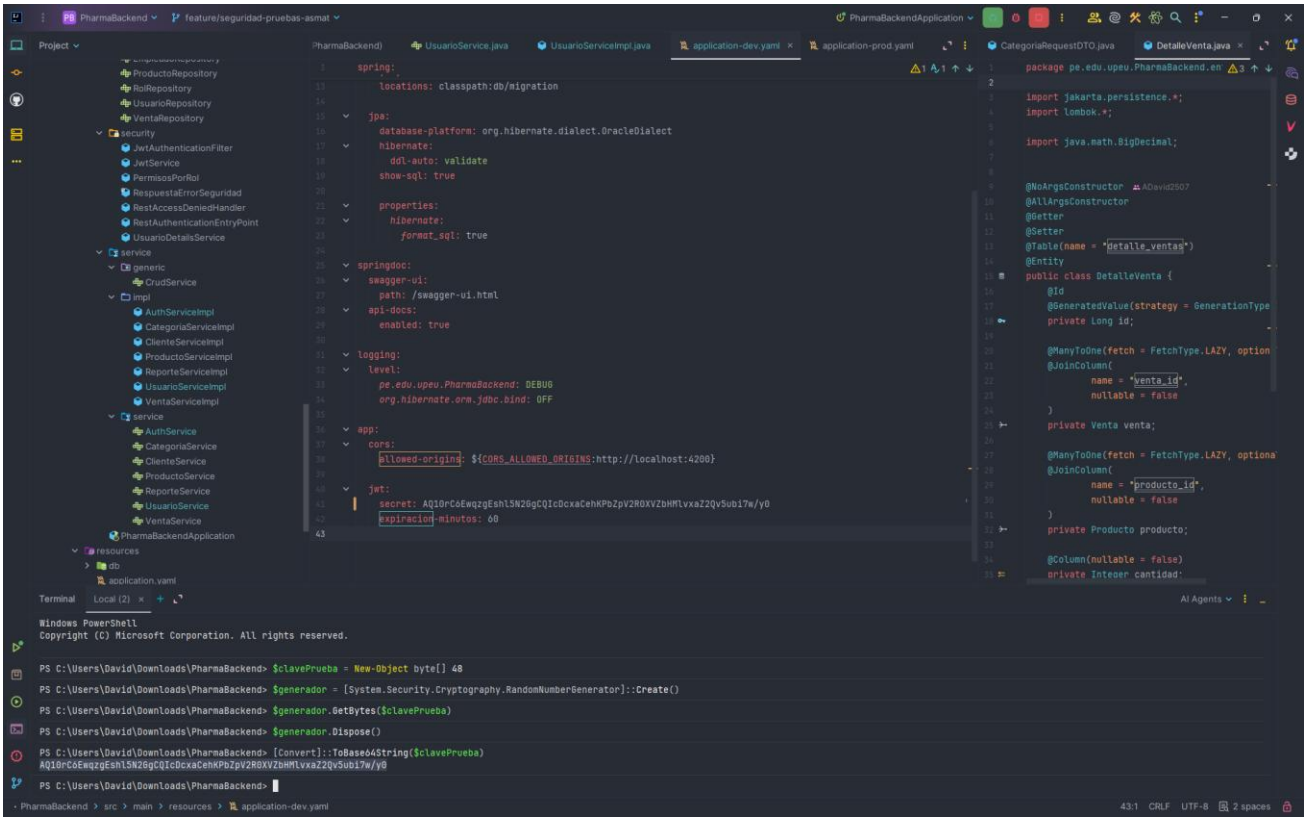
Precondición y datos utilizados: Token de vendedor válido antes del cambio de app.jwt.secret; captura del nuevo secreto y posterior petición con el token anterior.

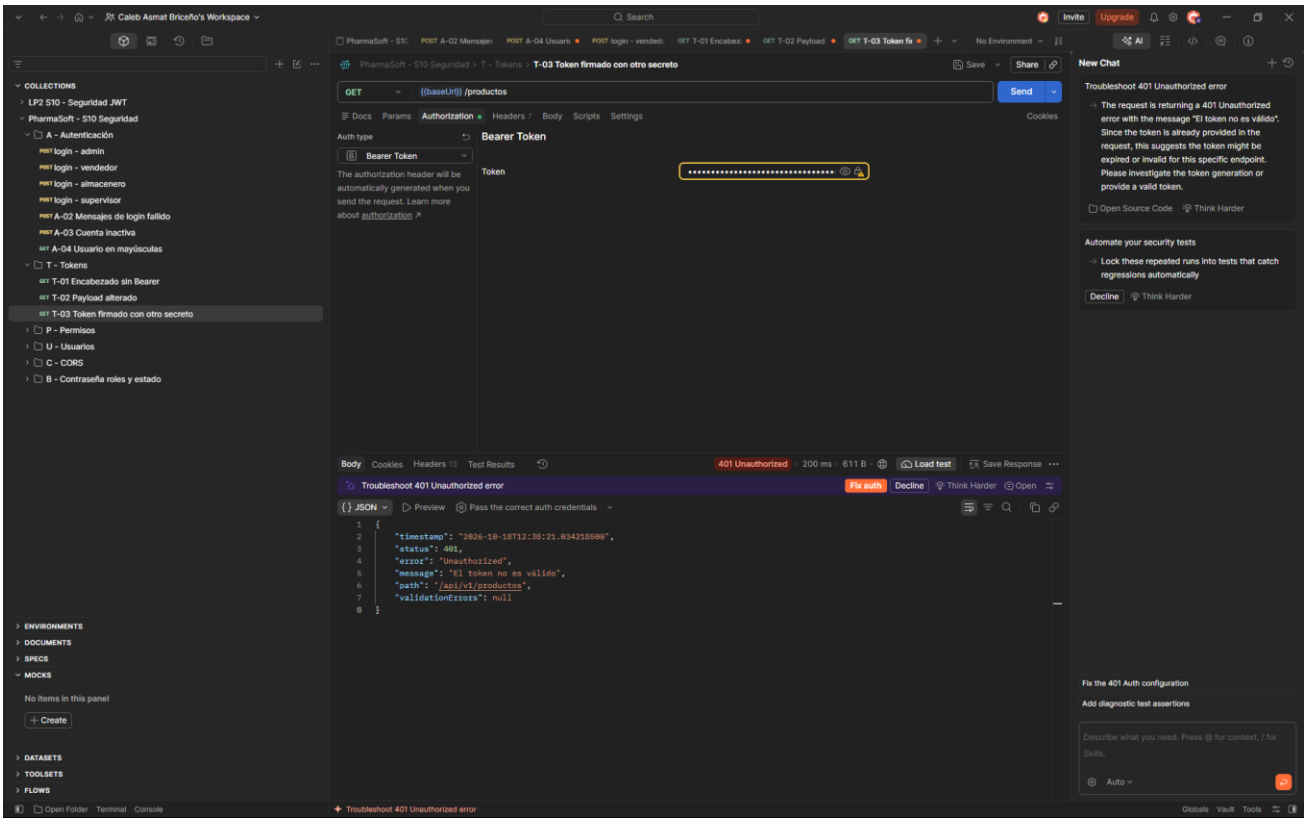
Resultado obtenido: 200 OK antes del cambio y 401 Unauthorized después; El token no es válido.

Estado: Pasa
Observaciones: La configuración con la clave temporal está incluida en una captura de desarrollo. No se transcribe el secreto en el informe.

Evidencia: 3 capturas incrustadas en la sección T-03, en el orden de las operaciones.




PharmaBackend
feature/seguridad-pruebas-asmat
PharmaBackendApplication
Project
application-dev.yaml
application-prod.yaml
UsuarioService.java
UsuarioServiceImpl.java
CategoriaRequestDTO.java
DetalleVenta.java
spring:
locations: classpath:db/migration
jpa:
database-platform: org.hibernate.dialect.OracleDialect
hibernate:
ddl-auto: validate
show-sql: true
properties:
hibernate:
format_sql: true
springdoc:
swagger-ui:
path: /swagger-ui.html
api-docs:
enabled: true
logging:
level:
pe.edu.upeu.PharmaBackend: DEBUG
org.hibernate.orm.jdbc.bind: OFF
app:
cors:
allowed-origins: ${CORS_ALLOWED_ORIGINS:http://localhost:4200}
jwt:
secret: AQ10rC6EwqzgEshl5N2GgCQIcDcxaCehKPbZpV2ROXVZbHMlvxaZ2Qv5ubi7w/y0
expiracion-minutos: 60
package pe.edu.upeu.PharmaBackend.en
import jakarta.persistence.*;
import lombok.*;
import java.math.BigDecimal;
@NoArgsConstructor
@AllArgsConstructor
@Getter
@Setter
@Table(name = "detalle_ventas")
@Entity
public class DetalleVenta {
@Id
@GeneratedValue(strategy = GenerationType
private Long id;
@ManyToOne(fetch = FetchType.LAZY, option
@JoinColumn(
name = "venta_id",
nullable = false
)
private Venta venta;
@ManyToOne(fetch = FetchType.LAZY, optiona
@JoinColumn(
name = "producto_id",
nullable = false
)
private Producto producto;
@Column(nullable = false)
private Integer cantidad;
Terminal
Local (2)
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.
PS C:\Users\David\Downloads\PharmaBackend> $clavePrueba = New-Object byte[] 48
PS C:\Users\David\Downloads\PharmaBackend> $generador = [System.Security.Cryptography.RandomNumberGenerator]::Create()
PS C:\Users\David\Downloads\PharmaBackend> $generador.GetBytes($clavePrueba)
PS C:\Users\David\Downloads\PharmaBackend> $generador.Dispose()
PS C:\Users\David\Downloads\PharmaBackend> [Convert]::ToBase64String($clavePrueba)
AQ10rC6EwqzgEshl5N2GgCQIcDcxaCehKPbZpV2ROXVZbHMlvxaZ2Qv5ubi7w/y0
PS C:\Users\David\Downloads\PharmaBackend>
PharmaBackend › src › main › resources › application-dev.yaml
43:1
CRLF
UTF-8
2 spaces


Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
LP2 S10 - Seguridad JWT
PharmaSoft - S10 Seguridad
A - Autenticación
login - admin
login - vendedor
login - almacenero
login - supervisor
A-02 Mensajes de login fallido
A-03 Cuenta inactiva
A-04 Usuario en mayúsculas
T - Tokens
T-01 Encabezado sin Bearer
T-02 Payload alterado
T-03 Token firmado con otro secreto
P - Permisos
U - Usuarios
C - CORS
B - Contraseña roles y estado
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
PharmaSoft - S10 Seguridad › T - Tokens › T-03 Token firmado con otro secreto
Save
Share
GET
{{baseUrl}} /productos
Send
Docs
Params
Authorization
Headers 7
Body
Scripts
Settings
Cookies
Auth type
Bearer Token
The authorization header will be automatically generated when you send the request. Learn more about authorization
Bearer Token
Token
Body
Cookies
Headers 13
Test Results
401 Unauthorized
200 ms
611 B
Load test
Save Response
Troubleshoot 401 Unauthorized error
Fix auth
Decline
Think Harder
Open
{ } JSON
Preview
Pass the correct auth credentials
{
"timestamp": "2026-10-18T12:38:21.034218500",
"status": 401,
"error": "Unauthorized",
"message": "El token no es válido",
"path": "/api/v1/productos",
"validationErrors": null
}
New Chat
Troubleshoot 401 Unauthorized error
The request is returning a 401 Unauthorized error with the message "El token no es válido". Since the token is already provided in the request, this suggests the token might be expired or invalid for this specific endpoint. Please investigate the token generation or provide a valid token.
Open Source Code
Think Harder
Automate your security tests
Lock these repeated runs into tests that catch regressions automatically
Decline
Think Harder
Fix the 401 Auth configuration
Add diagnostic test assertions
Describe what you need. Press @ for context, / for Skills.
Auto
Open Folder
Terminal
Console
Troubleshoot 401 Unauthorized error
Globals
Vault
Tools

T-04 Token vencido

Grupo: Token
Usuario o token: vendedor

Petición: GET /productos
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

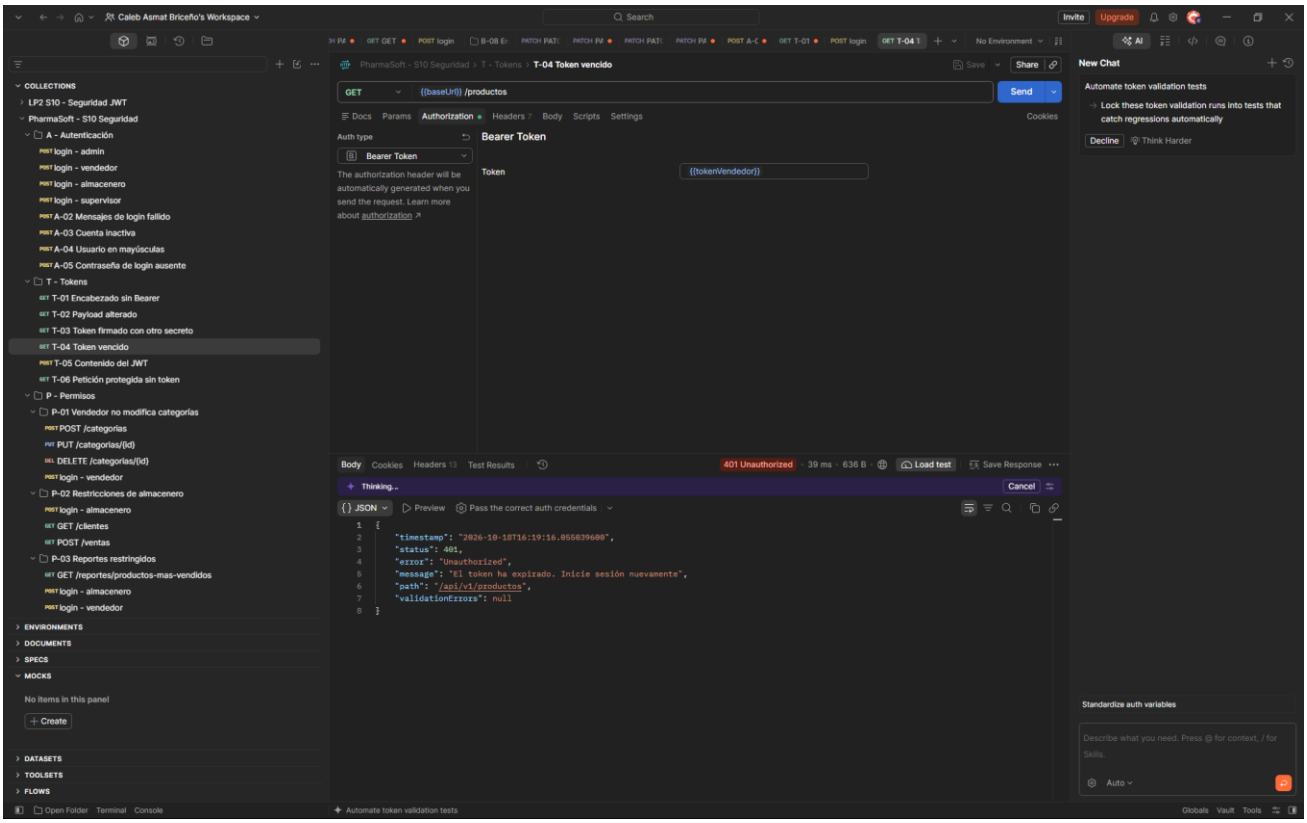
Resultado esperado: 401; El token ha expirado. Inicie sesión nuevamente.

Precondición y datos utilizados: GET /productos con Authorization de tipo Bearer Token y variable {{tokenVendedor}}. Se utiliza un JWT vencido.

Resultado obtenido: 401 Unauthorized; El token ha expirado. Inicie sesión nuevamente.

Estado: Pasa
Observaciones: La captura muestra el Bearer Token configurado y el mensaje específico de expiración.

Evidencia: 1 captura incrustada en la sección T-04, en el orden de las operaciones.



T-05 Contenido del JWT

Grupo: Token
Usuario o token: vendedor

Petición: Decodificar token del login
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

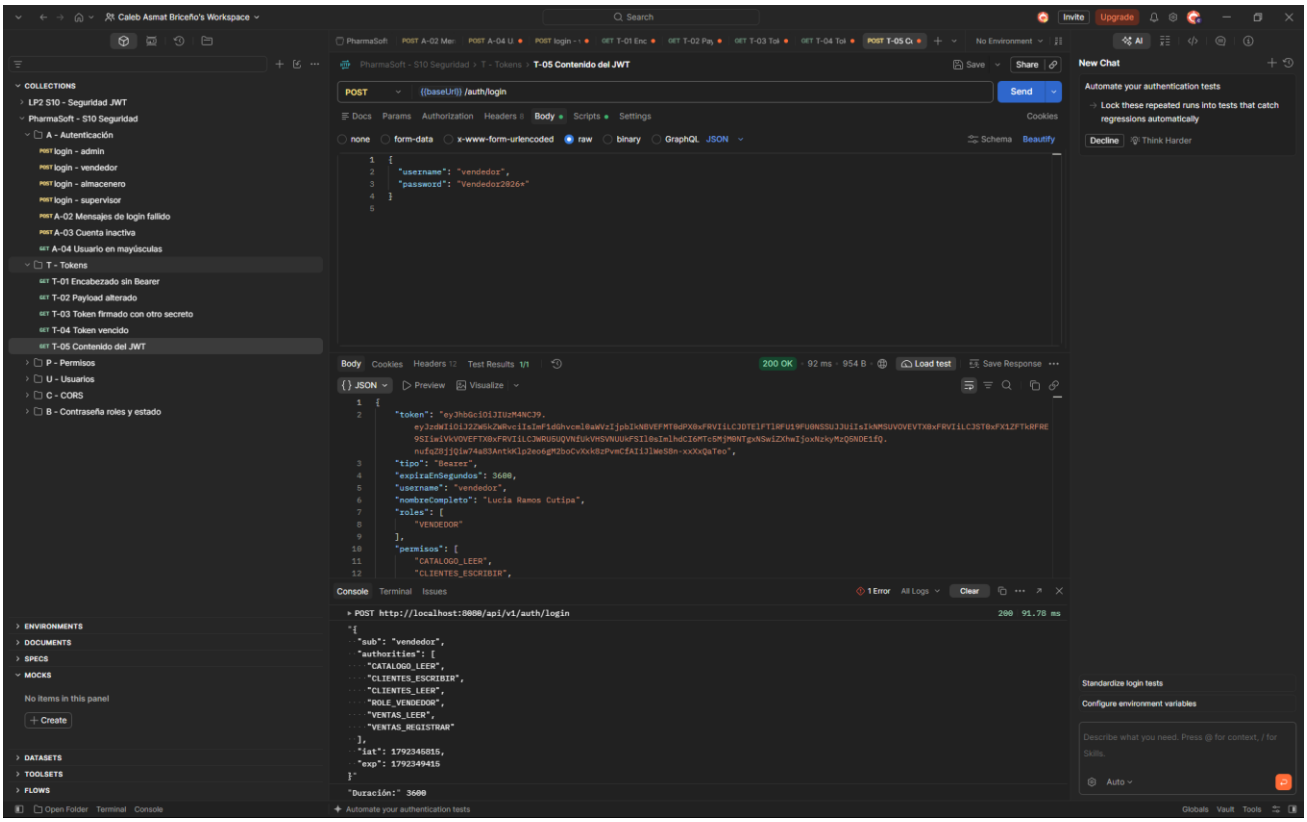
Resultado esperado: sub, authorities, iat y exp correctos; exp - iat = 3600 con configuración de 60 minutos; sin contraseña, hash ni secreto.

Precondición y datos utilizados: Login de vendedor con expiración informada de 3600 segundos y consola de Postman abierta.

Resultado obtenido: 200 OK. Payload con sub vendedor, authorities de vendedor, iat 1792345815 y exp 1792349415. Diferencia: 3600 segundos.

Estado: Pasa
Observaciones: El payload visible no contiene contraseña, hash ni secreto.

Evidencia: 1 captura incrustada en la sección T-05, en el orden de las operaciones.



P-01 Vendedor no modifica categorías

Grupo: Permisos
Usuario o token: vendedor

Petición: POST /categorias; PUT /categorias/{id}; DELETE /categorias/{id}
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

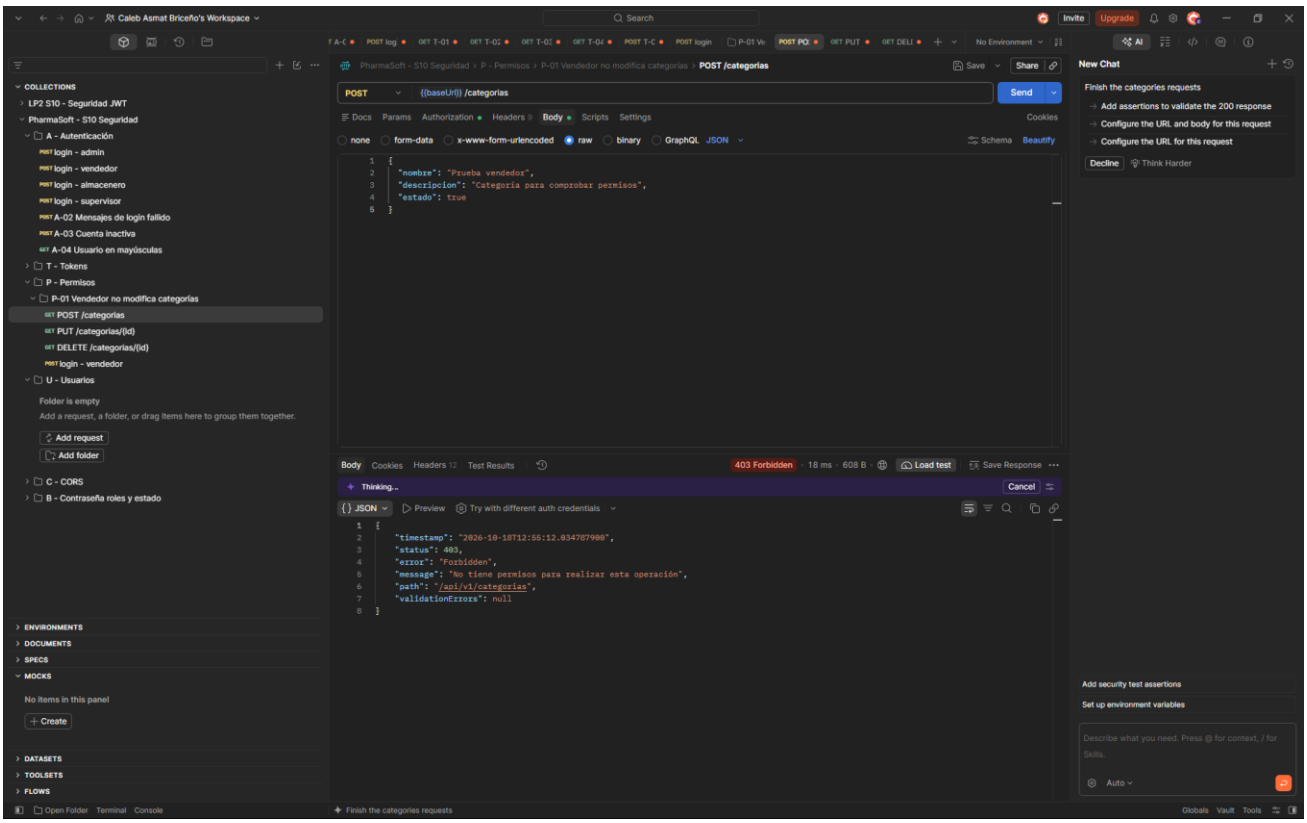
Resultado esperado: 403 en las tres peticiones.

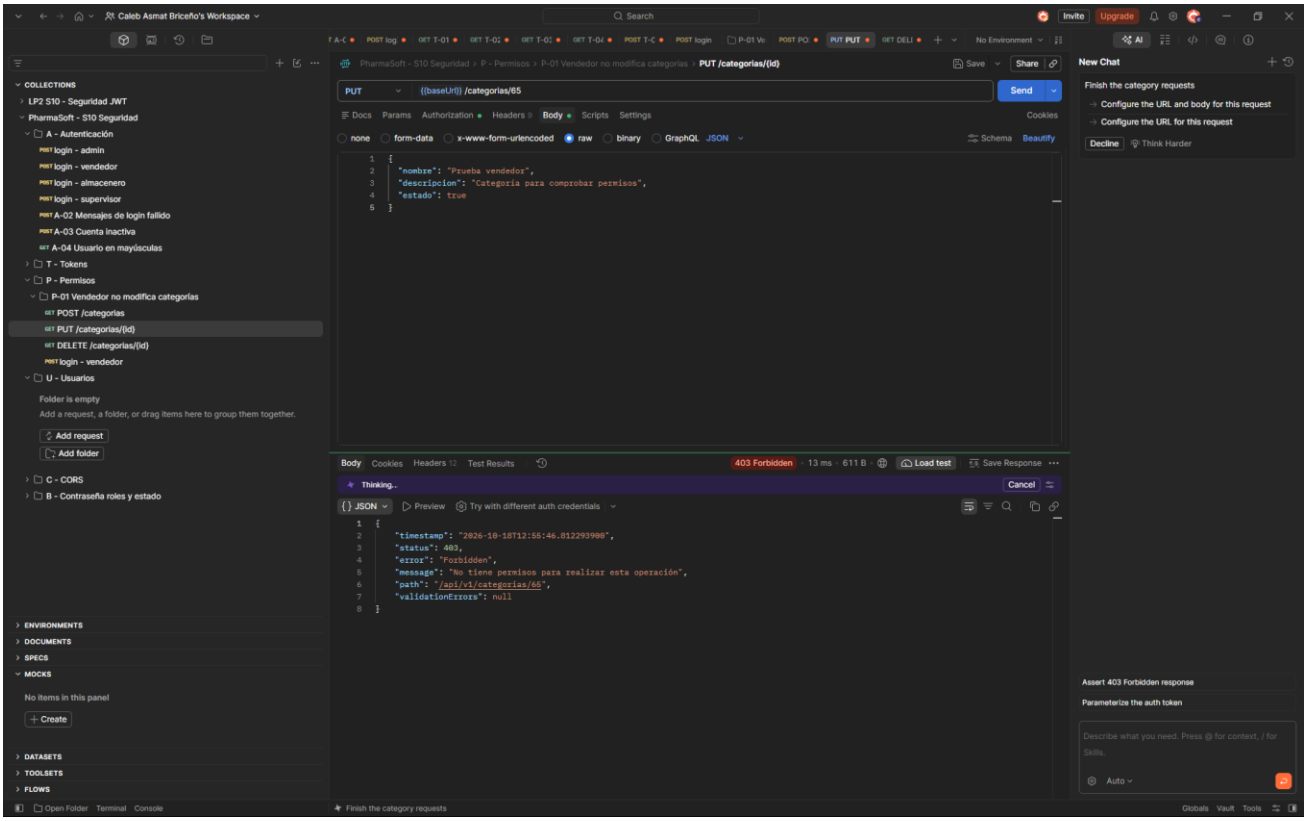
Precondición y datos utilizados: Token de vendedor. POST y PUT con nombre Prueba vendedor, descripción y estado true; categoría 65 para PUT y DELETE.

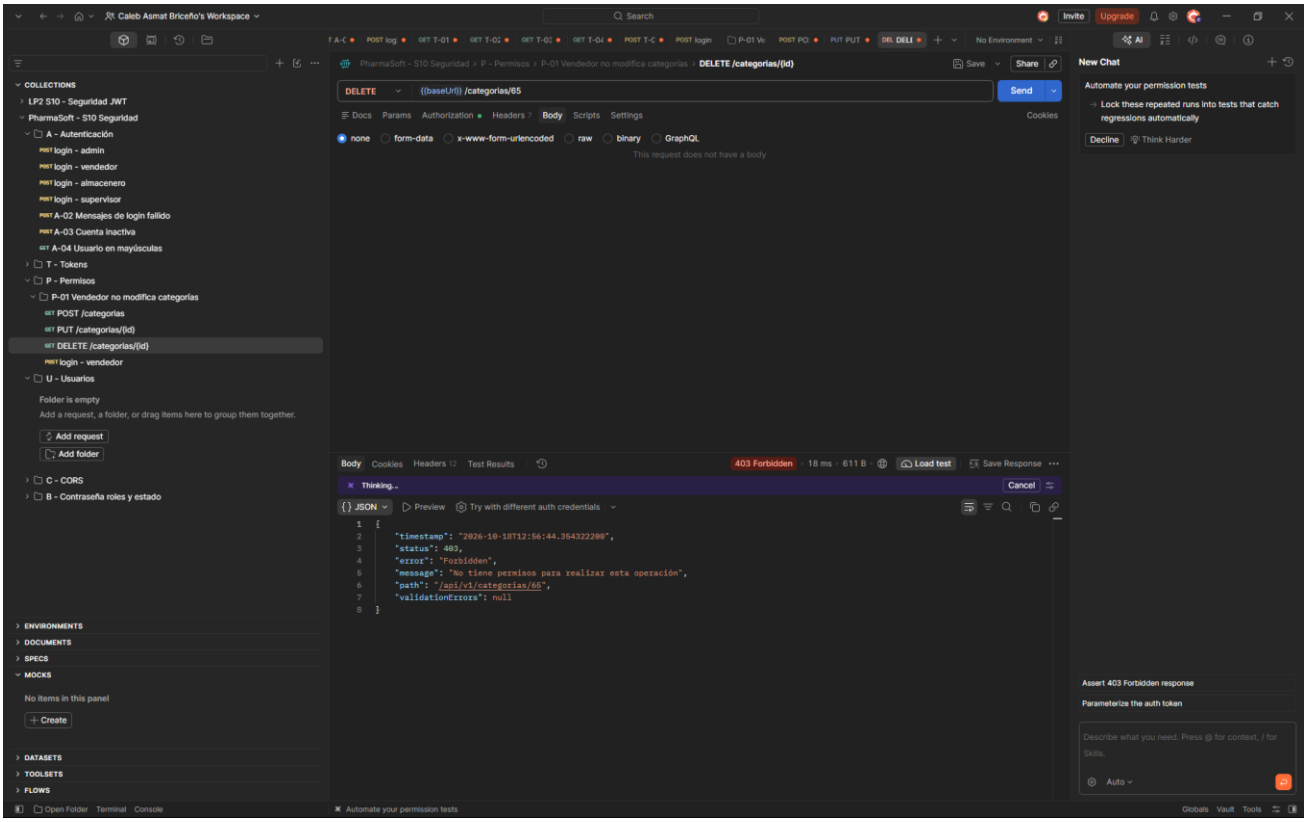
Resultado obtenido: POST, PUT y DELETE respondieron 403 Forbidden; No tiene permisos para realizar esta operación.

Estado: Pasa
Observaciones: Ninguna.

Evidencia: 3 capturas incrustadas en la sección P-01, en el orden de las operaciones.




PUT /categorias/{id}
{{baseUrl}} /categorias/65
Send
{
"nombre": "Prueba vendedor",
"descripcion": "Categoría para comprobar permisos",
"estado": true
}
403 Forbidden
{
"timestamp": "2026-10-18T12:55:46.81229390Z",
"status": 403,
"error": "Forbidden",
"message": "No tiene permisos para realizar esta operación",
"path": "/api/v1/categorias/65",
"validationErrors": null
}
New Chat
Finish the category requests
Configure the URL and body for this request
Configure the URL for this request
Decline
Assert 403 Forbidden response
Parameterize the auth token


DELETE /categorias/{id}
DELETE
{{baseUrl}} /categorias/65
Send
This request does not have a body
403 Forbidden
{
"timestamp": "2026-10-18T12:56:44.35432220Z",
"status": 403,
"error": "Forbidden",
"message": "No tiene permisos para realizar esta operación",
"path": "/api/v1/categorias/65",
"validationErrors": null
}
New Chat
Automate your permission tests
Lock these repeated runs into tests that catch regressions automatically
Decline
Assert 403 Forbidden response
Parameterize the auth token

P-02 Restricciones de almacenero

Grupo: Permisos
Usuario o token: almacen

Petición: GET /clientes; POST /ventas
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

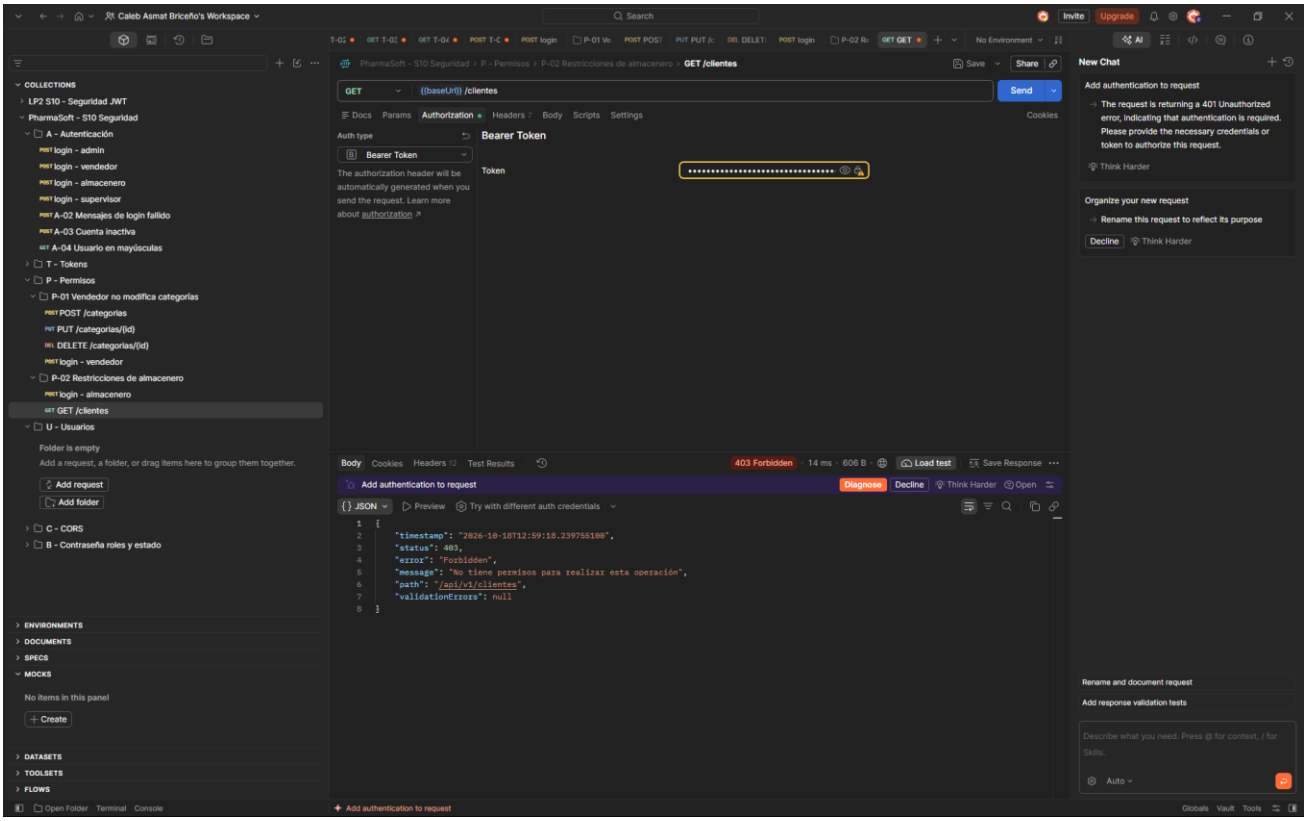
Resultado esperado: 403 en ambas peticiones.

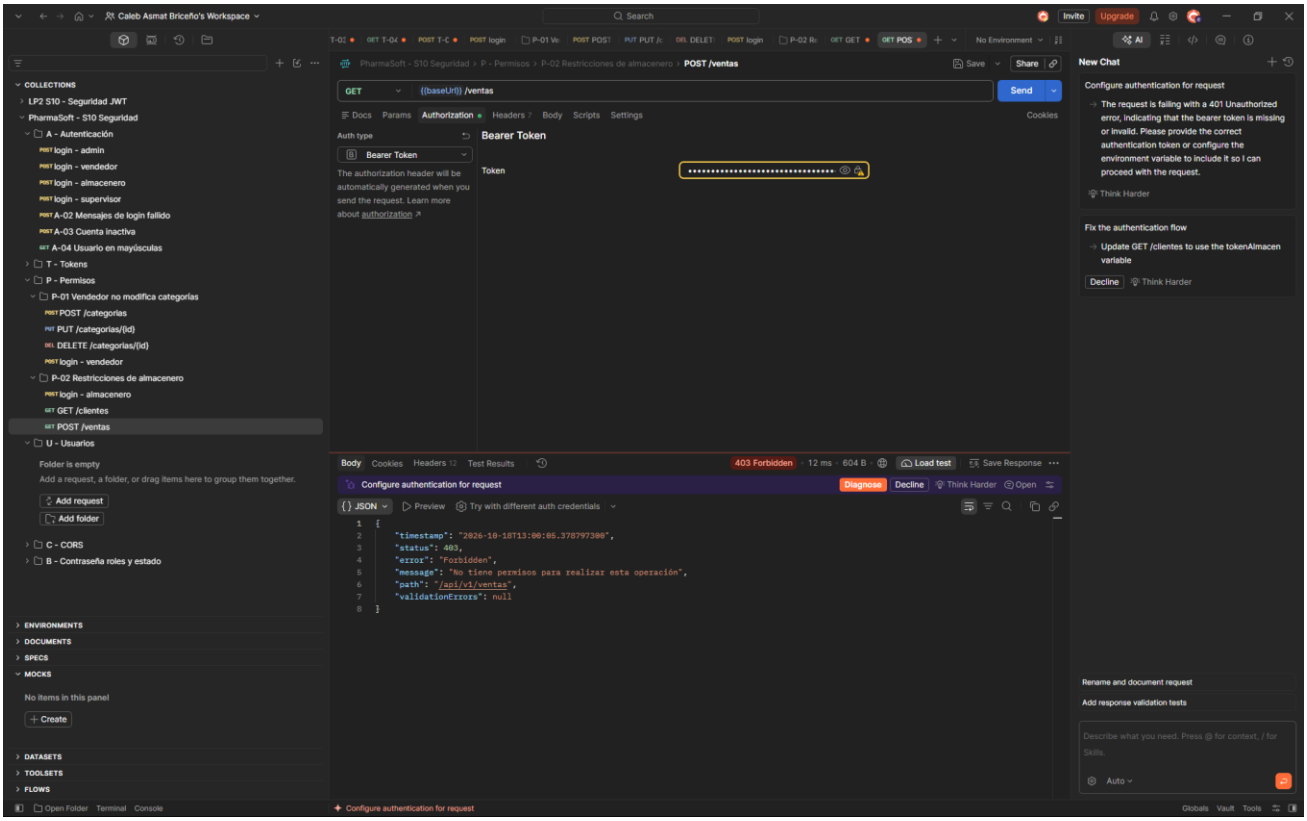
Precondición y datos utilizados: Token de almacen; GET /clientes y POST /ventas.

Resultado obtenido: 403 Forbidden en ambas peticiones; No tiene permisos para realizar esta operación.

Estado: Pasa
Observaciones: Ninguna

Evidencia: 2 capturas incrustadas en la sección P-02, en el orden de las operaciones.




Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
LP2 S10 - Seguridad JWT
PharmaSoft - S10 Seguridad
A - Autenticación
POST login - admin
POST login - vendedor
POST login - almacenero
POST login - supervisor
POST A-02 Mensajes de login fallido
POST A-03 Cuenta inactiva
GET A-04 Usuario en mayúsculas
T - Tokens
P - Permisos
P-01 Vendedor no modifica categorías
POST POST /categorías
PUT PUT /categorías/{id}
DEL DELETE /categorías/{id}
POST login - vendedor
P-02 Restricciones de almacenero
POST login - almacenero
GET GET /clientes
GET POST /ventas
U - Usuarios
Folder is empty
Add a request, a folder, or drag items here to group them together.
Add request
Add folder
C - CORS
B - Contraseña roles y estado
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
Open Folder
Terminal
Console
PharmaSoft - S10 Seguridad › P - Permisos › P-02 Restricciones de almacenero › POST /ventas
Save
Share
GET
{{baseUrl}} /ventas
Send
Docs
Params
Authorization
Headers 7
Body
Scripts
Settings
Cookies
Auth type
Bearer Token
The authorization header will be automatically generated when you send the request. Learn more about authorization
Bearer Token
Token
Body
Cookies
Headers 12
Test Results
403 Forbidden
12 ms
604 B
Load test
Save Response
Configure authentication for request
Diagnose
Decline
Think Harder
Open
JSON
Preview
Try with different auth credentials
{
"timestamp": "2026-10-18T13:00:05.37879730Z",
"status": 403,
"error": "Forbidden",
"message": "No tiene permisos para realizar esta operación",
"path": "/api/v1/ventas",
"validationErrors": null
}
Configure authentication for request
AI
New Chat
Configure authentication for request
The request is failing with a 401 Unauthorized error, indicating that the bearer token is missing or invalid. Please provide the correct authentication token or configure the environment variable to include it so I can proceed with the request.
Think Harder
Fix the authentication flow
Update GET /clientes to use the tokenAlmacen variable
Decline
Think Harder
Rename and document request
Add response validation tests
Describe what you need. Press @ for context, / for Skills.
Auto
Globals
Vault
Tools

P-03 Reportes restringidos

Grupo: Permisos
Usuario o token: vendedor y almacen

Petición: GET /reportes/productos-mas-vendidos
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

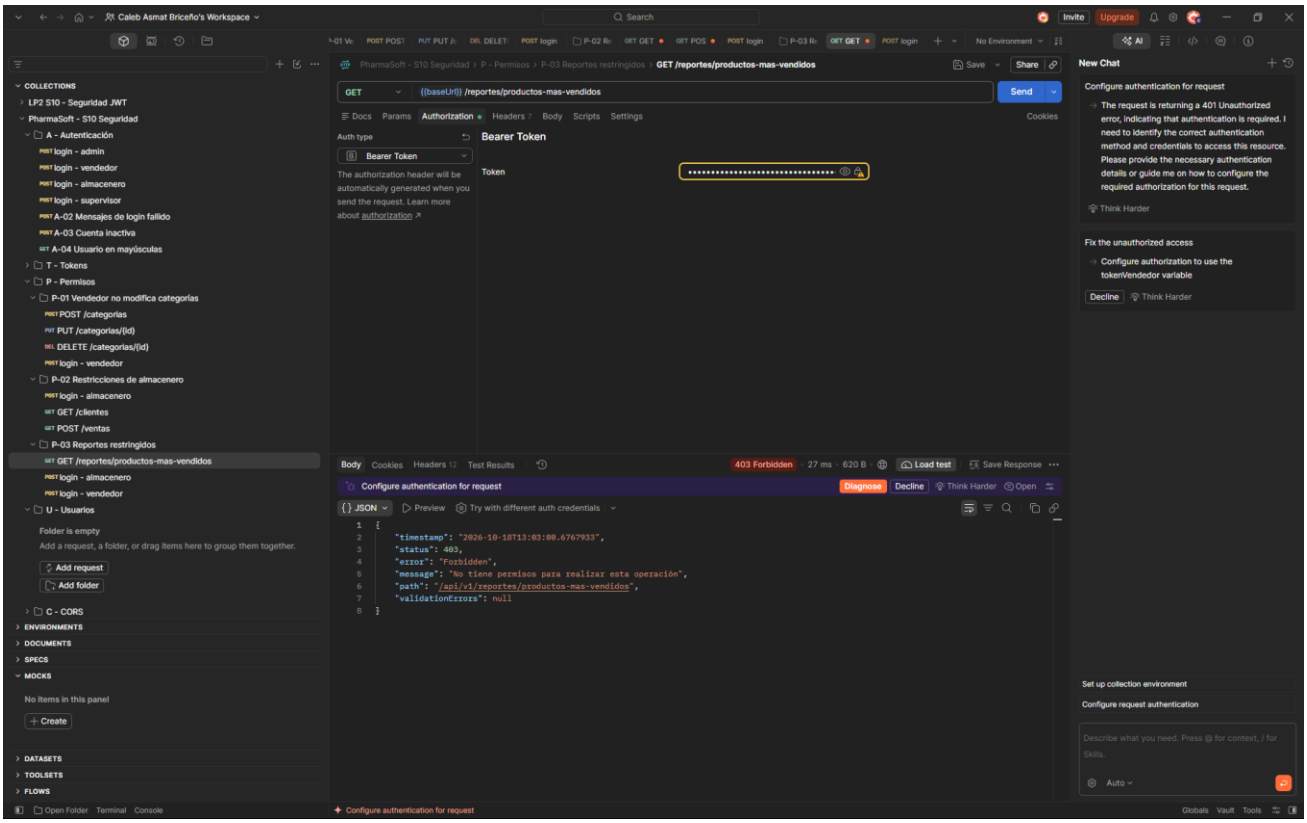
Resultado esperado: 403 para ambos usuarios; el controlador exige REPORTES_VER con @PreAuthorize.

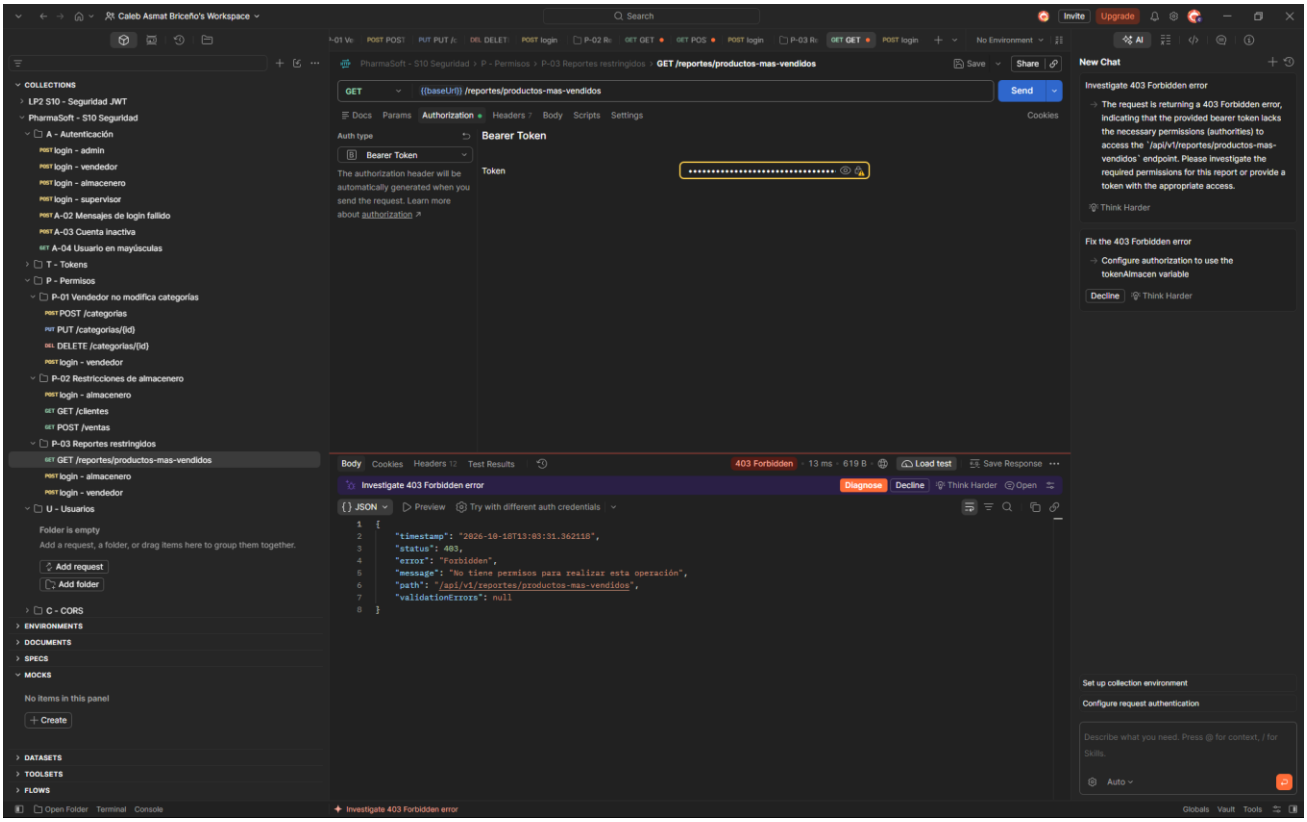
Precondición y datos utilizados: GET /reportes/productos-mas-vendidos con las credenciales de vendedor y almacen indicadas para el caso.

Resultado obtenido: 403 Forbidden en las dos capturas; No tiene permisos para realizar esta operación.

Estado: Pasa
Observaciones: Ninguna

Evidencia: 2 capturas incrustadas en la sección P-03, en el orden de las operaciones.




Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
LP2 S10 - Seguridad JWT
PharmaSoft - S10 Seguridad
A - Autenticación
login - admin
login - vendedor
login - almacenero
login - supervisor
A-02 Mensajes de login fallido
A-03 Cuenta inactiva
A-04 Usuario en mayúsculas
T - Tokens
P - Permisos
P-01 Vendedor no modifica categorías
POST /categorías
PUT /categorías/{id}
DELETE /categorías/{id}
login - vendedor
P-02 Restricciones de almacenero
login - almacenero
GET /clientes
POST /ventas
P-03 Reportes restringidos
GET /reportes/productos-mas-vendidos
login - almacenero
login - vendedor
U - Usuarios
Folder is empty
Add a request, a folder, or drag items here to group them together.
Add request
Add folder
C - CORS
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
Open Folder
Terminal
Console
PharmaSoft - S10 Seguridad › P - Permisos › P-03 Reportes restringidos › GET /reportes/productos-mas-vendidos
Save
Share
GET
{{baseUrl}} /reportes/productos-mas-vendidos
Send
Docs
Params
Authorization
Headers 7
Body
Scripts
Settings
Cookies
Auth type
Bearer Token
The authorization header will be automatically generated when you send the request. Learn more about authorization ↗
Bearer Token
Token
Body
Cookies
Headers 12
Test Results
403 Forbidden
13 ms
619 B
Load test
Save Response
Investigate 403 Forbidden error
Diagnose
Decline
Think Harder
Open
JSON
Preview
Try with different auth credentials
{
"timestamp": "2026-10-18T13:03:31.362118",
"status": 403,
"error": "Forbidden",
"message": "No tiene permisos para realizar esta operación",
"path": "/api/v1/reportes/productos-mas-vendidos",
"validationErrors": null
}
Investigate 403 Forbidden error
Globals
Vault
Tools
AI
New Chat
Investigate 403 Forbidden error
The request is returning a 403 Forbidden error, indicating that the provided bearer token lacks the necessary permissions (authorities) to access the `/api/v1/reportes/productos-mas-vendidos` endpoint. Please investigate the required permissions for this report or provide a token with the appropriate access.
Think Harder
Fix the 403 Forbidden error
Configure authorization to use the tokenAlmacen variable
Decline
Think Harder
Set up collection environment
Configure request authentication
Describe what you need. Press @ for context, / for skills.
Auto

P-04 Administrador accede a los módulos

Grupo: Permisos
Usuario o token: admin

Petición: GET /categorias; /productos; /clientes; /ventas; /reportes/productos-mas-vendidos; /usuarios; /empleados; /roles
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

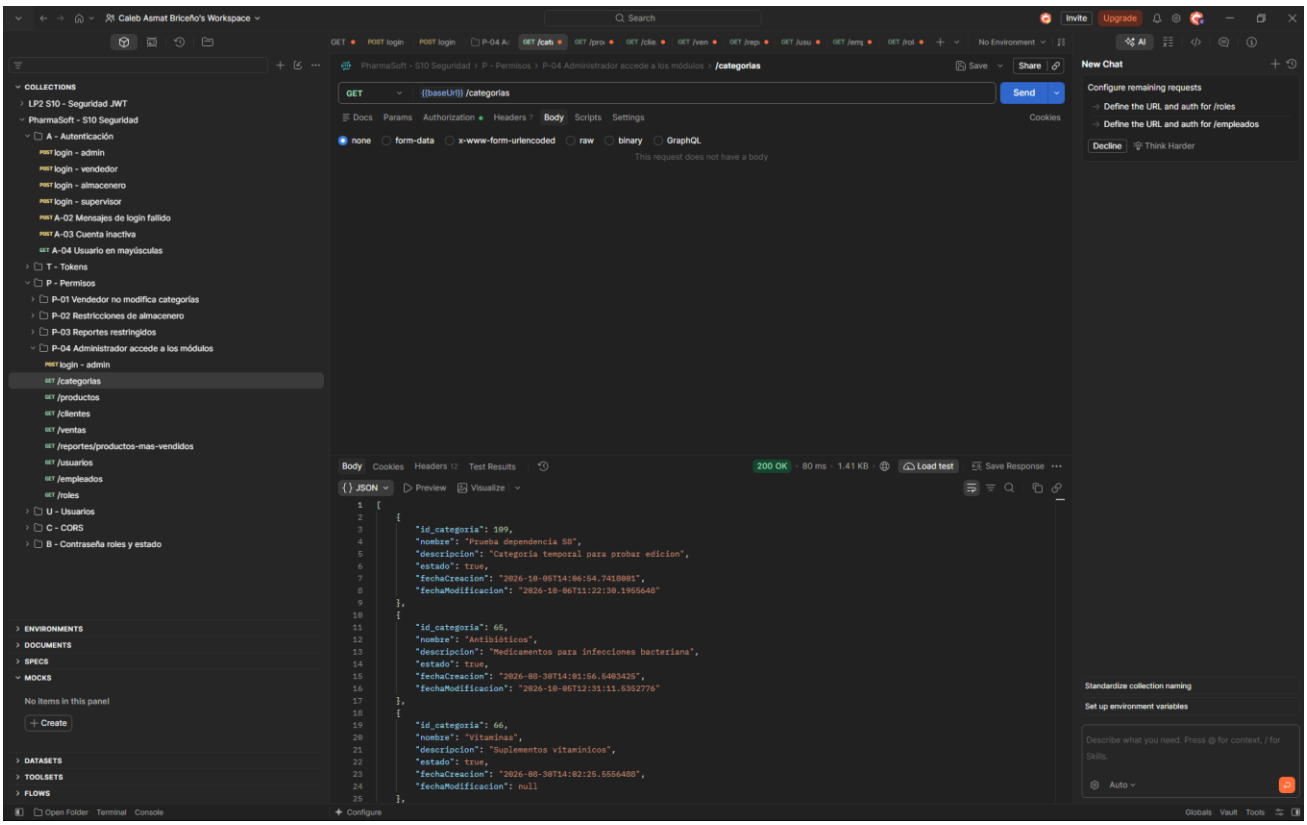
Resultado esperado: 2xx en todas las consultas.

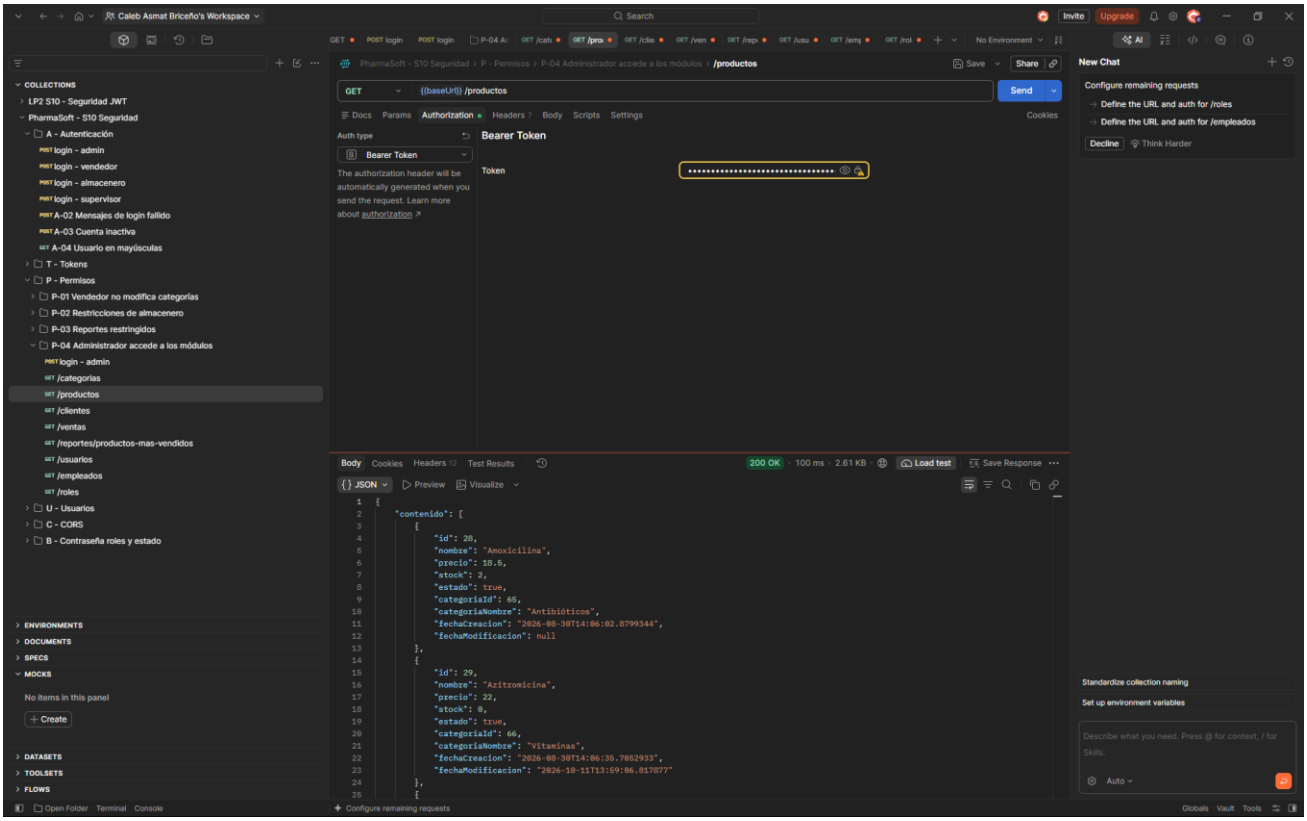
Precondición y datos utilizados: Token de admin; consultas de categorías, productos, clientes, ventas, reportes, usuarios, empleados y roles.

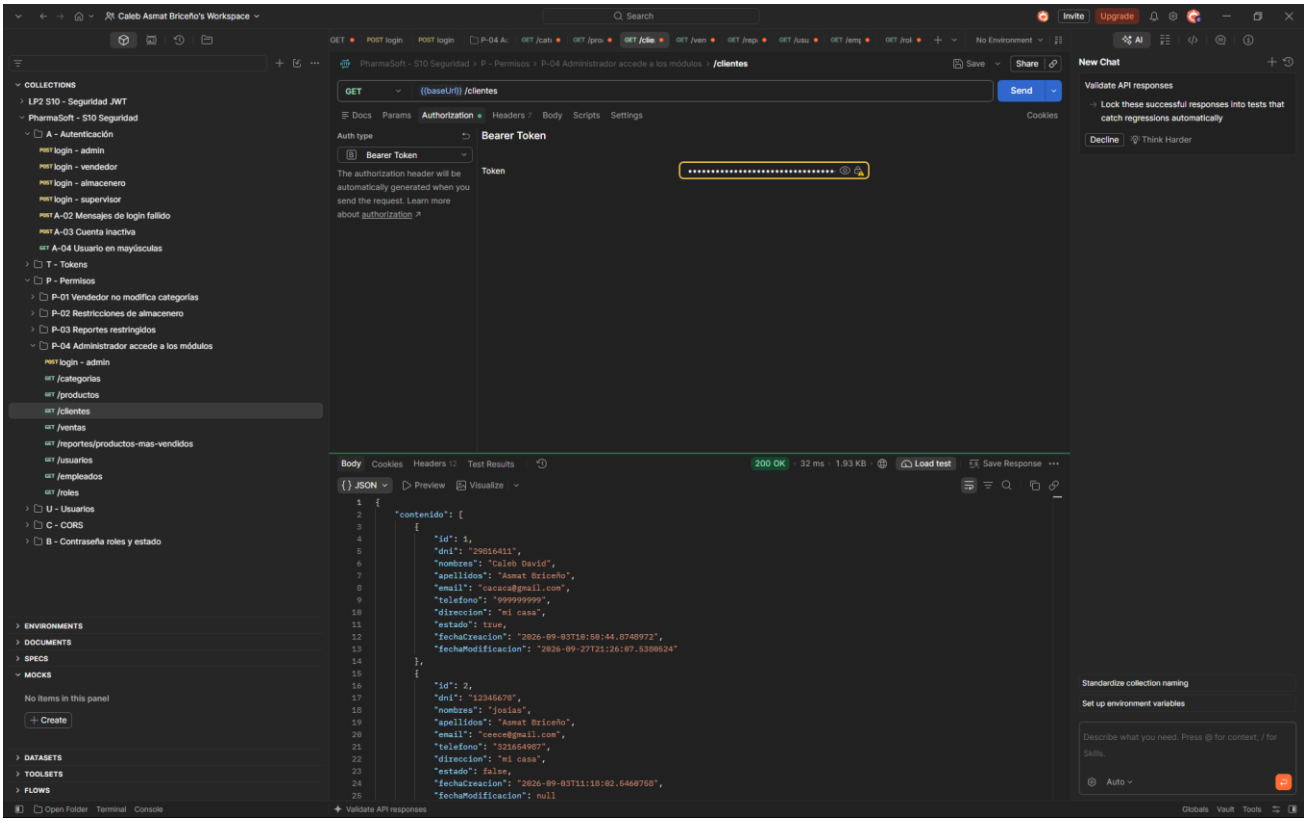
Resultado obtenido: 200 OK en las ocho consultas documentadas, con datos de cada módulo.

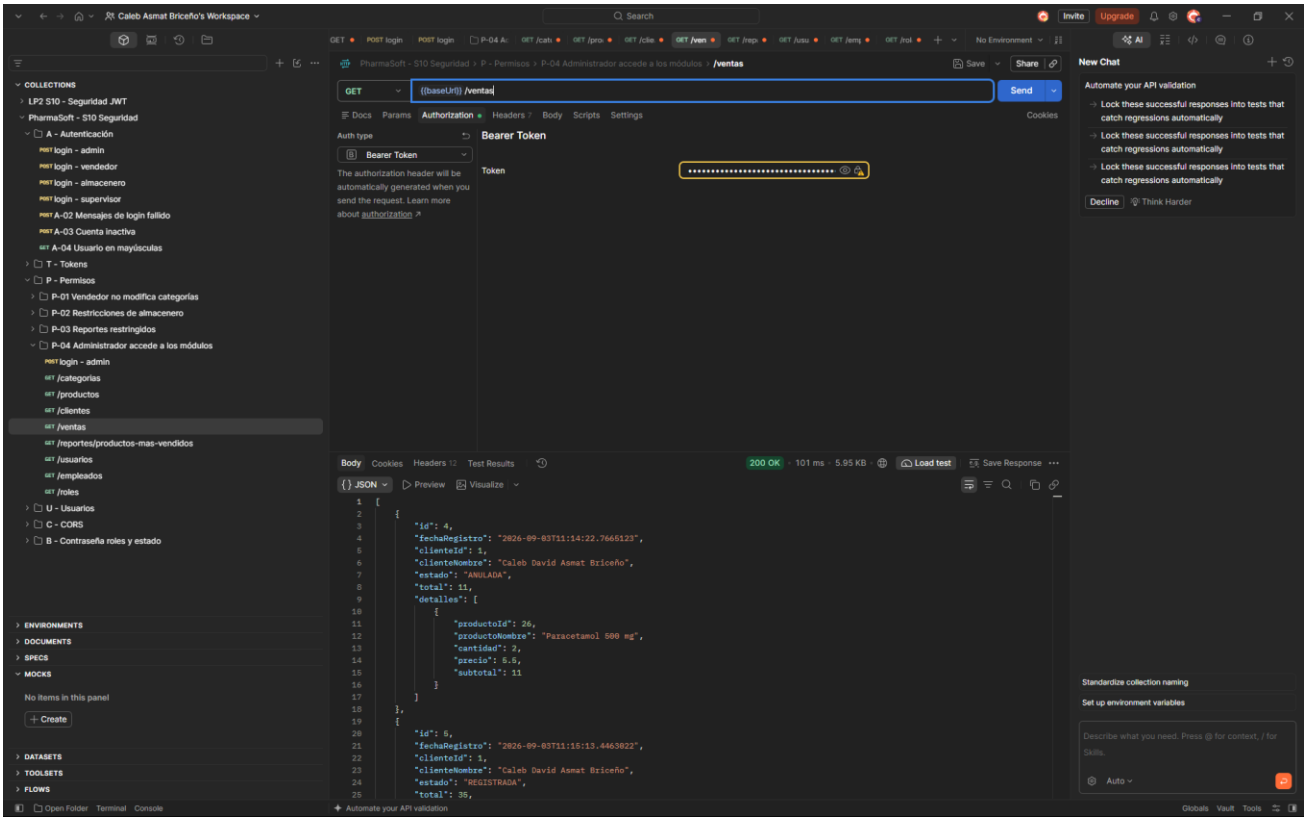
Estado: Pasa
Observaciones: Ninguna.

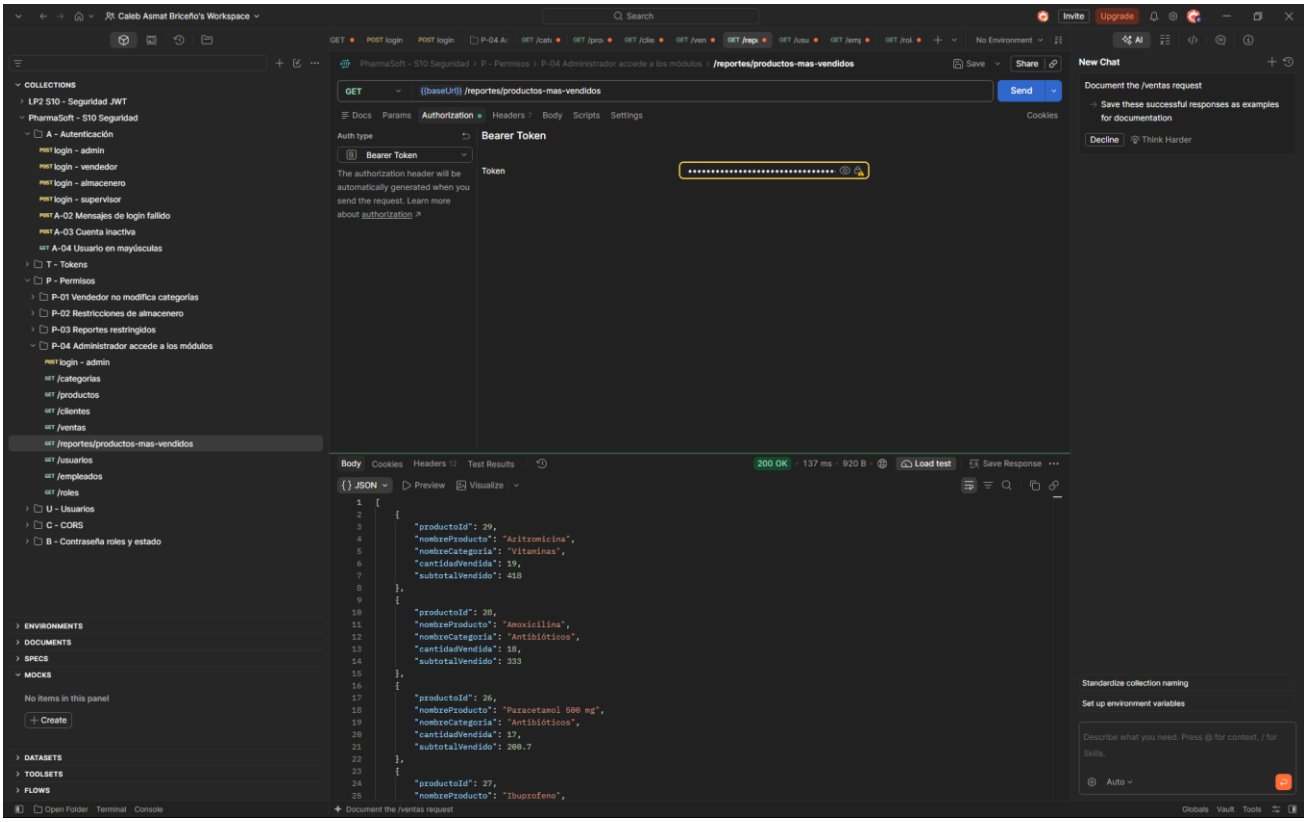
Evidencia: 8 capturas incrustadas en la sección P-04, en el orden de las operaciones.

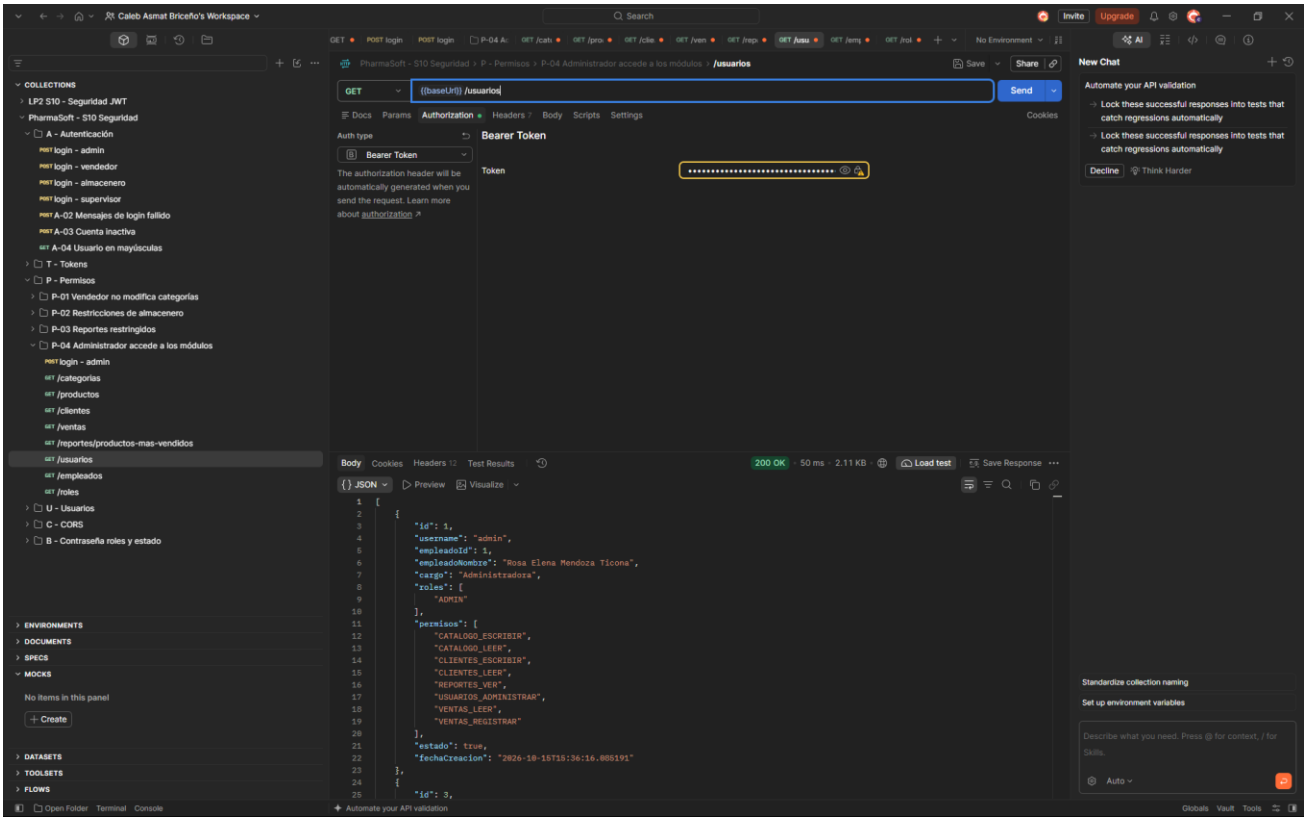


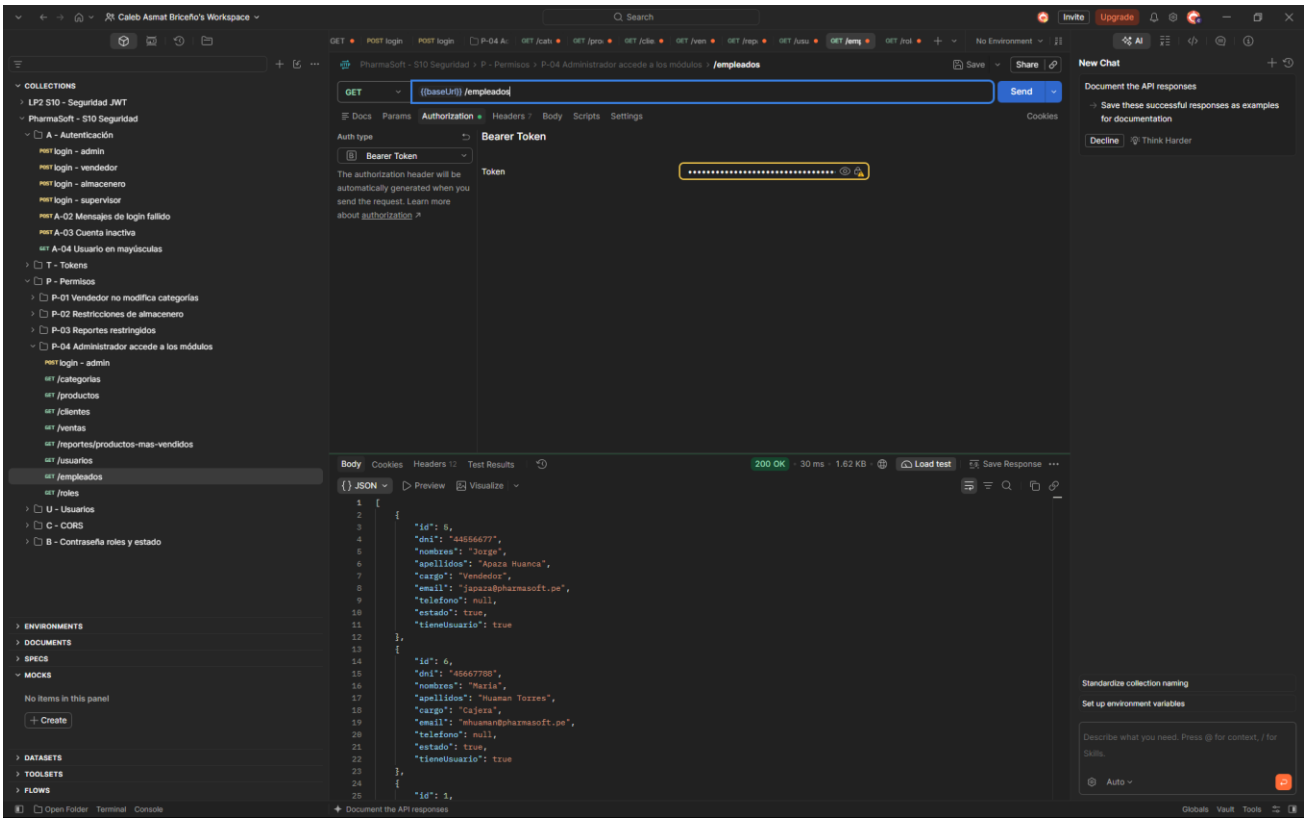

Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
LP2 S10 - Seguridad JWT
PharmaSoft - S10 Seguridad
A - Autenticación
login - admin
login - vendedor
login - almacenero
login - supervisor
A-02 Mensajes de login fallido
A-03 Cuenta inactiva
A-04 Usuario en mayúsculas
T - Tokens
P - Permisos
P-01 Vendedor no modifica categorías
P-02 Restricciones de almacenero
P-03 Reportes restringidos
P-04 Administrador accede a los módulos
login - admin
/categorías
/productos
/clientes
/ventas
/reportes/productos-mas-vendidos
/usuarios
/empleados
/roles
U - Usuarios
C - CORS
B - Contraseña roles y estado
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
PharmaSoft - S10 Seguridad › P - Permisos › P-04 Administrador accede a los módulos › /productos
Save
Share
GET
{{baseUrl}} /productos
Send
Docs
Params
Authorization
Headers 7
Body
Scripts
Settings
Cookies
Auth type
Bearer Token
Bearer Token
The authorization header will be automatically generated when you send the request. Learn more about authorization
Token
Body
Cookies
Headers 12
Test Results
200 OK
100 ms
2.61 KB
Load test
Save Response
{ } JSON
Preview
Visualize
{
"contenido": [
{
"id": 28,
"nombre": "Amoxicilina",
"precio": 18.5,
"stock": 2,
"estado": true,
"categoriaId": 65,
"categoriaNombre": "Antibióticos",
"fechaCreacion": "2026-08-30T14:06:02.8799344",
"fechaModificacion": null
},
{
"id": 29,
"nombre": "Azitromicina",
"precio": 22,
"stock": 0,
"estado": true,
"categoriaId": 66,
"categoriaNombre": "Vitaminas",
"fechaCreacion": "2026-08-30T14:06:35.7862933",
"fechaModificacion": "2026-10-11T13:59:06.817877"
},
{
New Chat
Configure remaining requests
Define the URL and auth for /roles
Define the URL and auth for /empleados
Decline
Think Harder
Standardize collection naming
Set up environment variables
Describe what you need. Press @ for context, / for Skills.
Auto
Open Folder
Terminal
Console
Configure remaining requests
Globals
Vault
Tools

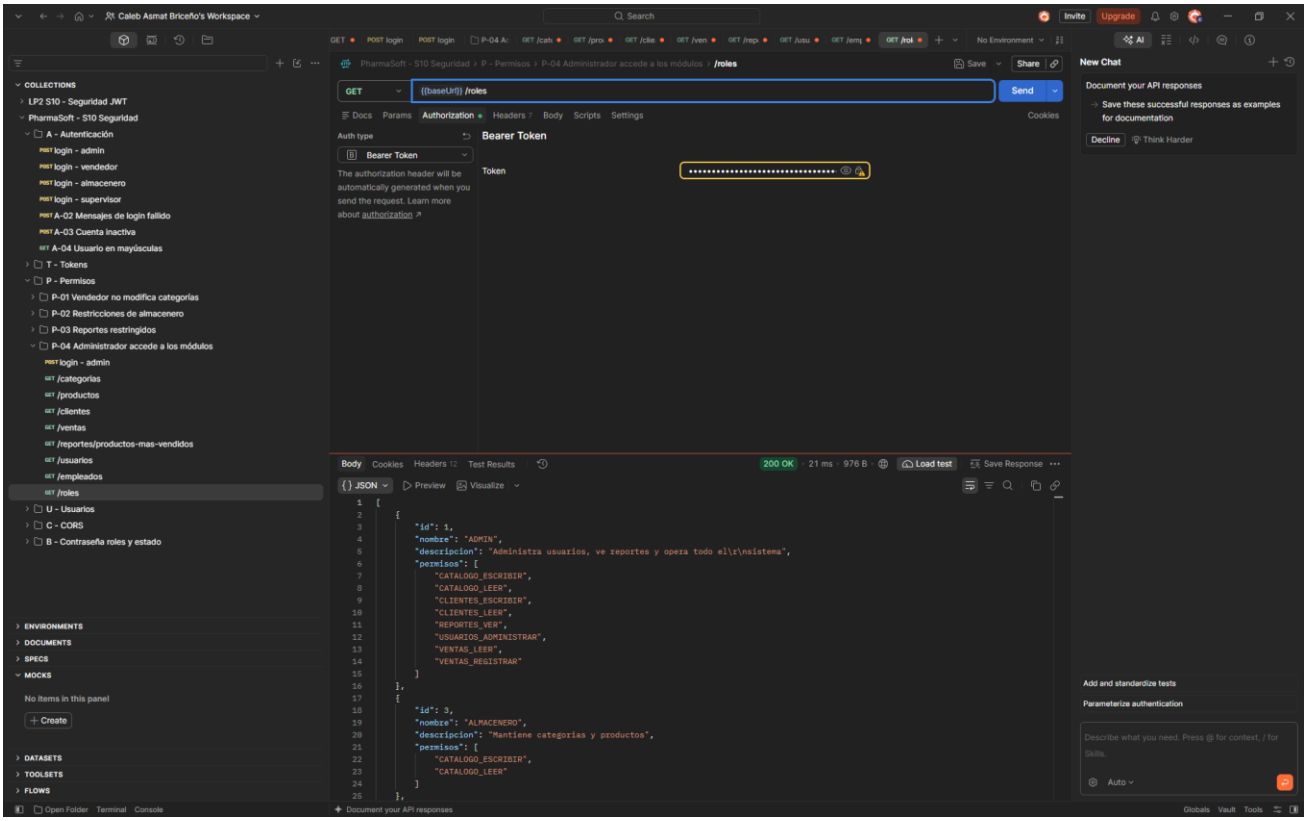

Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
LP2 S10 - Seguridad JWT
PharmaSoft - S10 Seguridad
A - Autenticación
login - admin
login - vendedor
login - almacenero
login - supervisor
A-02 Mensajes de login fallido
A-03 Cuenta inactiva
A-04 Usuario en mayúsculas
T - Tokens
P - Permisos
P-01 Vendedor no modifica categorías
P-02 Restricciones de almacenero
P-03 Reportes restringidos
P-04 Administrador accede a los módulos
login - admin
/categorías
/productos
/clientes
/ventas
/reportes/productos-mas-vendidos
/usuarios
/empleados
/roles
U - Usuarios
C - CORS
B - Contraseña roles y estado
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
PharmaSoft - S10 Seguridad › P - Permisos › P-04 Administrador accede a los módulos › /clientes
Save
Share
GET
{{baseUrl}} /clientes
Send
Docs
Params
Authorization
Headers 7
Body
Scripts
Settings
Cookies
Auth type
Bearer Token
Bearer Token
The authorization header will be automatically generated when you send the request. Learn more about authorization
Token
Body
Cookies
Headers 12
Test Results
200 OK
32 ms
1.93 KB
Load test
Save Response
{ } JSON
Preview
Visualize
{
"contenido": [
{
"id": 1,
"dni": "29816411",
"nombres": "Caleb David",
"apellidos": "Asmat Briceño",
"email": "cacaca@gmail.com",
"telefono": "999999999",
"direccion": "mi casa",
"estado": true,
"fechaCreacion": "2026-09-03T10:50:44.8748972",
"fechaModificacion": "2026-09-27T21:26:07.6308524"
},
{
"id": 2,
"dni": "12345678",
"nombres": "josias",
"apellidos": "Asmat Briceño",
"email": "ceece@gmail.com",
"telefono": "321654987",
"direccion": "mi casa",
"estado": false,
"fechaCreacion": "2026-09-03T11:18:02.6460758",
"fechaModificacion": null
New Chat
Validate API responses
Lock these successful responses into tests that catch regressions automatically
Decline
Think Harder
Standardize collection naming
Set up environment variables
Describe what you need. Press @ for context, / for Skills.
Auto
Open Folder
Terminal
Console
Validate API responses
Globals
Vault
Tools


Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
LP2 S10 - Seguridad JWT
PharmaSoft - S10 Seguridad
A - Autenticación
login - admin
login - vendedor
login - almacenero
login - supervisor
A-02 Mensajes de login fallido
A-03 Cuenta inactiva
A-04 Usuario en mayúsculas
T - Tokens
P - Permisos
P-01 Vendedor no modifica categorías
P-02 Restricciones de almacenero
P-03 Reportes restringidos
P-04 Administrador accede a los módulos
login - admin
/categorías
/productos
/clientes
/ventas
/reportes/productos-mas-vendidos
/usuarios
/empleados
/roles
U - Usuarios
C - CORS
B - Contraseña roles y estado
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
PharmaSoft - S10 Seguridad › P - Permisos › P-04 Administrador accede a los módulos › /ventas
Save
Share
GET
{{baseUrl}} /ventas
Send
Docs
Params
Authorization
Headers 7
Body
Scripts
Settings
Cookies
Auth type
Bearer Token
The authorization header will be automatically generated when you send the request. Learn more about authorization
Bearer Token
Token
Body
Cookies
Headers 12
Test Results
200 OK
101 ms
5.95 KB
Load test
Save Response
{ } JSON
Preview
Visualize
[
{
"id": 4,
"fechaRegistro": "2026-09-03T11:14:22.7666123",
"clienteId": 1,
"clienteNombre": "Caleb David Asmat Briceño",
"estado": "ANULADA",
"total": 11,
"detalles": [
{
"productoId": 26,
"productoNombre": "Paracetamol 500 mg",
"cantidad": 2,
"precio": 5.5,
"subtotal": 11
}
]
},
{
"id": 6,
"fechaRegistro": "2026-09-03T11:15:13.4463022",
"clienteId": 1,
"clienteNombre": "Caleb David Asmat Briceño",
"estado": "REGISTRADA",
"total": 35,
New Chat
Automate your API validation
Lock these successful responses into tests that catch regressions automatically
Lock these successful responses into tests that catch regressions automatically
Lock these successful responses into tests that catch regressions automatically
Decline
Think Harder
Standardize collection naming
Set up environment variables
Describe what you need. Press @ for context, / for Skills.
Auto
Open Folder
Terminal
Console
Automate your API validation
Globals
Vault
Tools


Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
LP2 S10 - Seguridad JWT
PharmaSoft - S10 Seguridad
A - Autenticación
login - admin
login - vendedor
login - almacenero
login - supervisor
A-02 Mensajes de login fallido
A-03 Cuenta inactiva
A-04 Usuario en mayúsculas
T - Tokens
P - Permisos
P-01 Vendedor no modifica categorías
P-02 Restricciones de almacenero
P-03 Reportes restringidos
P-04 Administrador accede a los módulos
login - admin
/categorías
/productos
/clientes
/ventas
/reportes/productos-mas-vendidos
/usuarios
/empleados
/roles
U - Usuarios
C - CORS
B - Contraseña roles y estado
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
PharmaSoft - S10 Seguridad › P - Permisos › P-04 Administrador accede a los módulos › /reportes/productos-mas-vendidos
Save
Share
GET
{{baseUrl}} /reportes/productos-mas-vendidos
Send
Docs
Params
Authorization
Headers 7
Body
Scripts
Settings
Cookies
Auth type
Bearer Token
The authorization header will be automatically generated when you send the request. Learn more about authorization
Bearer Token
Token
Body
Cookies
Headers 12
Test Results
200 OK
137 ms
920 B
Load test
Save Response
{ } JSON
Preview
Visualize
[
{
"productoId": 29,
"nombreProducto": "Azitromicina",
"nombreCategoria": "Vitaminas",
"cantidadVendida": 19,
"subtotalVendido": 418
},
{
"productoId": 28,
"nombreProducto": "Amoxicilina",
"nombreCategoria": "Antibióticos",
"cantidadVendida": 18,
"subtotalVendido": 333
},
{
"productoId": 26,
"nombreProducto": "Paracetamol 500 mg",
"nombreCategoria": "Antibióticos",
"cantidadVendida": 17,
"subtotalVendido": 200.7
},
{
"productoId": 27,
"nombreProducto": "Ibuprofeno",
New Chat
Document the /ventas request
Save these successful responses as examples for documentation
Decline
Think Harder
Standardize collection naming
Set up environment variables
Describe what you need. Press @ for context, / for Skills.
Auto
Open Folder
Terminal
Console
Document the /ventas request
Globals
Vault
Tools


Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
LP2 S10 - Seguridad JWT
PharmaSoft - S10 Seguridad
A - Autenticación
login - admin
login - vendedor
login - almacenero
login - supervisor
A-02 Mensajes de login fallido
A-03 Cuenta inactiva
A-04 Usuario en mayúsculas
T - Tokens
P - Permisos
P-01 Vendedor no modifica categorías
P-02 Restricciones de almacenero
P-03 Reportes restringidos
P-04 Administrador accede a los módulos
login - admin
/categorías
/productos
/clientes
/ventas
/reportes/productos-mas-vendidos
/usuarios
/empleados
/roles
U - Usuarios
C - CORS
B - Contraseña roles y estado
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
PharmaSoft - S10 Seguridad > P - Permisos > P-04 Administrador accede a los módulos > /usuarios
Save
Share
GET
{{baseUrl}} /usuarios
Send
Docs
Params
Authorization
Headers 7
Body
Scripts
Settings
Cookies
Auth type
Bearer Token
The authorization header will be automatically generated when you send the request. Learn more about authorization
Bearer Token
Token
Body
Cookies
Headers 12
Test Results
200 OK
50 ms
2.11 KB
Load test
Save Response
JSON
Preview
Visualize
[
{
"id": 1,
"username": "admin",
"empleadoId": 1,
"empleadoNombre": "Rosa Elena Mendoza Ticona",
"cargo": "Administradora",
"roles": [
"ADMIN"
],
"permisos": [
"CATALOGO_ESCRIBIR",
"CATALOGO_LEER",
"CLIENTES_ESCRIBIR",
"CLIENTES_LEER",
"REPORTES_VER",
"USUARIOS_ADMINISTRAR",
"VENTAS_LEER",
"VENTAS_REGISTRAR"
],
"estado": true,
"fechaCreacion": "2026-10-15T15:36:16.085191"
},
{
"id": 3,
New Chat
Automate your API validation
Lock these successful responses into tests that catch regressions automatically
Lock these successful responses into tests that catch regressions automatically
Decline
Think Harder
Standardize collection naming
Set up environment variables
Describe what you need. Press @ for context, / for Skills.
Auto
Open Folder
Terminal
Console
Automate your API validation
Globals
Vault
Tools


Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
LP2 S10 - Seguridad JWT
PharmaSoft - S10 Seguridad
A - Autenticación
login - admin
login - vendedor
login - almacenero
login - supervisor
A-02 Mensajes de login fallido
A-03 Cuenta inactiva
A-04 Usuario en mayúsculas
T - Tokens
P - Permisos
P-01 Vendedor no modifica categorías
P-02 Restricciones de almacenero
P-03 Reportes restringidos
P-04 Administrador accede a los módulos
login - admin
/categorías
/productos
/clientes
/ventas
/reportes/productos-mas-vendidos
/usuarios
/empleados
/roles
U - Usuarios
C - CORS
B - Contraseña roles y estado
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
PharmaSoft - S10 Seguridad > P - Permisos > P-04 Administrador accede a los módulos > /empleados
Save
Share
GET
{{baseUrl}} /empleados
Send
Docs
Params
Authorization
Headers 7
Body
Scripts
Settings
Cookies
Auth type
Bearer Token
The authorization header will be automatically generated when you send the request. Learn more about authorization
Bearer Token
Token
Body
Cookies
Headers 12
Test Results
200 OK
30 ms
1.62 KB
Load test
Save Response
JSON
Preview
Visualize
[
{
"id": 5,
"dni": "44556677",
"nombres": "Jorge",
"apellidos": "Apaza Huanca",
"cargo": "Vendedor",
"email": "japaza@pharmasoft.pe",
"telefono": null,
"estado": true,
"tieneUsuario": true
},
{
"id": 6,
"dni": "45667788",
"nombres": "Maria",
"apellidos": "Huaman Torres",
"cargo": "Cajera",
"email": "mhuaman@pharmasoft.pe",
"telefono": null,
"estado": true,
"tieneUsuario": true
},
{
"id": 1,
New Chat
Document the API responses
Save these successful responses as examples for documentation
Decline
Think Harder
Standardize collection naming
Set up environment variables
Describe what you need. Press @ for context, / for Skills.
Auto
Open Folder
Terminal
Console
Document the API responses
Globals
Vault
Tools


Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
LP2 S10 - Seguridad JWT
PharmaSoft - S10 Seguridad
A - Autenticación
login - admin
login - vendedor
login - almacenero
login - supervisor
A-02 Mensajes de login fallido
A-03 Cuenta inactiva
A-04 Usuario en mayúsculas
T - Tokens
P - Permisos
P-01 Vendedor no modifica categorías
P-02 Restricciones de almacenero
P-03 Reportes restringidos
P-04 Administrador accede a los módulos
login - admin
/categorías
/productos
/clientes
/ventas
/reportes/productos-mas-vendidos
/usuarios
/empleados
/roles
U - Usuarios
C - CORS
B - Contraseña roles y estado
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
PharmaSoft - S10 Seguridad › P - Permisos › P-04 Administrador accede a los módulos › /roles
Save
Share
GET
{{baseUrl}} /roles
Send
Docs
Params
Authorization
Headers 7
Body
Scripts
Settings
Cookies
Auth type
Bearer Token
The authorization header will be automatically generated when you send the request. Learn more about authorization
Bearer Token
Token
Body
Cookies
Headers 12
Test Results
200 OK
21 ms
976 B
Load test
Save Response
JSON
Preview
Visualize
[
{
"id": 1,
"nombre": "ADMIN",
"descripcion": "Administra usuarios, ve reportes y opera todo el\r\nsistema",
"permisos": [
"CATALOGO_ESCRIBIR",
"CATALOGO_LEER",
"CLIENTES_ESCRIBIR",
"CLIENTES_LEER",
"REPORTES_VER",
"USUARIOS_ADMINISTRAR",
"VENTAS_LEER",
"VENTAS_REGISTRAR"
]
},
{
"id": 3,
"nombre": "ALMACENERO",
"descripcion": "Mantiene categorías y productos",
"permisos": [
"CATALOGO_ESCRIBIR",
"CATALOGO_LEER"
]
},
Open Folder
Terminal
Console
Document your API responses
Globals
Vault
Tools
AI
New Chat
Document your API responses
Save these successful responses as examples for documentation
Decline
Think Harder
Add and standardize tests
Parameterize authentication
Describe what you need. Press @ for context, / for Skills.
Auto

U-01 Validación del alta de usuario

Grupo: Usuarios
Usuario o token: admin

Petición: POST /usuarios
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

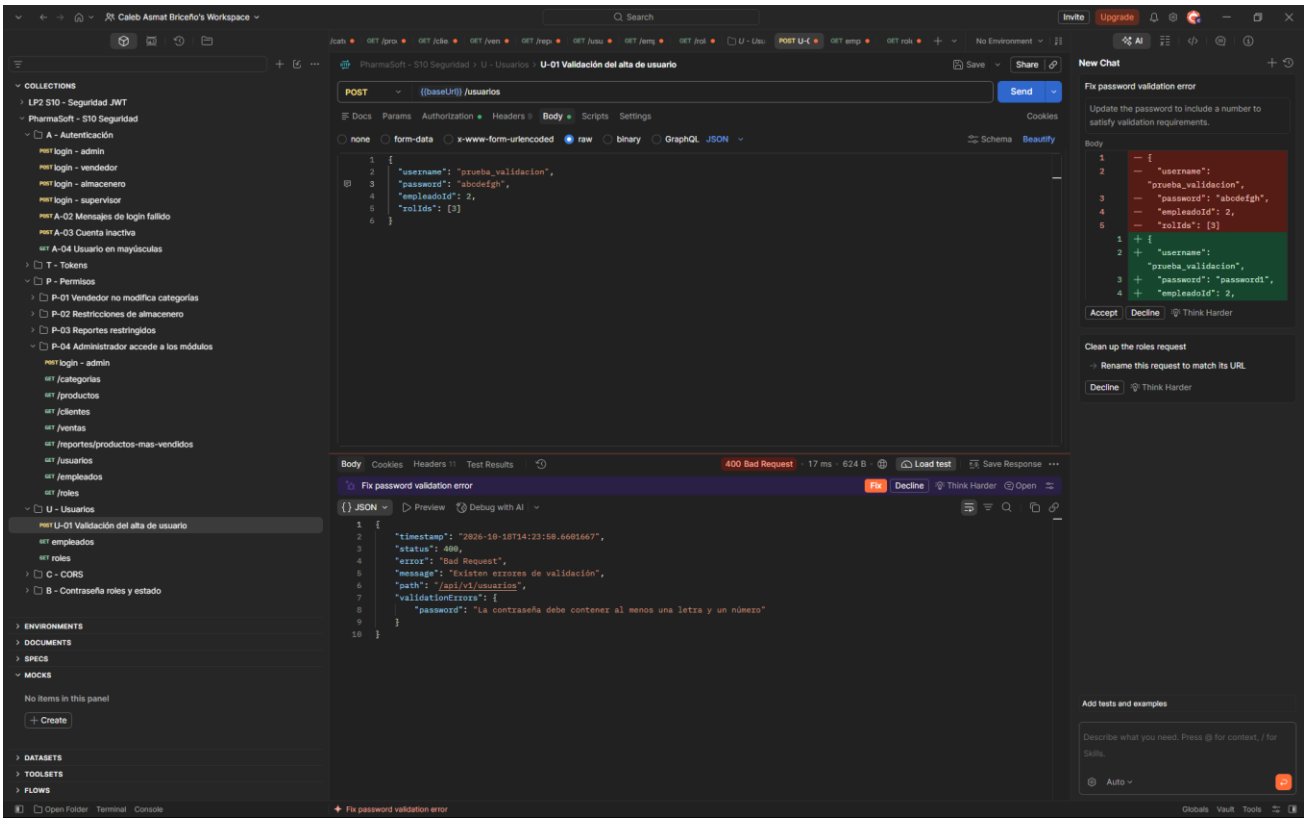
Resultado esperado: 400 con contraseña abcdefgh y 400 con rollds vacío.

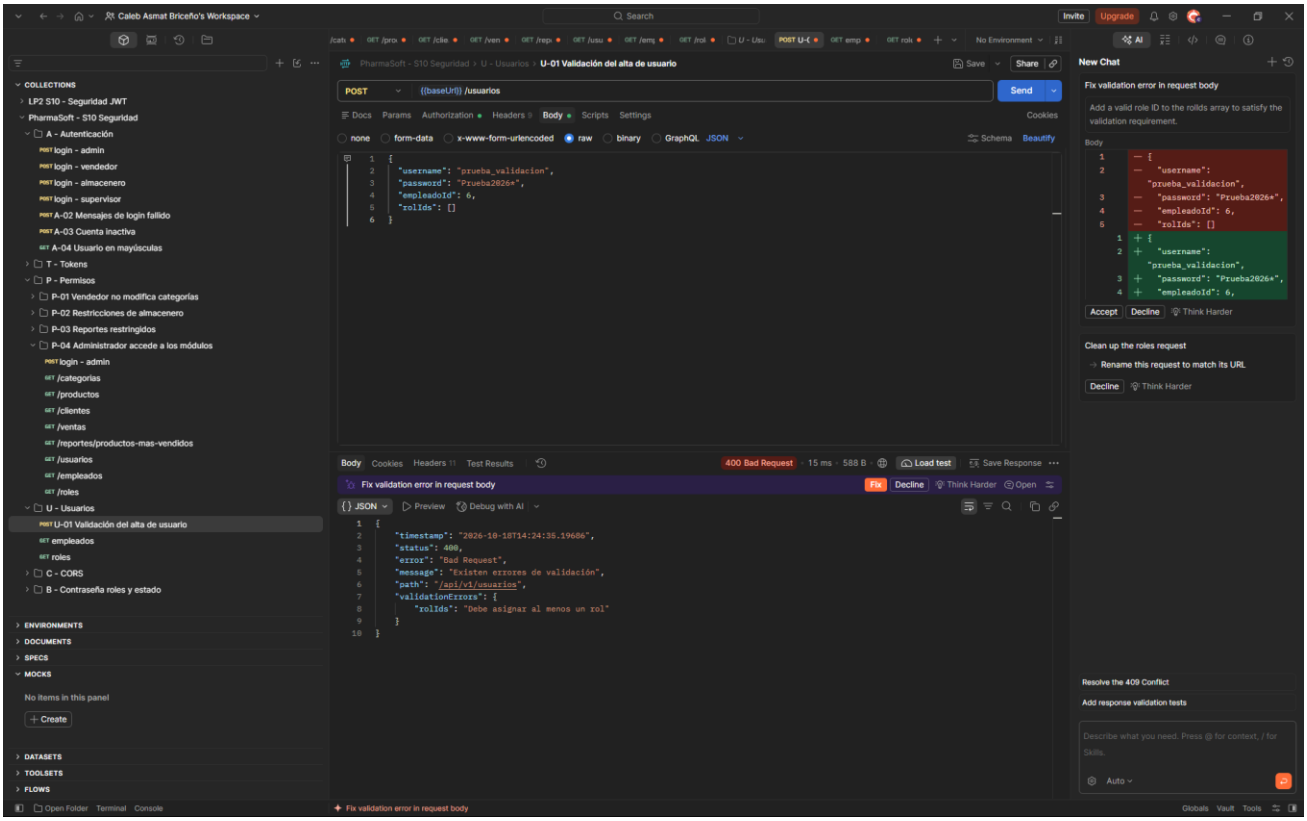
Precondición y datos utilizados: Username prueba_validacion. Primer cuerpo: password abcdefgh, empleadoId 2 y rollds 3. Segundo: password Prueba2026*, empleadoId 6 y rollds vacío.

Resultado obtenido: 400 Bad Request en ambos. password: La contraseña debe contener al menos una letra y un número. rollds: Debe asignar al menos un rol.

Estado: Pasa
Observaciones: La validación del DTO ocurre antes de ejecutar las reglas de negocio; las cuentas no se crean.

Evidencia: 2 capturas incrustadas en la sección U-01, en el orden de las operaciones.




Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
LP2 S10 - Seguridad JWT
PharmaSoft - S10 Seguridad
A - Autenticación
login - admin
login - vendedor
login - almacenero
login - supervisor
A-02 Mensajes de login fallido
A-03 Cuenta inactiva
A-04 Usuario en mayúsculas
T - Tokens
P - Permisos
P-01 Vendedor no modifica categorías
P-02 Restricciones de almacenero
P-03 Reportes restringidos
P-04 Administrador accede a los módulos
login - admin
/categorías
/productos
/clientes
/ventas
/reportes/productos-mas-vendidos
/usuarios
/empleados
/roles
U - Usuarios
U-01 Validación del alta de usuario
empleados
roles
C - CORS
B - Contraseña roles y estado
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
Open Folder
Terminal
Console
PharmaSoft - S10 Seguridad › U - Usuarios › U-01 Validación del alta de usuario
Save
Share
POST
{{baseUrl}} /usuarios
Send
Docs
Params
Authorization
Headers 9
Body
Scripts
Settings
Cookies
none
form-data
x-www-form-urlencoded
raw
binary
GraphQL
JSON
Schema
Beautify
{
"username": "prueba_validacion",
"password": "Prueba2026*",
"empleadoId": 6,
"rolIds": []
}
Body
Cookies
Headers 11
Test Results
400 Bad Request
15 ms
588 B
Load test
Save Response
Fix validation error in request body
Fix
Decline
Think Harder
Open
JSON
Preview
Debug with AI
{
"timestamp": "2026-10-18T14:24:35.19686",
"status": 400,
"error": "Bad Request",
"message": "Existen errores de validación",
"path": "/api/v1/usuarios",
"validationErrors": {
"rolIds": "Debe asignar al menos un rol"
}
}
Fix validation error in request body
Globals
Vault
Tools
AI
New Chat
Fix validation error in request body
Add a valid role ID to the rolIds array to satisfy the validation requirement.
Body
{
"username": "prueba_validacion",
"password": "Prueba2026*",
"empleadoId": 6,
"rolIds": []
{
"username": "prueba_validacion",
"password": "Prueba2026*",
"empleadoId": 6,
Accept
Decline
Think Harder
Clean up the roles request
Rename this request to match its URL
Decline
Think Harder
Resolve the 409 Conflict
Add response validation tests
Describe what you need. Press @ for context, / for Skills.
Auto

U-02 Relación uno a uno y alta con BCrypt

Grupo: Usuarios
Usuario o token: admin

Petición: POST /usuarios y consultas en Oracle
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

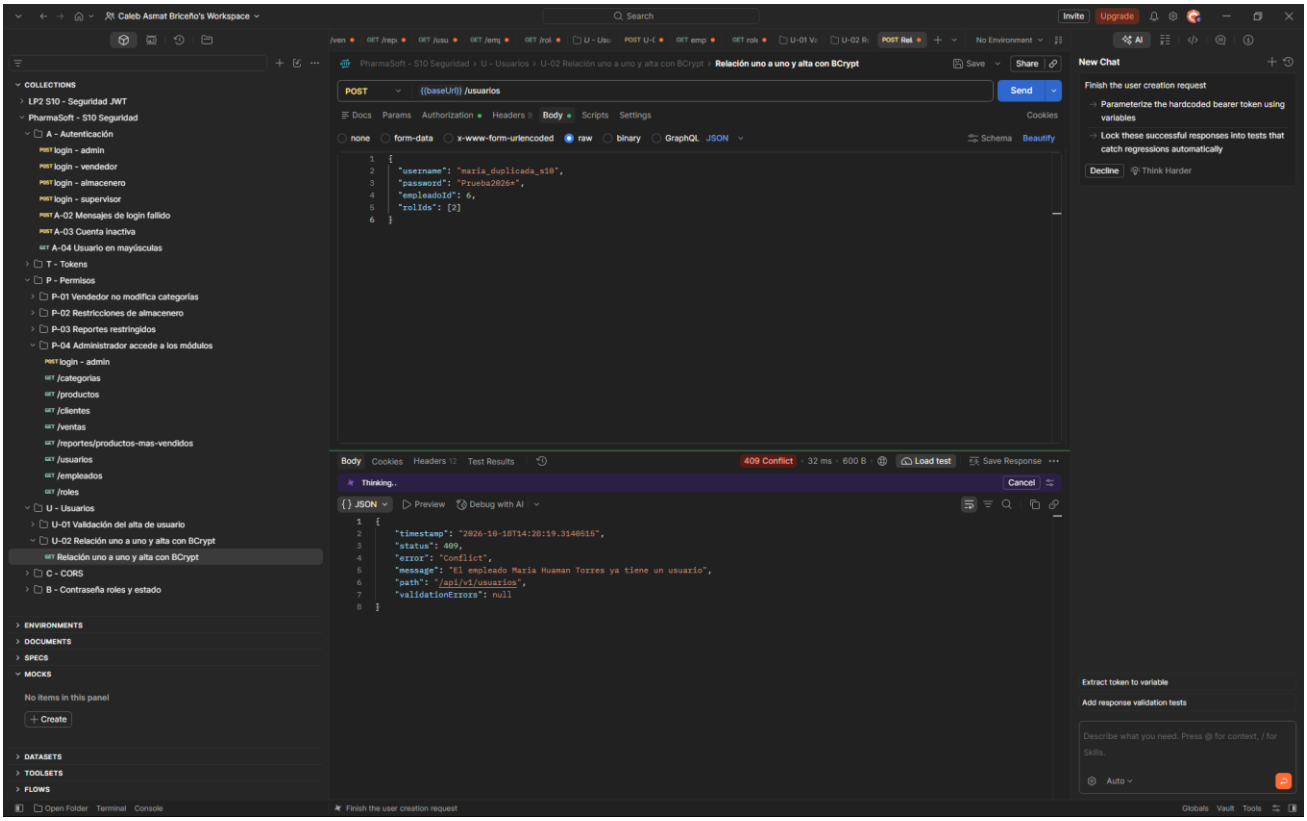
Resultado esperado: 409 si el empleado ya tiene usuario; 201 al dar de alta a uno libre; respuesta sin contraseña; hash BCrypt y fila usuario_roles en Oracle.

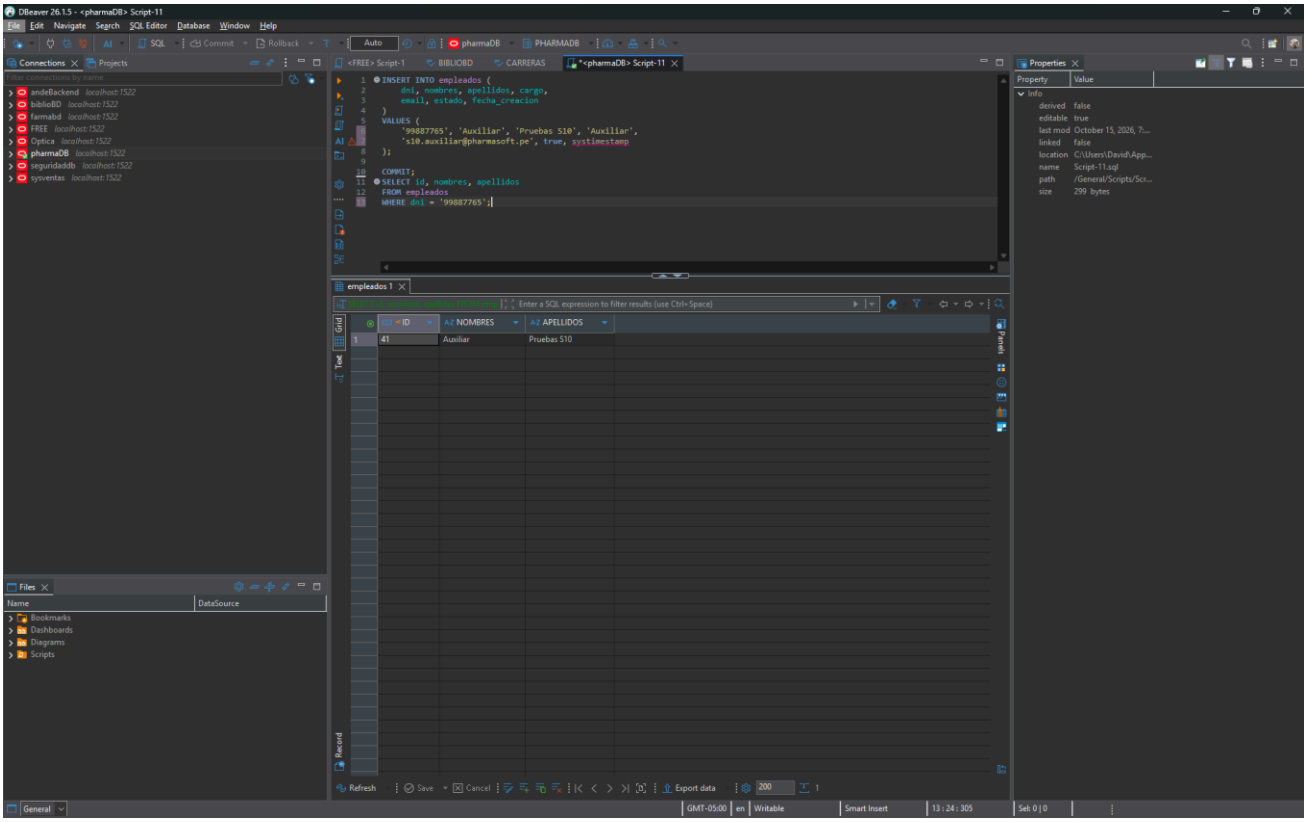
Precondición y datos utilizados: María, empleado 6, ya tiene cuenta. Se preparó el empleado 41, Auxiliar Pruebas S10, DNI 99887765, y se creó s10_auxiliar con rol 2.

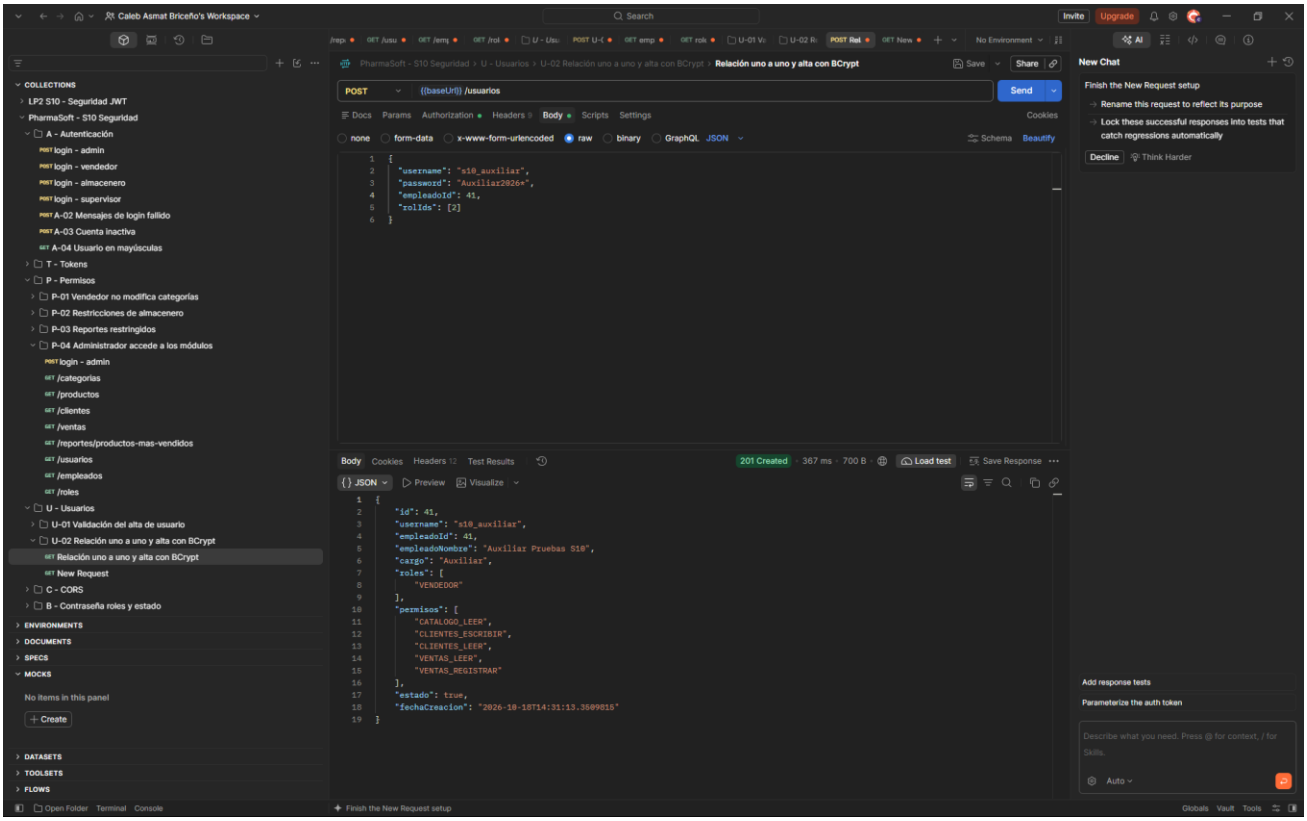
Resultado obtenido: 409 para el alta duplicada de María. 201 Created para s10_auxiliar, usuario 41 y empleado 41, con rol VENDEDOR y sin contraseña en respuesta. Oracle muestra hash BCrypt de 60 caracteres y usuario_roles con usuario 41 y rol 2.

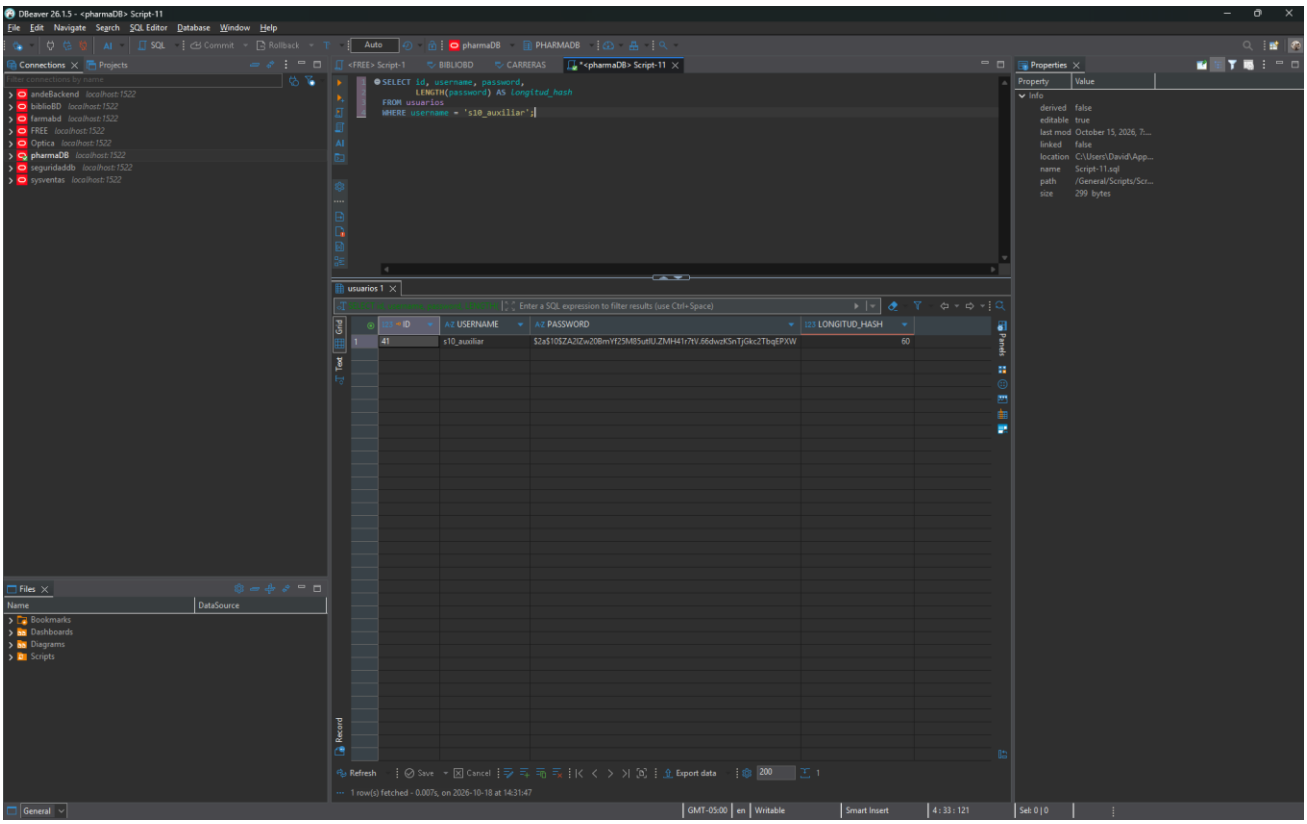
Estado: Pasa
Observaciones: María ya tenía cuenta por la práctica anterior; el alta válida se realizó con otro empleado activo sin usuario.

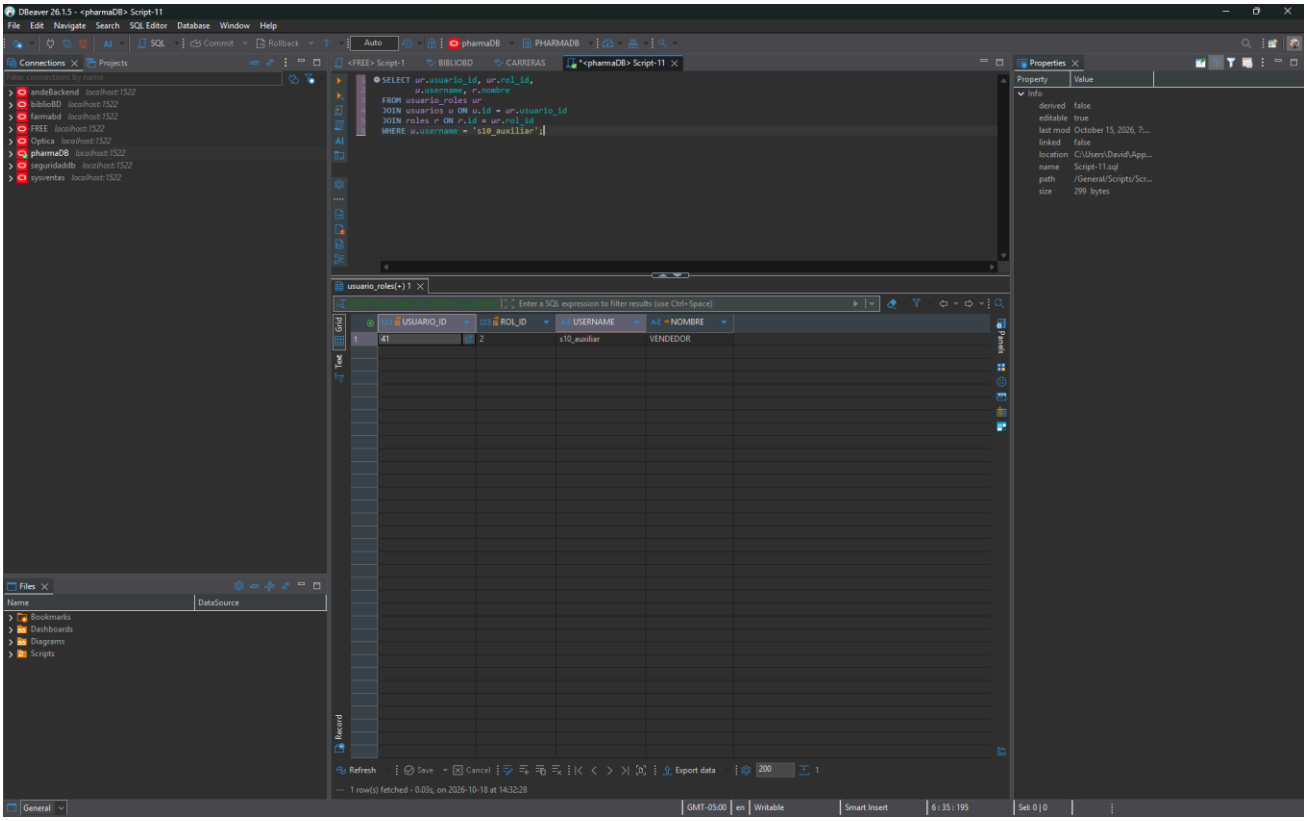
Evidencia: 5 capturas incrustadas en la sección U-02, en el orden de las operaciones.


POST
{{baseUrl}} /usuarios
Send
Relación uno a uno y alta con BCrypt
{
"username": "maria_duplicada_s10",
"password": "Prueba2026+",
"empleadoId": 6,
"rolIds": [2]
}
409 Conflict
{
"timestamp": "2026-10-18T14:28:19.3148515",
"status": 409,
"error": "Conflict",
"message": "El empleado Maria Huaman Torres ya tiene un usuario",
"path": "/api/v1/usuarios",
"validationErrors": null
}


INSERT INTO empleados (
dni, nombres, apellidos, cargo,
email, estado, fecha_creacion
)
VALUES (
'99887765', 'Auxiliar', 'Pruebas S10', 'Auxiliar',
's10.auxiliar@pharmasoft.pe', true, systimestamp
);
COMMIT;
SELECT id, nombres, apellidos
FROM empleados
WHERE dni = '99887765';
41 Auxiliar Pruebas S10


POST
{{baseUrl}} /usuarios
Send
Body
Cookies
Headers 12
Test Results
201 Created
367 ms · 700 B
Load test
Save Response
{
"id": 41,
"username": "s10_auxiliar",
"empleadoId": 41,
"empleadoNombre": "Auxiliar Pruebas S10",
"cargo": "Auxiliar",
"roles": [
"VENDEDOR"
],
"permisos": [
"CATALOGO_LEER",
"CLIENTES_ESCRIBIR",
"CLIENTES_LEER",
"VENTAS_LEER",
"VENTAS_REGISTRAR"
],
"estado": true,
"fechaCreacion": "2026-10-18T14:31:13.3609815"
}


SELECT id, username, password,
LENGTH(password) AS longitud_hash
FROM usuarios
WHERE username = 's10_auxiliar';
ID
USERNAME
PASSWORD
LONGITUD_HASH
41
s10_auxiliar
$2a$10$ZA2iZw20BmYf2SM85utlU.ZMH41r7tV.66dwzKSnTjGkc2TbqEPXW
60


DBeaver 26.1.5 - <pharmaDB> Script-11
File Edit Navigate Search SQL Editor Database Window Help
Connections
Projects
andieBackend localhost:1522
biblioBD localhost:1522
farmabd localhost:1522
FREE localhost:1522
Optica localhost:1522
pharmaDB localhost:1522
seguridaddb localhost:1522
sysventas localhost:1522
Files
Name
DataSource
Bookmarks
Dashboards
Diagrams
Scripts
<FREE> Script-1
BIBLIOBD
CARRERAS
*<pharmaDB> Script-11
SELECT ur.usuario_id, ur.rol_id,
u.username, r.nombre
FROM usuario_roles ur
JOIN usuarios u ON u.id = ur.usuario_id
JOIN roles r ON r.id = ur.rol_id
WHERE u.username = 's10_auxiliar';
usuario_roles(+) 1
Enter a SQL expression to filter results (use Ctrl+Space)
USUARIO_ID
ROL_ID
USERNAME
NOMBRE
1
41
2
s10_auxiliar
VENDEDOR
Refresh
Save
Cancel
Export data
200
1 row(s) fetched - 0.03s, on 2026-10-18 at 14:32:28
Properties
Property
Value
info
derived false
editable true
last mod October 15, 2026, 7:...
linked false
location C:\Users\David\App...
name Script-11.sql
path /General/Scripts/Scr...
size 299 bytes
General
GMT-05:00
en
Writable
Smart Insert
6 : 35 : 195
Sel: 0 | 0

C-01 Preflight desde la SPA

Grupo: CORS
Usuario o token: Navegador en localhost:4200

Petición: OPTIONS y GET a /api/v1/productos
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

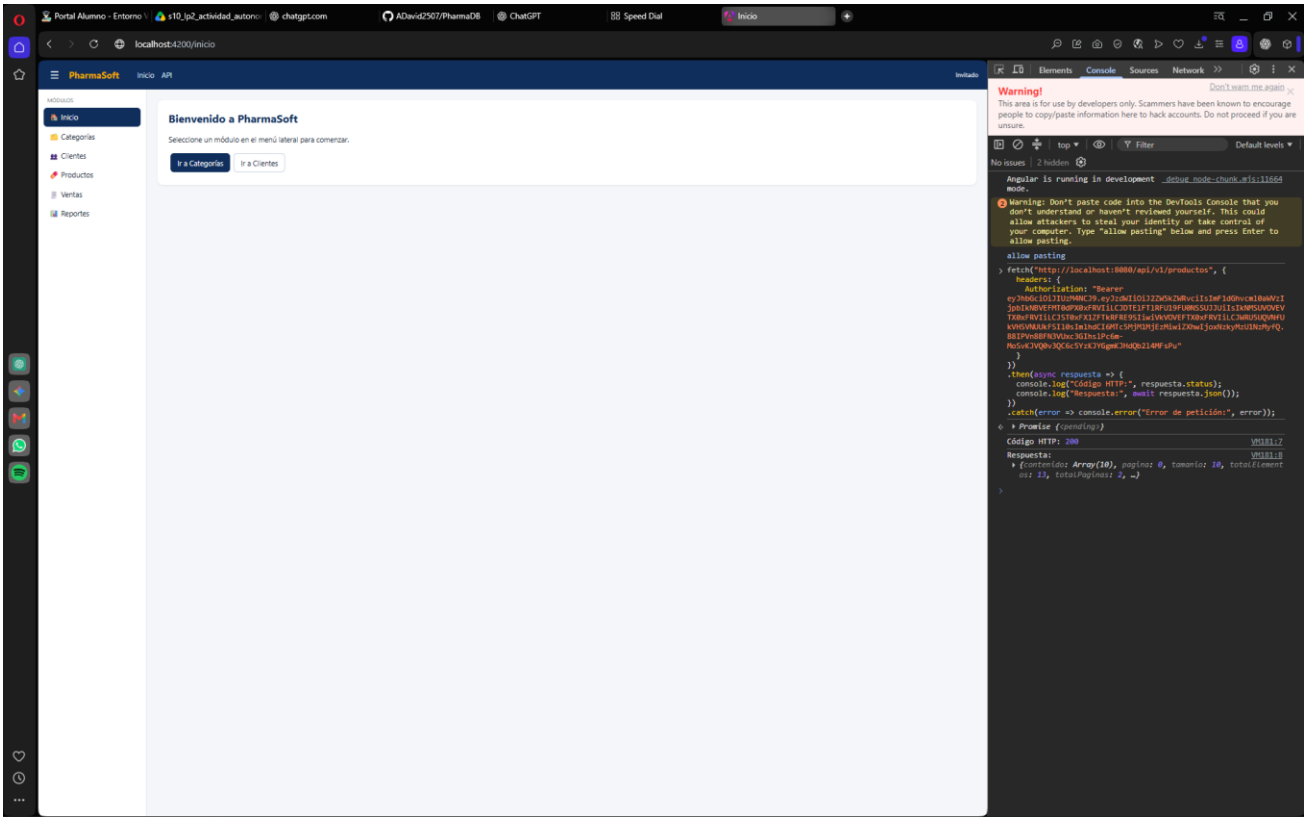
Resultado esperado: OPTIONS 200 y petición real 200 o 401; sin error de CORS.

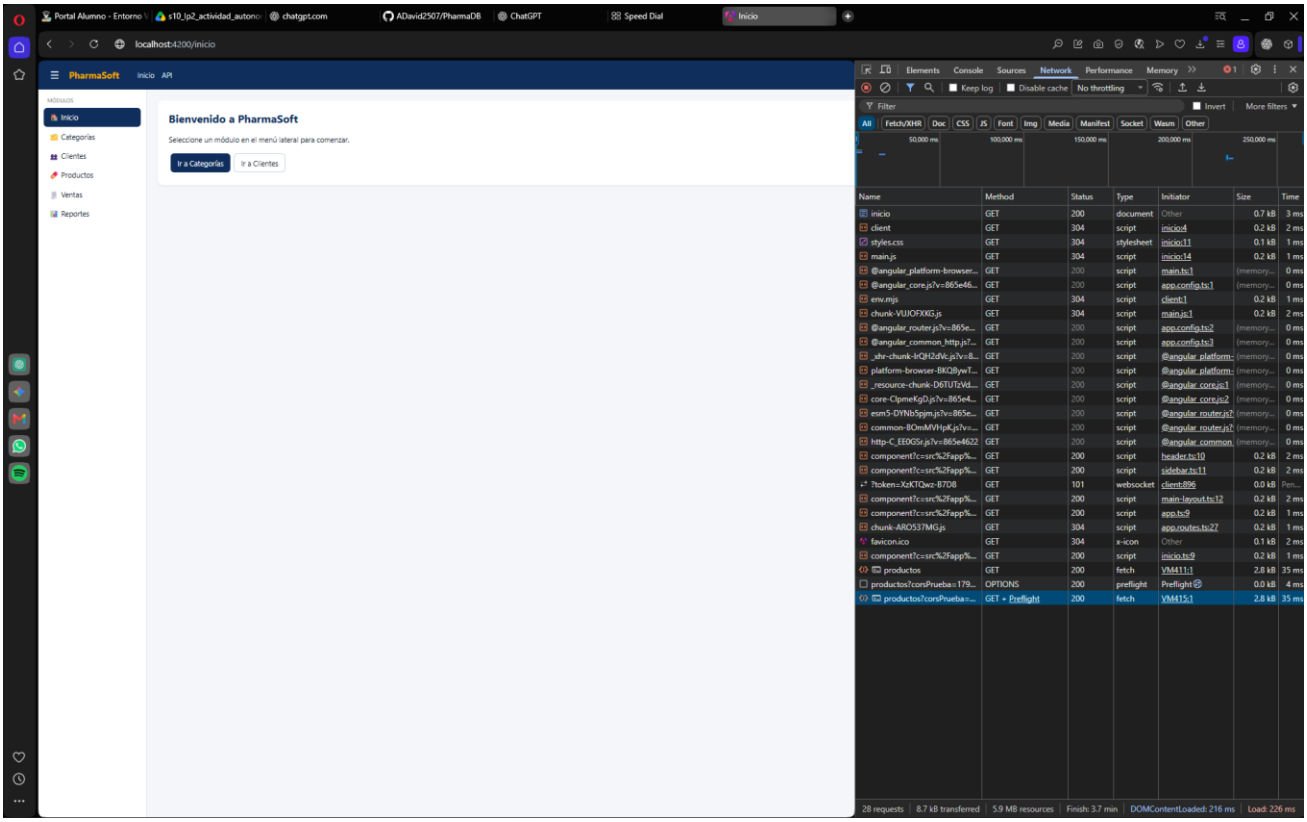
Precondición y datos utilizados: SPA en http://localhost:4200; fetch a productos con Authorization y parámetro corsPrueba.

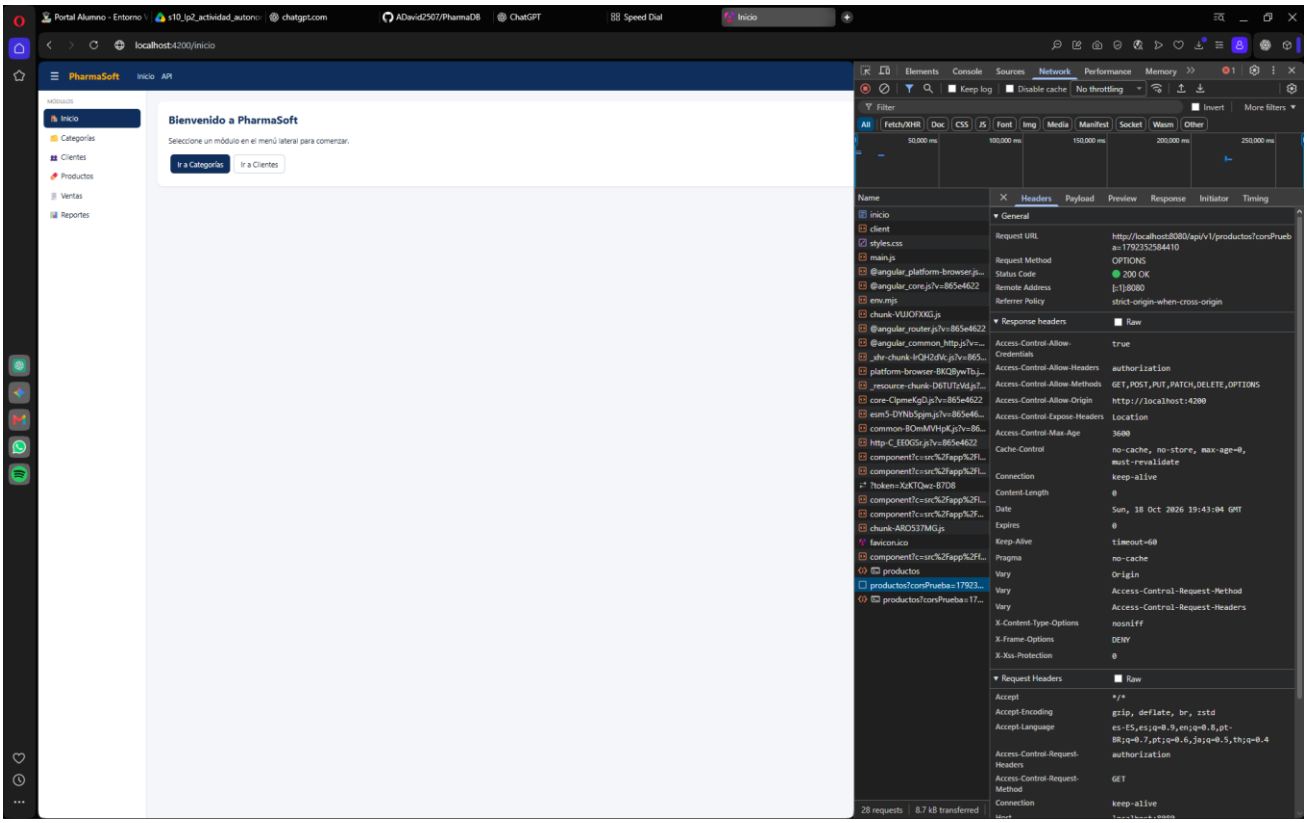
Resultado obtenido: OPTIONS 200 OK y GET 200 OK. La respuesta permite el origen http://localhost:4200, el encabezado authorization y los métodos GET, POST, PUT, PATCH, DELETE y OPTIONS. La consola pudo leer el JSON.

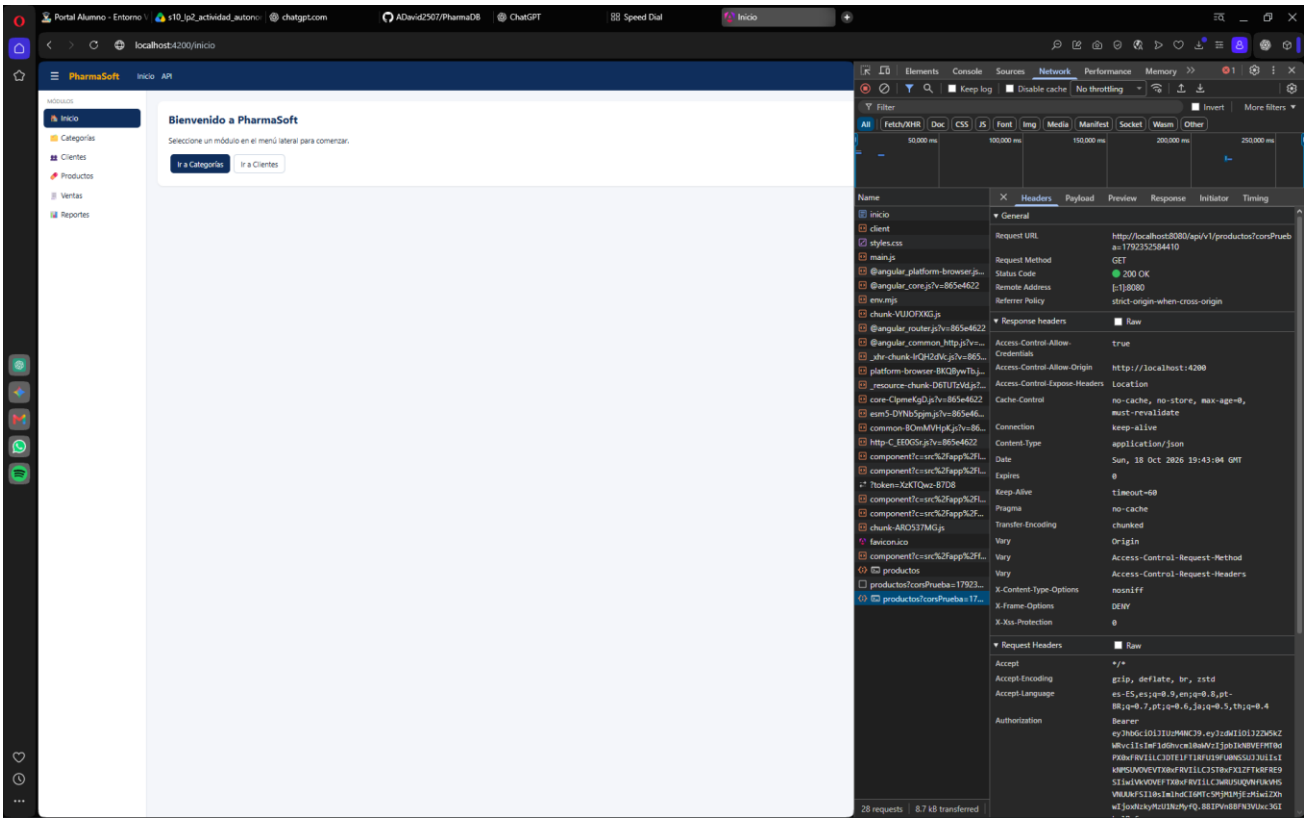
Estado: Pasa
Observaciones: Ninguna

Evidencia: 4 capturas incrustadas en la sección C-01, en el orden de las operaciones.




Portal Alumno - Entorno
s10_lp2_actividad_autono
chatgpt.com
ADavid2507/PharmaDB
ChatGPT
Speed Dial
Inicio
localhost:4200/inicio
PharmaSoft
Inicio
API
MÓDULOS
Inicio
Categorías
Clientes
Productos
Ventas
Reportes
Bienvenido a PharmaSoft
Seleccione un módulo en el menú lateral para comenzar.
Ir a Categorías
Ir a Clientes
Elements
Console
Sources
Network
Performance
Memory
Keep log
Disable cache
No throttling
Filter
Invert
More filters
All
Fetch/XHR
Doc
CSS
JS
Font
Img
Media
Manifest
Socket
Wasm
Other
Name
Method
Status
Type
Initiator
Size
Time
inicio GET 200 document Other 0.7 kB 3 ms
client GET 304 script inicio:4 0.2 kB 2 ms
styles.css GET 304 stylesheet inicio:11 0.1 kB 1 ms
main.js GET 304 script inicio:14 0.2 kB 1 ms
@angular_platform-browser... GET 200 script main.ts:1 (memory... 0 ms
@angular_core.js?v=865e46... GET 200 script app.config.ts:1 (memory... 0 ms
env.mjs GET 304 script client:1 0.2 kB 1 ms
chunk-VUJOFXKG.js GET 304 script main.js:1 0.2 kB 2 ms
@angular_router.js?v=865e... GET 200 script app.config.ts:2 (memory... 0 ms
@angular_common_http.js?... GET 200 script app.config.ts:3 (memory... 0 ms
_xhr-chunk-IrQH2dVL.js?v=8... GET 200 script @angular_platform- (memory... 0 ms
platform-browser-BKQBywT... GET 200 script @angular_platform- (memory... 0 ms
_resource-chunk-D6TUTzVd... GET 200 script @angular_core.js:1 (memory... 0 ms
core-ClpmeKgD.js?v=865e4... GET 200 script @angular_core.js:2 (memory... 0 ms
esm5-DYNb5pjm.js?v=865e... GET 200 script @angular_router.js?: (memory... 0 ms
common-BOmMVHpK.js?v=... GET 200 script @angular_router.js?: (memory... 0 ms
http-C_EEOGSr.js?v=865e4622 GET 200 script @angular_common (memory... 0 ms
component?c=src%2Fapp%... GET 200 script header.ts:10 0.2 kB 2 ms
component?c=src%2Fapp%... GET 200 script sidebar.ts:11 0.2 kB 2 ms
?token=XcKTQwz-B7D8 GET 101 websocket client:896 0.0 kB Pen...
component?c=src%2Fapp%... GET 200 script main-layout.ts:12 0.2 kB 2 ms
component?c=src%2Fapp%... GET 200 script app.ts:9 0.2 kB 1 ms
chunk-ARO537MG.js GET 304 script app.routes.ts:27 0.2 kB 1 ms
favicon.ico GET 304 x-icon Other 0.1 kB 2 ms
component?c=src%2Fapp%... GET 200 script inicio.ts:9 0.2 kB 1 ms
productos GET 200 fetch VM411:1 2.8 kB 35 ms
productos?corsPrueba=179... OPTIONS 200 preflight Preflight 0.0 kB 4 ms
productos?corsPrueba=... GET + Preflight 200 fetch VM415:1 2.8 kB 35 ms
28 requests
8.7 kB transferred
5.9 MB resources
Finish: 3.7 min
DOMContentLoaded: 216 ms
Load: 226 ms


Portal Alumno - Entorno
s10_lp2_actividad_autono
chatgpt.com
ADavid2507/PharmaDB
ChatGPT
Speed Dial
Inicio
localhost:4200/inicio
PharmaSoft
Inicio
API
Bienvenido a PharmaSoft
Seleccione un módulo en el menú lateral para comenzar.
Ir a Categorías
Ir a Clientes
Headers
Payload
Preview
Response
Initiator
Timing
General
Request URL
http://localhost:8080/api/v1/productos?corsPrueba=1792352584410
Request Method
OPTIONS
Status Code
200 OK
Remote Address
[::1]:8080
Referrer Policy
strict-origin-when-cross-origin
Response headers
Raw
Access-Control-Allow-Credentials
true
Access-Control-Allow-Headers
authorization
Access-Control-Allow-Methods
GET,POST,PUT,PATCH,DELETE,OPTIONS
Access-Control-Allow-Origin
http://localhost:4200
Access-Control-Expose-Headers
Location
Access-Control-Max-Age
3600
Cache-Control
no-cache, no-store, max-age=0, must-revalidate
Connection
keep-alive
Content-Length
0
Date
Sun, 18 Oct 2026 19:43:04 GMT
Expires
0
Keep-Alive
timeout=60
Pragma
no-cache
Vary
Origin
Vary
Access-Control-Request-Method
Vary
Access-Control-Request-Headers
X-Content-Type-Options
nosniff
X-Frame-Options
DENY
X-Xss-Protection
0
Request Headers
Raw
Accept
/
Accept-Encoding
gzip, deflate, br, zstd
Accept-Language
es-ES,es;q=0.9,en;q=0.8,pt-BR;q=0.7,pt;q=0.6,ja;q=0.5,th;q=0.4
Access-Control-Request-Headers
authorization
Access-Control-Request-Method
GET
Connection
keep-alive
28 requests
8.7 kB transferred


Portal Alumno - Entorno
s10_lp2_actividad_autono
chatgpt.com
ADavid2507/PharmaDB
ChatGPT
Speed Dial
Inicio
localhost:4200/inicio
PharmaSoft
Inicio
API
MÓDULOS
Inicio
Categorías
Clientes
Productos
Ventas
Reportes
Bienvenido a PharmaSoft
Seleccione un módulo en el menú lateral para comenzar.
Ir a Categorías
Ir a Clientes
Elements
Console
Sources
Network
Performance
Memory
Keep log
Disable cache
No throttling
Filter
Invert
More filters
All
Fetch/XHR
Doc
CSS
JS
Font
Img
Media
Manifest
Socket
Wasm
Other
50,000 ms
100,000 ms
150,000 ms
200,000 ms
250,000 ms
Name
inicio
client
styles.css
main.js
@angular_platform-browser.js...
@angular_core.js?v=865e4622
env.mjs
chunk-VUJOFXKG.js
@angular_router.js?v=865e4622
@angular_common_http.js?v=...
_xhr-chunk-IrQH2dVc.js?v=865...
platform-browser-BKQBywTb.j...
_resource-chunk-D6TUTzVd.js?...
core-ClpmeKgD.js?v=865e4622
esm5-DYNb5pjm.js?v=865e46...
common-BOmMVHpK.js?v=86...
http-C_EEOGSr.js?v=865e4622
component?c=src%2Fapp%2Fi...
component?c=src%2Fapp%2Fi...
?token=XzKTQwz-87D8
component?c=src%2Fapp%2Fi...
component?c=src%2Fapp%2F...
chunk-ARO537MG.js
favicon.ico
component?c=src%2Fapp%2Fi...
productos
productos?corsPrueba=17923...
productos?corsPrueba=17...
28 requests
8.7 kB transferred
Headers
Payload
Preview
Response
Initiator
Timing
General
Request URL
http://localhost:8080/api/v1/productos?corsPrueba=1792325804410
Request Method
GET
Status Code
200 OK
Remote Address
[::1]:8080
Referrer Policy
strict-origin-when-cross-origin
Response headers
Raw
Access-Control-Allow-Credentials
true
Access-Control-Allow-Origin
http://localhost:4200
Access-Control-Expose-Headers
Location
Cache-Control
no-cache, no-store, max-age=0, must-revalidate
Connection
keep-alive
Content-Type
application/json
Date
Sun, 18 Oct 2026 19:43:04 GMT
Expires
0
Keep-Alive
timeout=60
Pragma
no-cache
Transfer-Encoding
chunked
Vary
Origin
Vary
Access-Control-Request-Method
Vary
Access-Control-Request-Headers
X-Content-Type-Options
nosniff
X-Frame-Options
DENY
X-Xss-Protection
0
Request Headers
Raw
Accept
/
Accept-Encoding
gzip, deflate, br, zstd
Accept-Language
es-ES,es;q=0.9,en;q=0.8,pt-BR;q=0.7,pt;q=0.6,ja;q=0.5,th;q=0.4
Authorization
Bearer
eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJ2ZW5kZWRvciIsImF1dGhvcm10aWzIjpbIkNBVEFMT0dPX0xFRV1iLCJDTE1FTlRFU19FU0NSSUJUiIsIkNMSUVOVEVTX0xFX2FTkRFRE9SIiwiVkVOVEFTX0xFRV1iLCJWRU5UQVNfUkVNVUkVMX5iUkImlhdCI6MTc5MjM5MjE2MiwiZXhwIjoxNzkyMzU1NzMyfQ.88IPVn8BFN3VUxc3GI

A-05 Contraseña de login ausente

Grupo: Autenticación propio
Usuario o token: Sin token

Petición: POST /auth/login
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

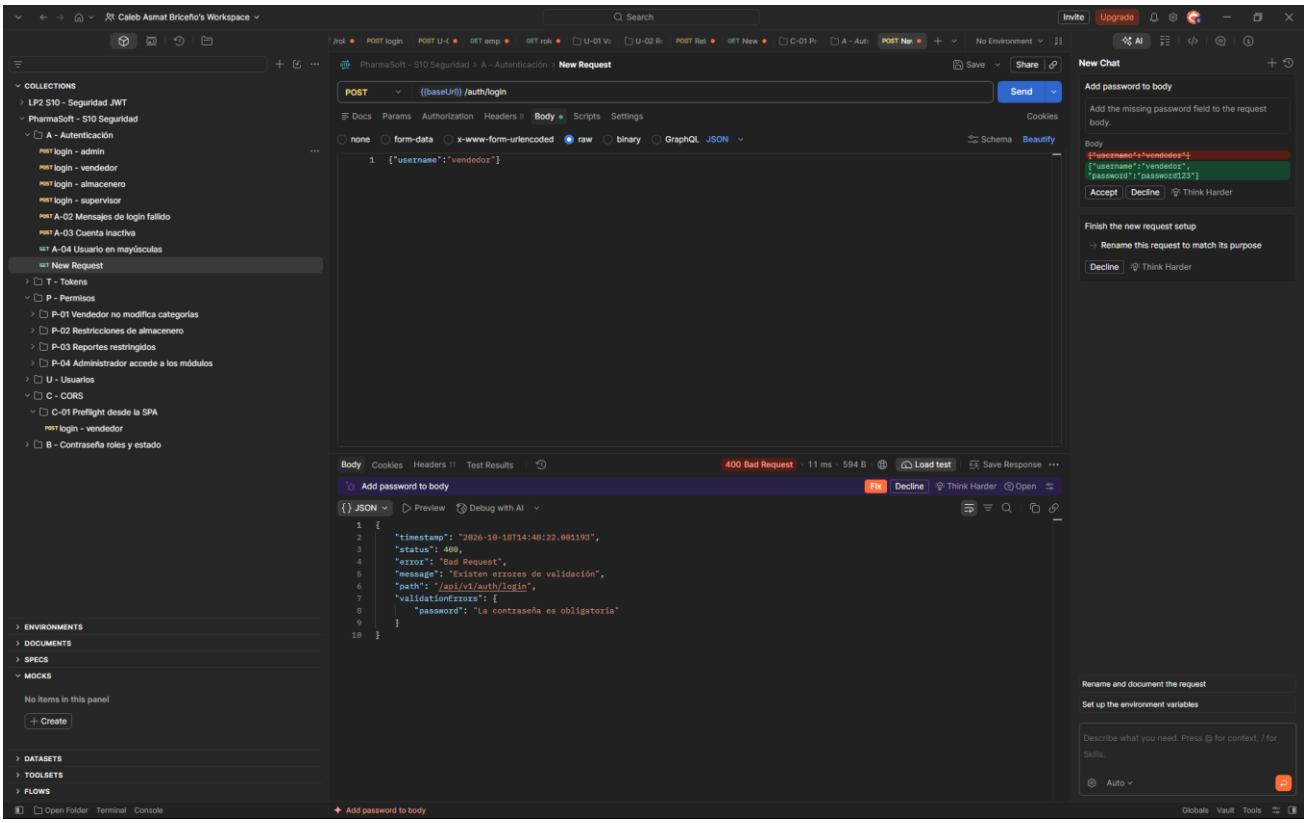
Resultado esperado: 400 con validationErrors.password.

Precondición y datos utilizados: POST /auth/login con cuerpo que contiene solo username vendedor.

Resultado obtenido: 400 Bad Request; validationErrors.password: La contraseña es obligatoria.

Estado: Pasa
Observaciones: Caso propio del grupo Autenticación.

Evidencia: 1 captura incrustada en la sección A-05, en el orden de las operaciones.



T-06 Petición protegida sin token

Grupo: Token propio
Usuario o token: Sin token

Petición: GET /auth/me
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

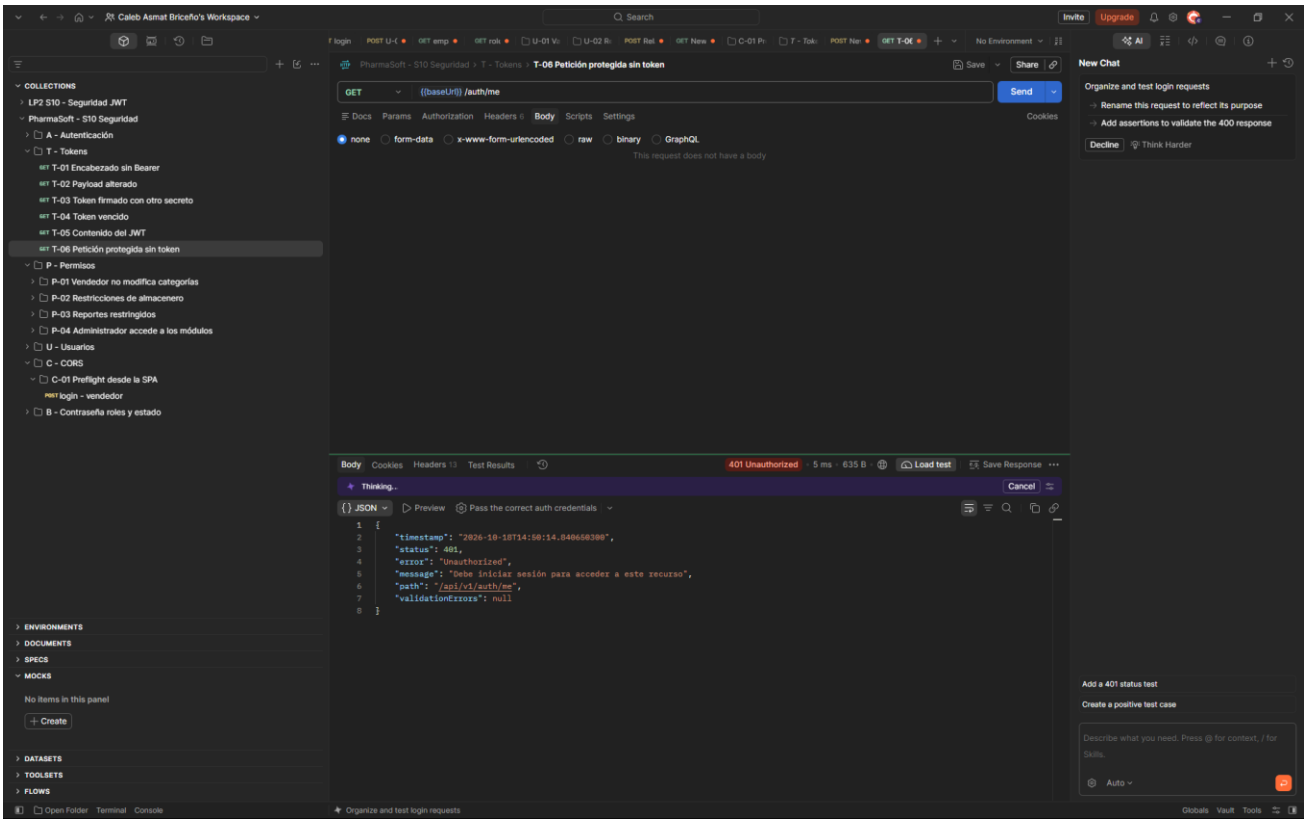
Resultado esperado: 401; Debe iniciar sesión para acceder a este recurso.

Precondición y datos utilizados: GET /auth/me sin token, según la condición del caso.

Resultado obtenido: 401 Unauthorized; Debe iniciar sesión para acceder a este recurso.

Estado: Pasa
Observaciones: Caso propio del grupo Token.

Evidencia: 1 captura incrustada en la sección T-06, en el orden de las operaciones.



P-05 Vendedor no administra cuentas

Grupo: Permisos propio
Usuario o token: vendedor

Petición: GET /usuarios
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

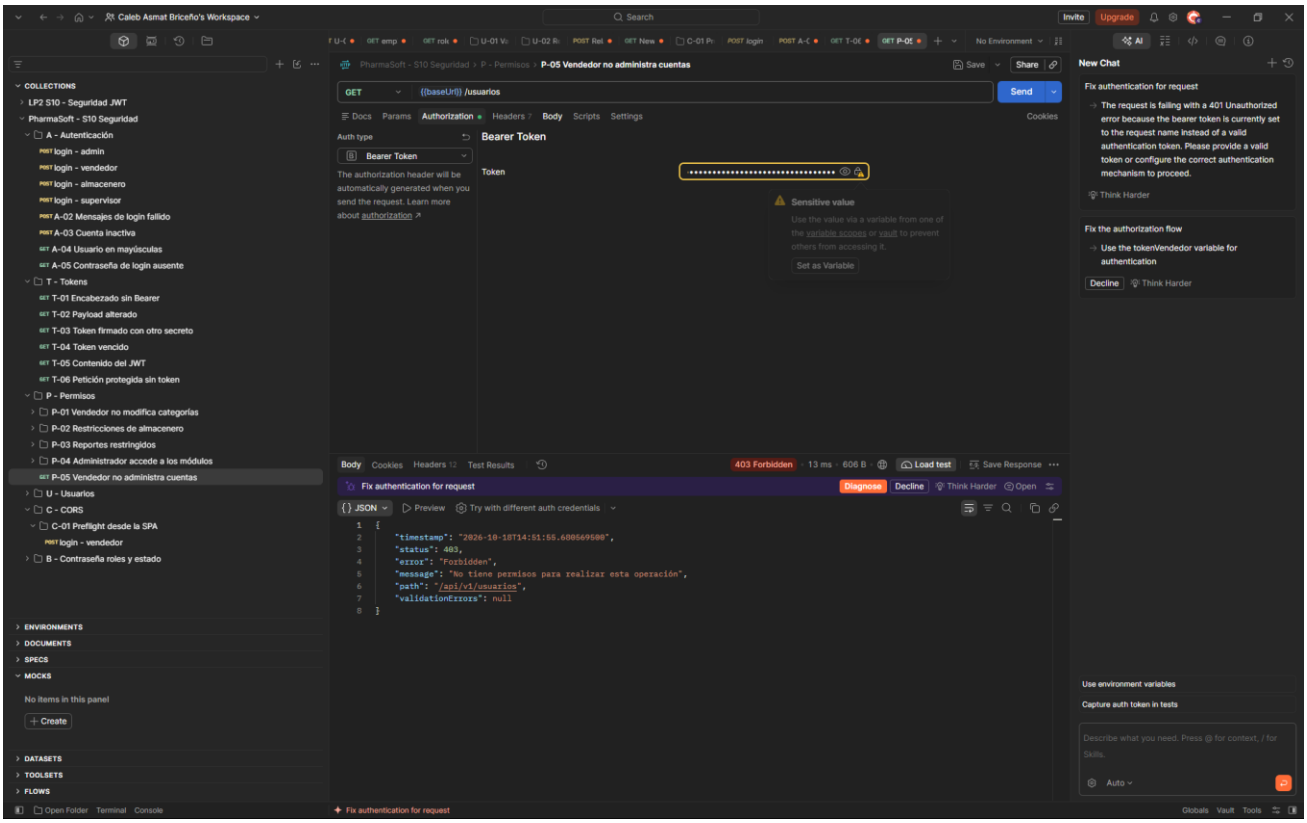
Resultado esperado: 403; No tiene permisos para realizar esta operación.

Precondición y datos utilizados: GET /usuarios con token de vendedor.

Resultado obtenido: 403 Forbidden; No tiene permisos para realizar esta operación.

Estado: Pasa
Observaciones: Caso propio del grupo Permisos.

Evidencia: 1 captura incrustada en la sección P-05, en el orden de las operaciones.



U-03 Empleado inexistente

Grupo: Usuarios propio
Usuario o token: admin

Petición: POST /usuarios
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

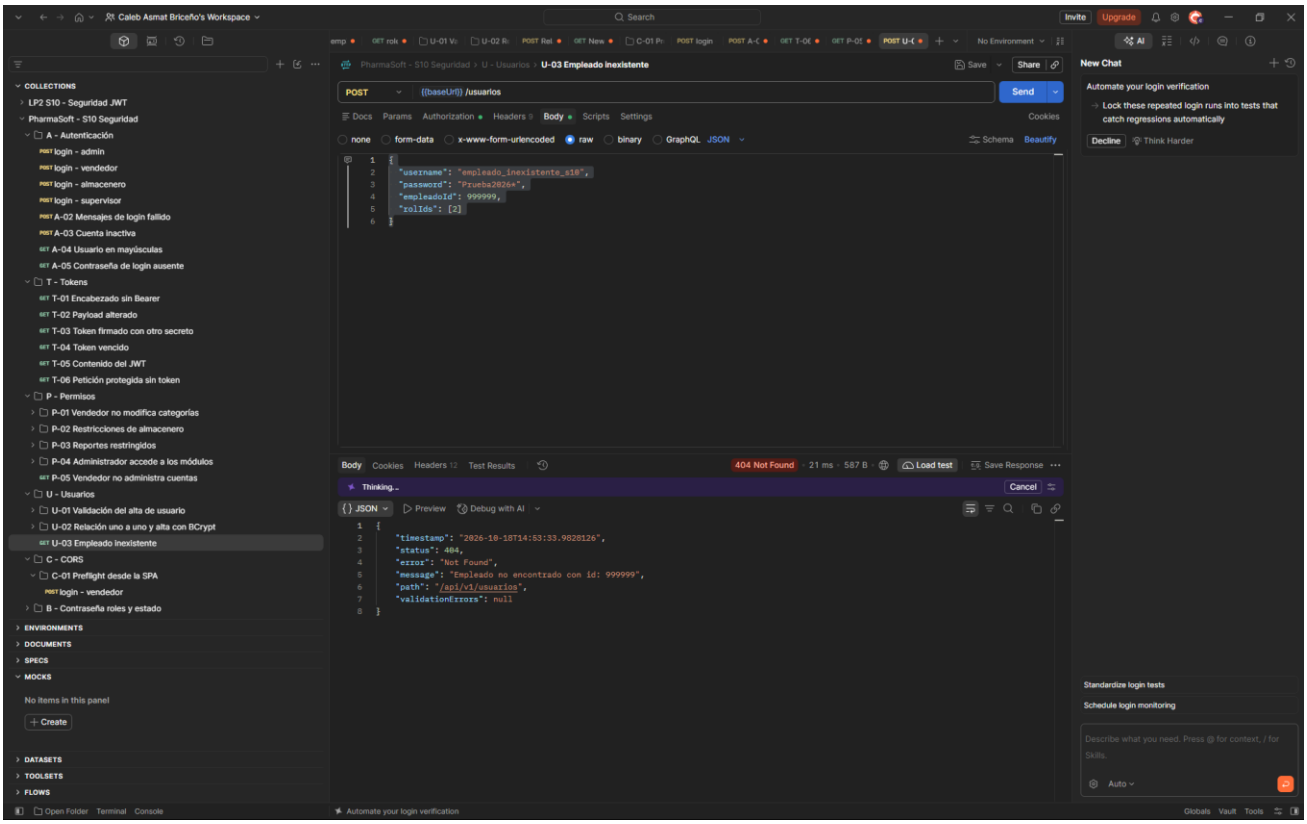
Resultado esperado: 404; Empleado no encontrado con id seguido del ID usado.

Precondición y datos utilizados: Admin intenta crear empleado_inexistente_s10 con password Prueba2026*, empleadoId 999999 y rolIds 2.

Resultado obtenido: 404 Not Found; Empleado no encontrado con id: 999999.

Estado: Pasa
Observaciones: Caso propio del grupo Usuarios; la petición no creó cuenta.

Evidencia: 1 captura incrustada en la sección U-03, en el orden de las operaciones.



B-01 Contraseña actual incorrecta

Grupo: Contraseña
Usuario o token: vendedor

Petición: PUT /auth/password
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

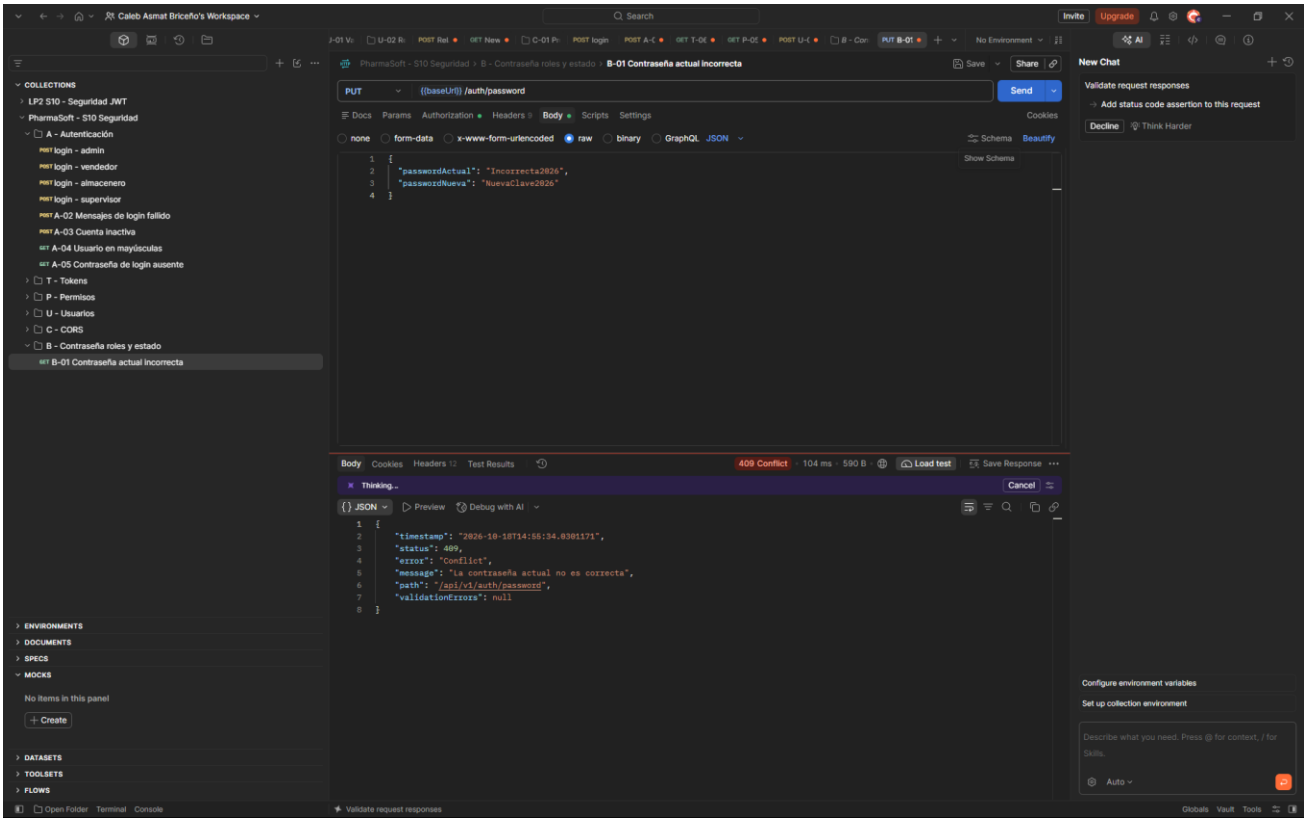
Resultado esperado: 409; La contraseña actual no es correcta.

Precondición y datos utilizados: Token de vendedor; passwordActual Incorrecta2026 y passwordNueva NuevaClave2026.

Resultado obtenido: 409 Conflict; La contraseña actual no es correcta.

Estado: Pasa
Observaciones: Ninguna.

Evidencia: 1 captura incrustada en la sección B-01, en el orden de las operaciones.



B-02 Nueva contraseña repetida

Grupo: Contraseña
Usuario o token: vendedor

Petición: PUT /auth/password
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

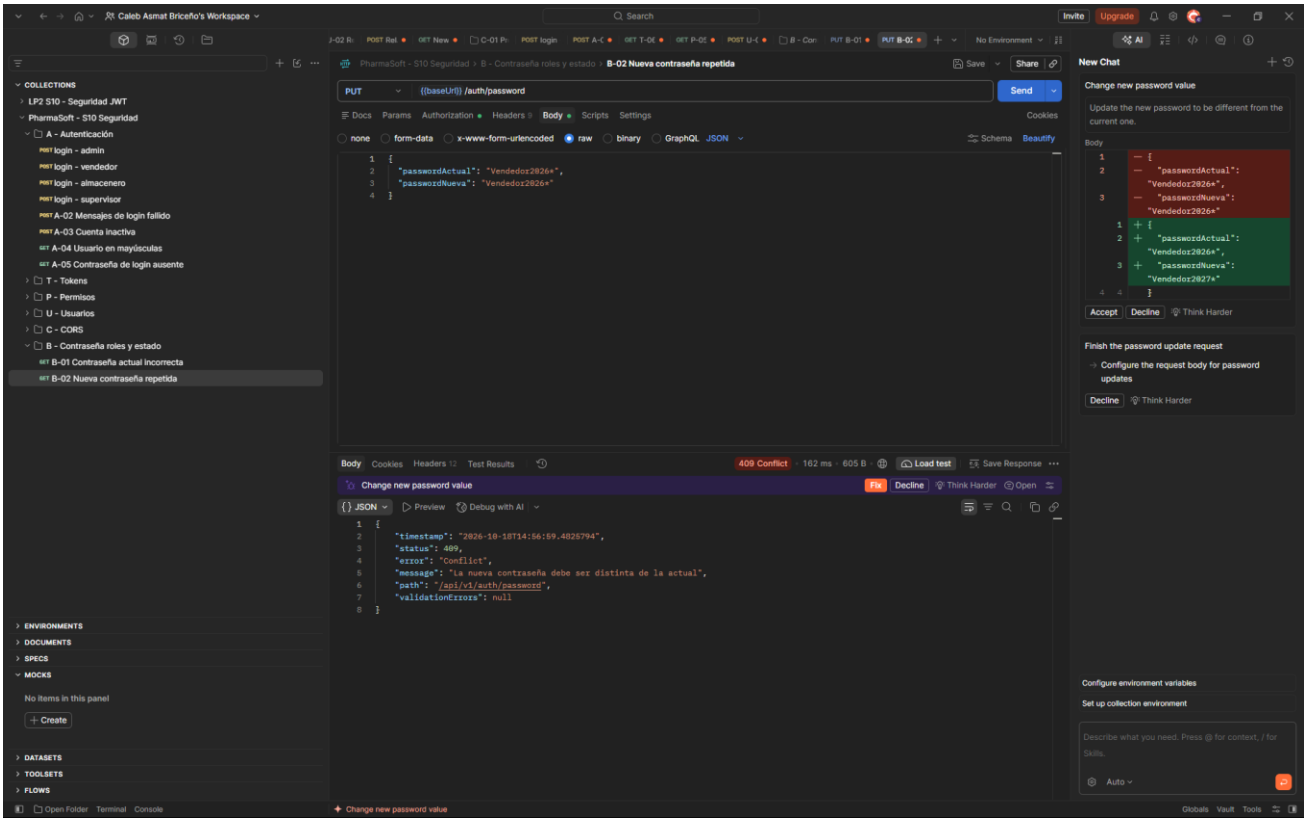
Resultado esperado: 409; La nueva contraseña debe ser distinta de la actual.

Precondición y datos utilizados: Token de vendedor; passwordActual y passwordNueva iguales a Vendedor2026*.

Resultado obtenido: 409 Conflict; La nueva contraseña debe ser distinta de la actual.

Estado: Pasa
Observaciones: Ninguna.

Evidencia: 1 captura incrustada en la sección B-02, en el orden de las operaciones.



B-03 Validación de la nueva contraseña

Grupo: Contraseña
Usuario o token: vendedor

Petición: PUT /auth/password
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

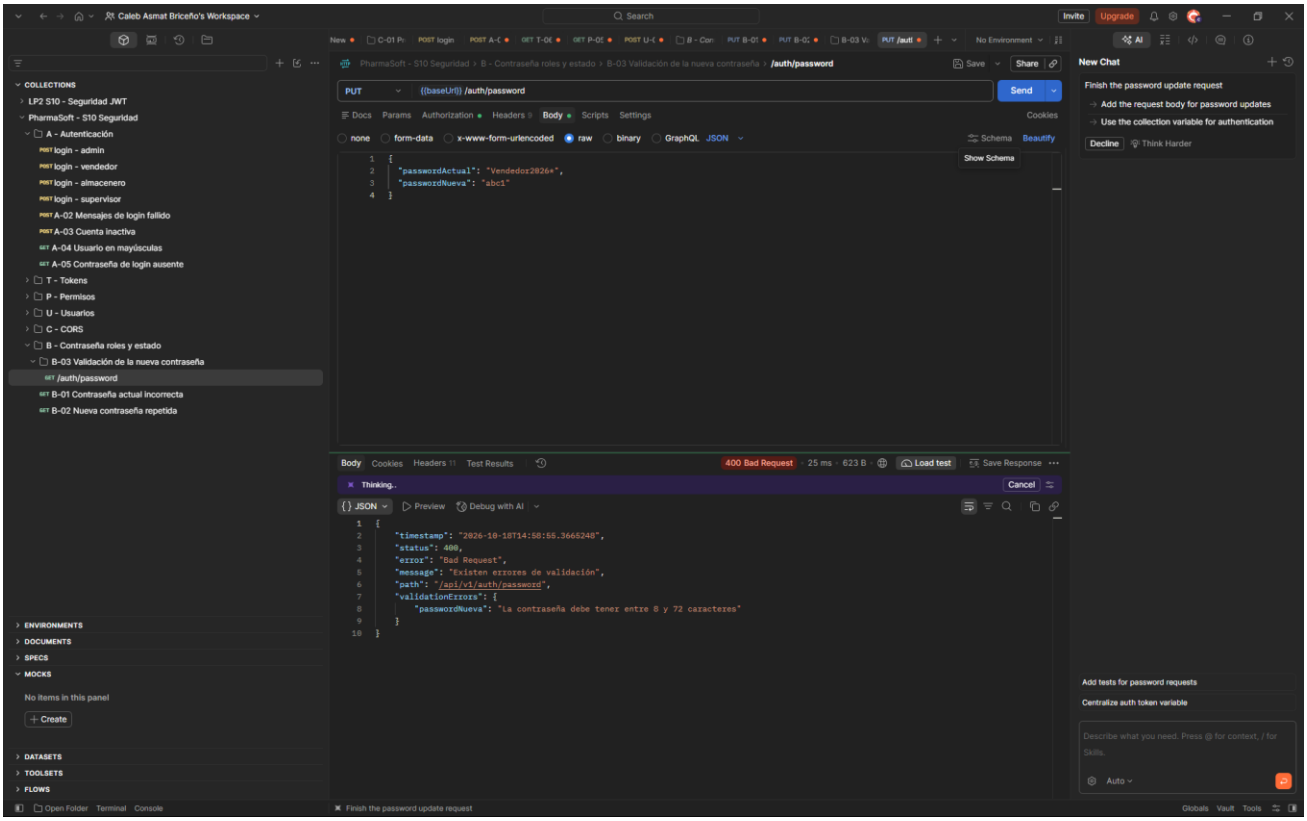
Resultado esperado: 400 para nueva contraseña corta, sin número y sin letra.

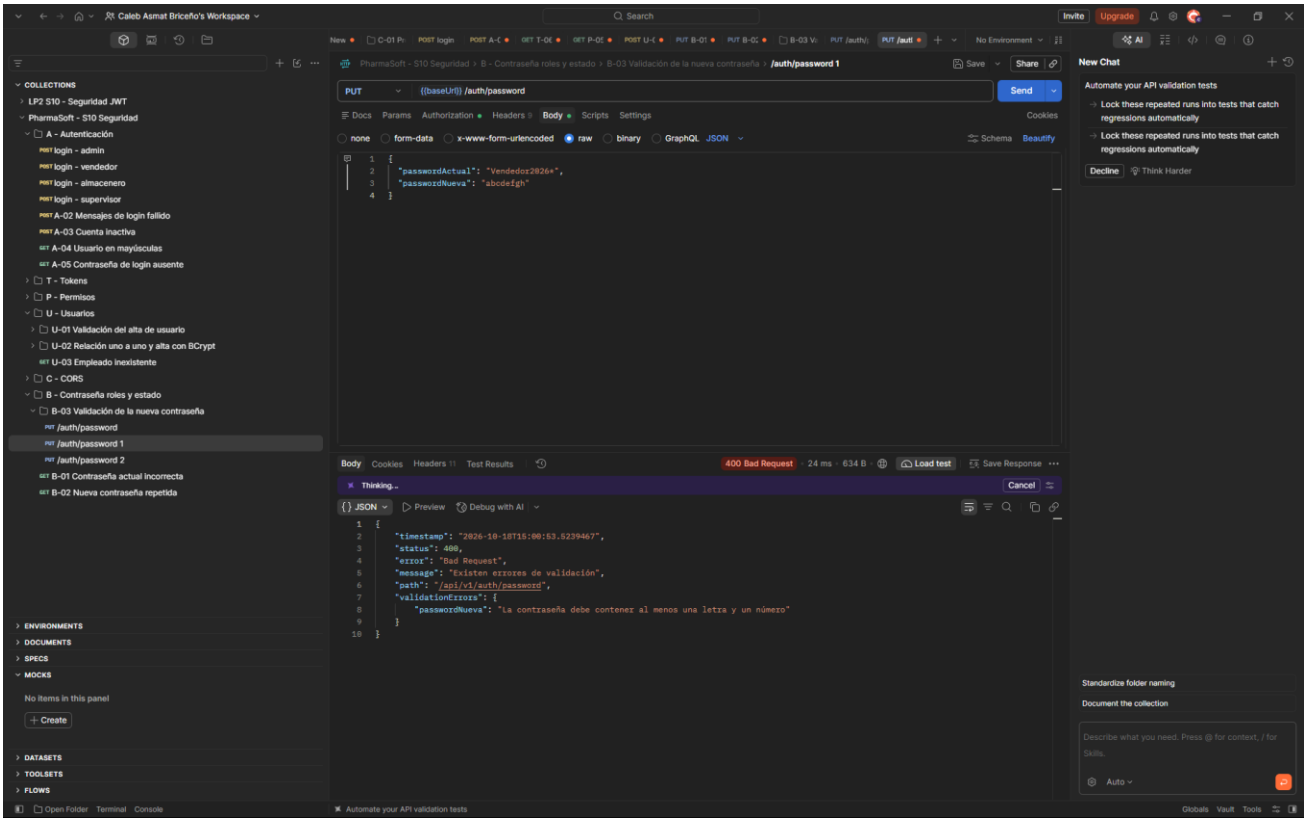
Precondición y datos utilizados: Password actual Vendedor2026*. Nuevas contraseñas probadas: abc1, abcdefgh y 12345678.

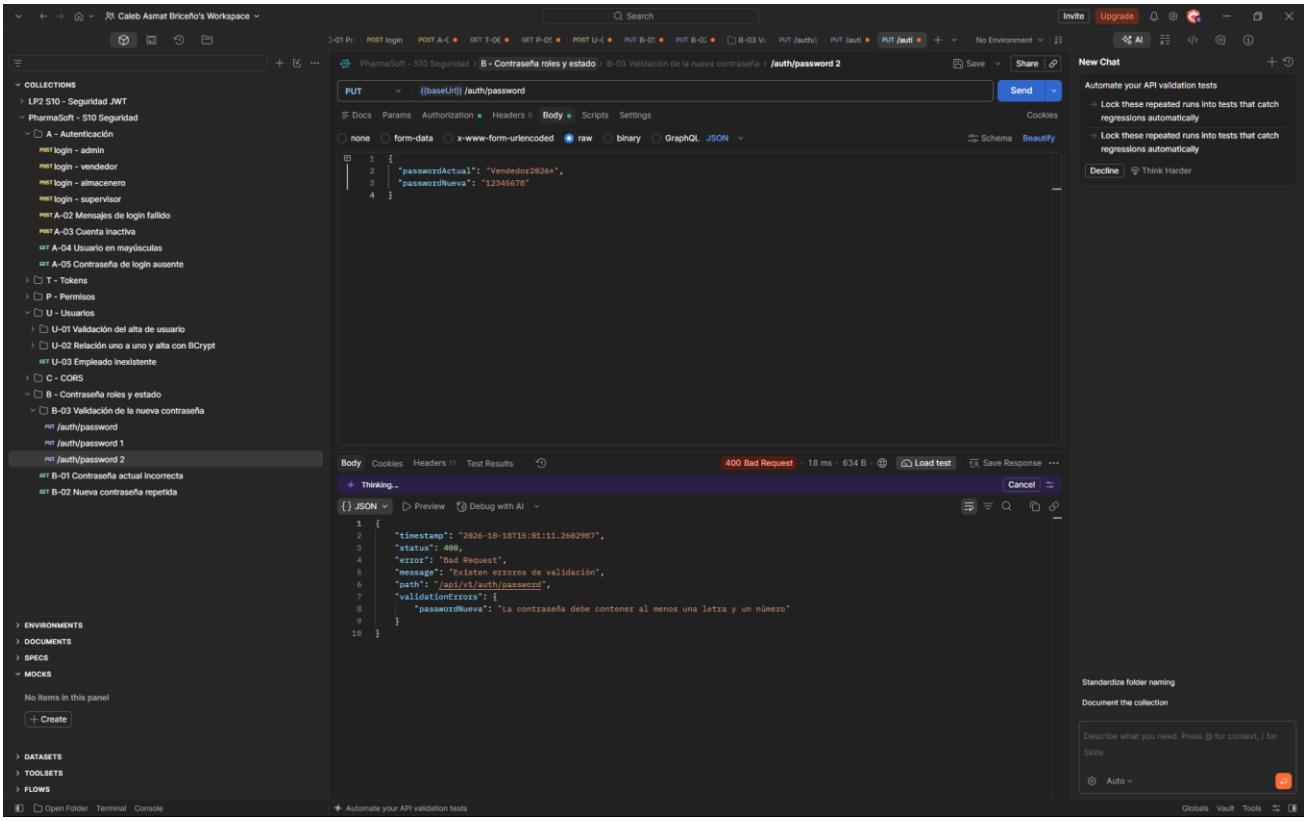
Resultado obtenido: 400 Bad Request en las tres. abc1 incumple longitud de 8 a 72 caracteres; abcdefgh y 12345678 incumplen la combinación de letra y número.

Estado: Pasa
Observaciones: Ninguna.

Evidencia: 3 capturas incrustadas en la sección B-03, en el orden de las operaciones.


PUT {{baseUrl}} /auth/password
Send
{
"passwordActual": "Vendedor2026*",
"passwordNueva": "abc1"
}
400 Bad Request
{
"timestamp": "2026-10-18T14:58:55.3665248",
"status": 400,
"error": "Bad Request",
"message": "Existen errores de validación",
"path": "/api/v1/auth/password",
"validationErrors": {
"passwordNueva": "La contraseña debe tener entre 8 y 72 caracteres"
}
}


PUT {{baseUrl}} /auth/password
Send
{
"passwordActual": "Vendedor2026*",
"passwordNueva": "abcdefgh"
}
400 Bad Request
{
"timestamp": "2026-10-18T15:00:53.5239467",
"status": 400,
"error": "Bad Request",
"message": "Existen errores de validación",
"path": "/api/v1/auth/password",
"validationErrors": {
"passwordNueva": "La contraseña debe contener al menos una letra y un número"
}
}


Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
LP2 S10 - Seguridad JWT
PharmaSoft - S10 Seguridad
A - Autenticación
login - admin
login - vendedor
login - almacenero
login - supervisor
A-02 Mensajes de login fallido
A-03 Cuenta inactiva
A-04 Usuario en mayúsculas
A-05 Contraseña de login ausente
T - Tokens
P - Permisos
U - Usuarios
U-01 Validación del alta de usuario
U-02 Relación uno a uno y alta con BCrypt
U-03 Empleado inexistente
C - CORS
B - Contraseña roles y estado
B-03 Validación de la nueva contraseña
/auth/password
/auth/password 1
/auth/password 2
B-01 Contraseña actual Incorrecta
B-02 Nueva contraseña repetida
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
PharmaSoft - S10 Seguridad › B - Contraseña roles y estado › B-03 Validación de la nueva contraseña › /auth/password 2
Save
Share
PUT
{{baseUrl}} /auth/password
Send
Docs
Params
Authorization
Headers 9
Body
Scripts
Settings
Cookies
none
form-data
x-www-form-urlencoded
raw
binary
GraphQL
JSON
Schema
Beautify
{
"passwordActual": "Vendedor2026+",
"passwordNueva": "12345678"
}
Body
Cookies
Headers 11
Test Results
400 Bad Request
18 ms
634 B
Load test
Save Response
Thinking...
Cancel
JSON
Preview
Debug with AI
{
"timestamp": "2026-10-18T15:01:11.2602987",
"status": 400,
"error": "Bad Request",
"message": "Existen errores de validación",
"path": "/api/v1/auth/password",
"validationErrors": {
"passwordNueva": "La contraseña debe contener al menos una letra y un número"
}
}
AI
New Chat
Automate your API validation tests
Lock these repeated runs into tests that catch regressions automatically
Lock these repeated runs into tests that catch regressions automatically
Decline
Think Harder
Standardize folder naming
Document the collection
Describe what you need. Press @ for context, / for Skills.
Auto
Open Folder
Terminal
Console
Automate your API validation tests
Globals
Vault
Tools

B-04 Cambio exitoso y comportamiento del token

Grupo: Contraseña
Usuario o token: vendedor

Petición: PUT /auth/password; POST /auth/login; GET /auth/me; SQL
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

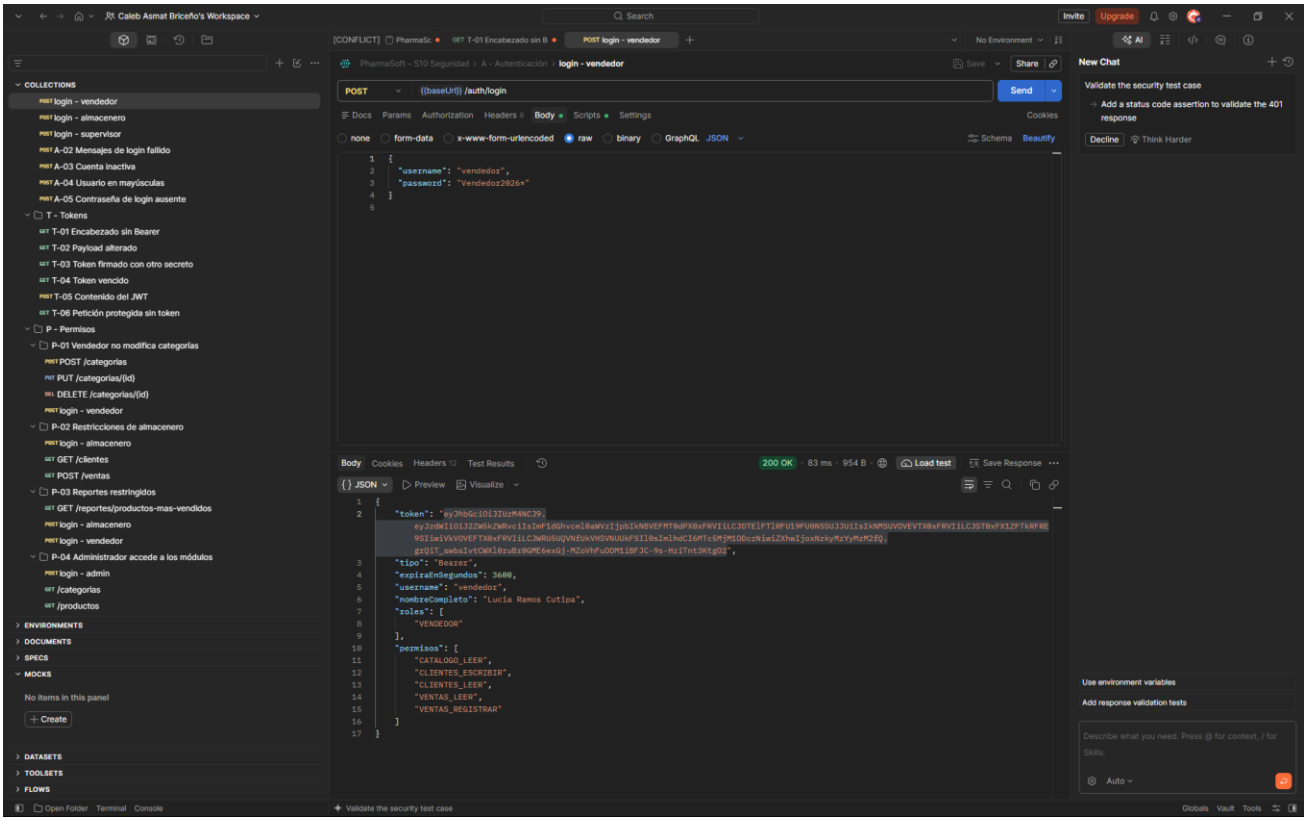
Resultado esperado: 204 sin cuerpo; login anterior 401; login nuevo 200; token anterior aún válido mientras no expire; hash BCrypt nuevo.

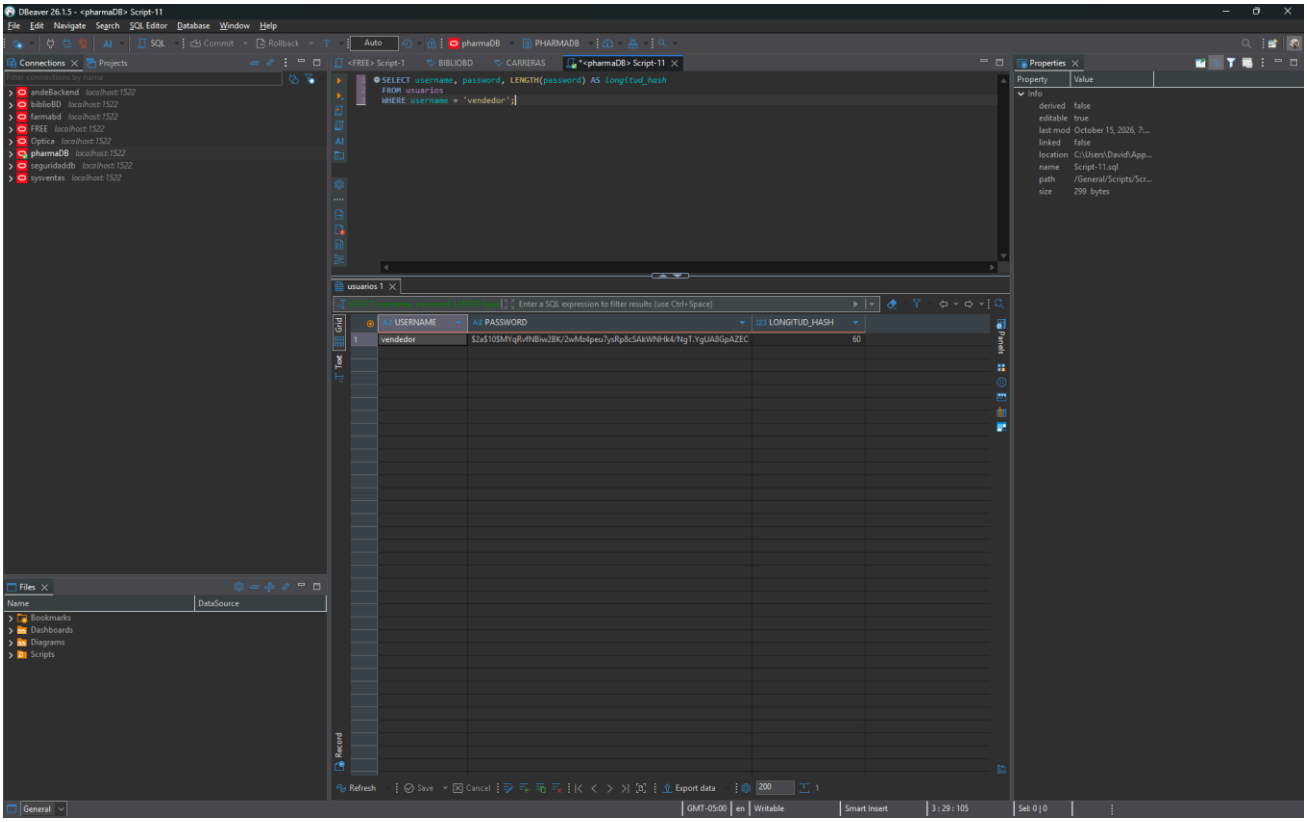
Precondición y datos utilizados: Login de vendedor con Vendedor2026*; consulta inicial del hash; cambio a NuevaClave2026 mediante PUT /auth/password; consulta posterior del hash. Se conserva el token previo en {{tokenVendedorAnterior}}.

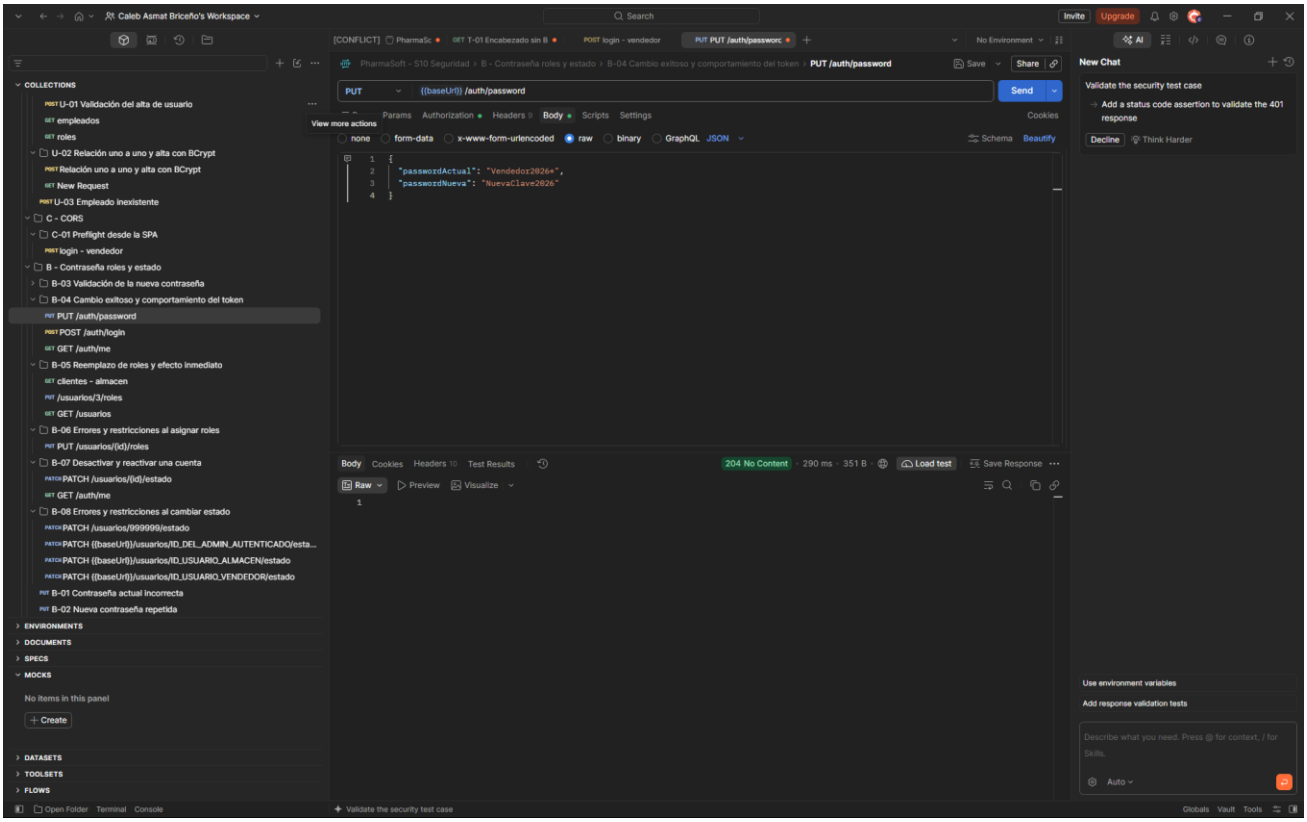
Resultado obtenido: Login inicial 200; cambio 204 sin cuerpo; contraseña anterior rechazada con 401 y nueva aceptada con 200. Las consultas de Oracle muestran hashes BCrypt diferentes, ambos de 60 caracteres.

Estado: Pasa
Observaciones: Se acredita el cambio de contraseña, los logins, el token previo, los hashes BCrypt diferentes de 60 caracteres y el registro INFO de AuthServiceImpl: Contraseña actualizada: usuario=vendedor.

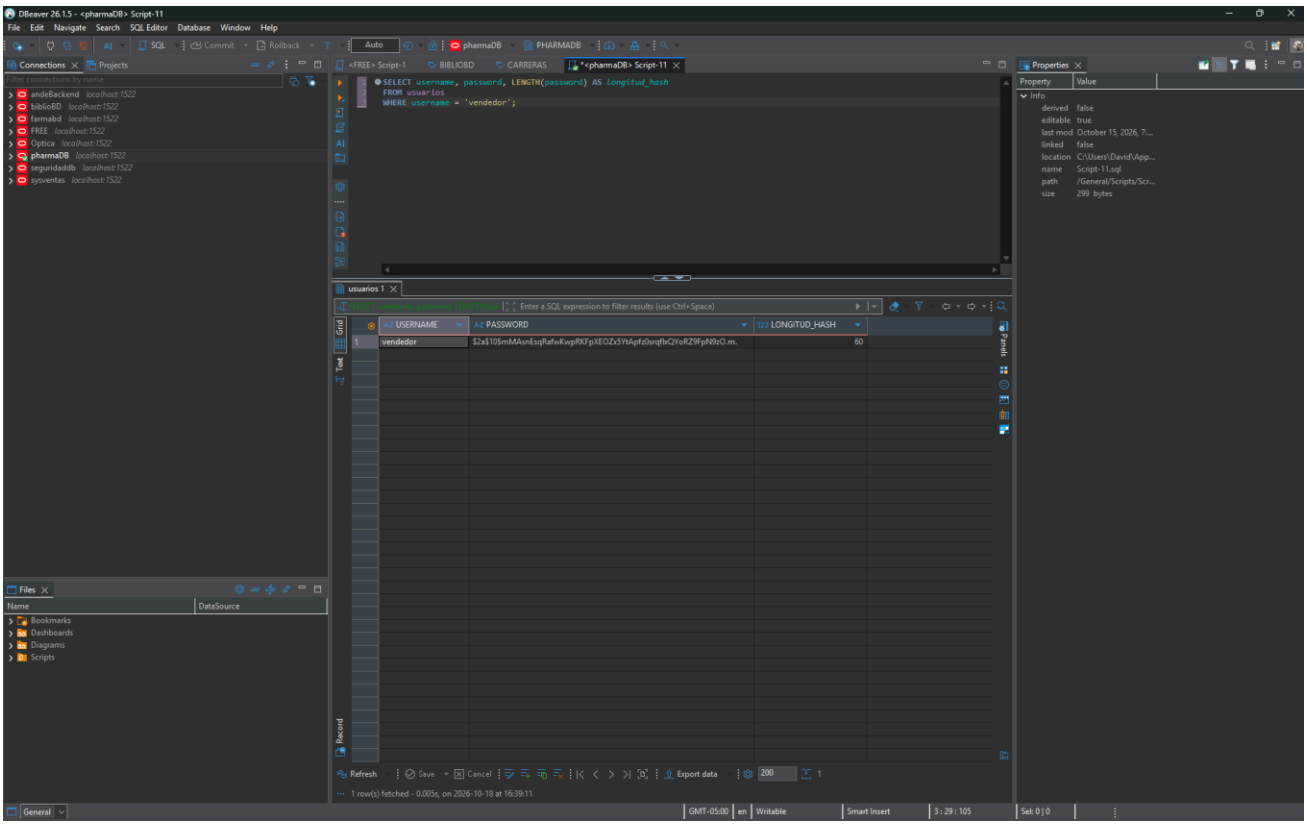
Evidencia: 8 capturas incrustadas en la sección B-04, incluido el registro INFO.

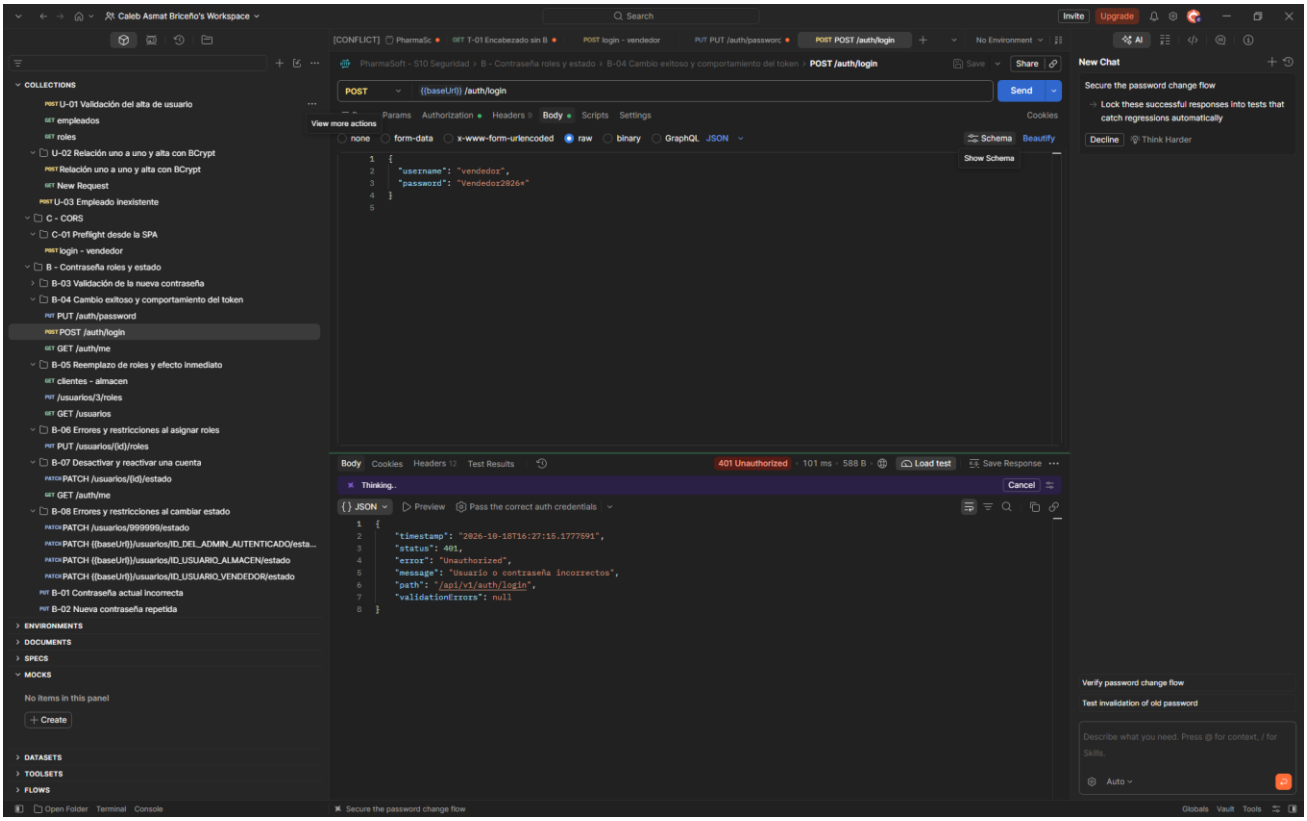

POST login - vendedor
{{baseUrl}} /auth/login
Send
{
"username": "vendedor",
"password": "Vendedor2026*"
}
200 OK
{
"token": "eyJhbGciOiJIUzM4NC39.
eyJzdWIiOiJ2ZW5kZWRvciIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0xFRVIiLCJDTElFTlRFU19FU0NSSUJJUiIsIkNMSUVOVEVTX0xFRVIiLCJSTBxFX1ZFTkRFRE9SIiwiVkVOVEFTX0xFRVIiLCJWRUSUQVNtEukVHSVNVUUkFSIl0sImlhdCI6MTc5MjM1ODczNiwiZXhwIjoxNzkyMzYyMzM2fQ.
grQiT_swbsIvtCWXl0zuBz0GME6exGj-MZoVhFuODM1iBFJC-9s-HziTnt3KtgO2",
"tipo": "Bearer",
"expiraEnSegundos": 3600,
"username": "vendedor",
"nombreCompleto": "Lucía Ramos Cutipa",
"roles": [
"VENDEDOR"
],
"permisos": [
"CATALOGO_LEER",
"CLIENTES_ESCRIBIR",
"CLIENTES_LEER",
"VENTAS_LEER",
"VENTAS_REGISTRAR"
]
}

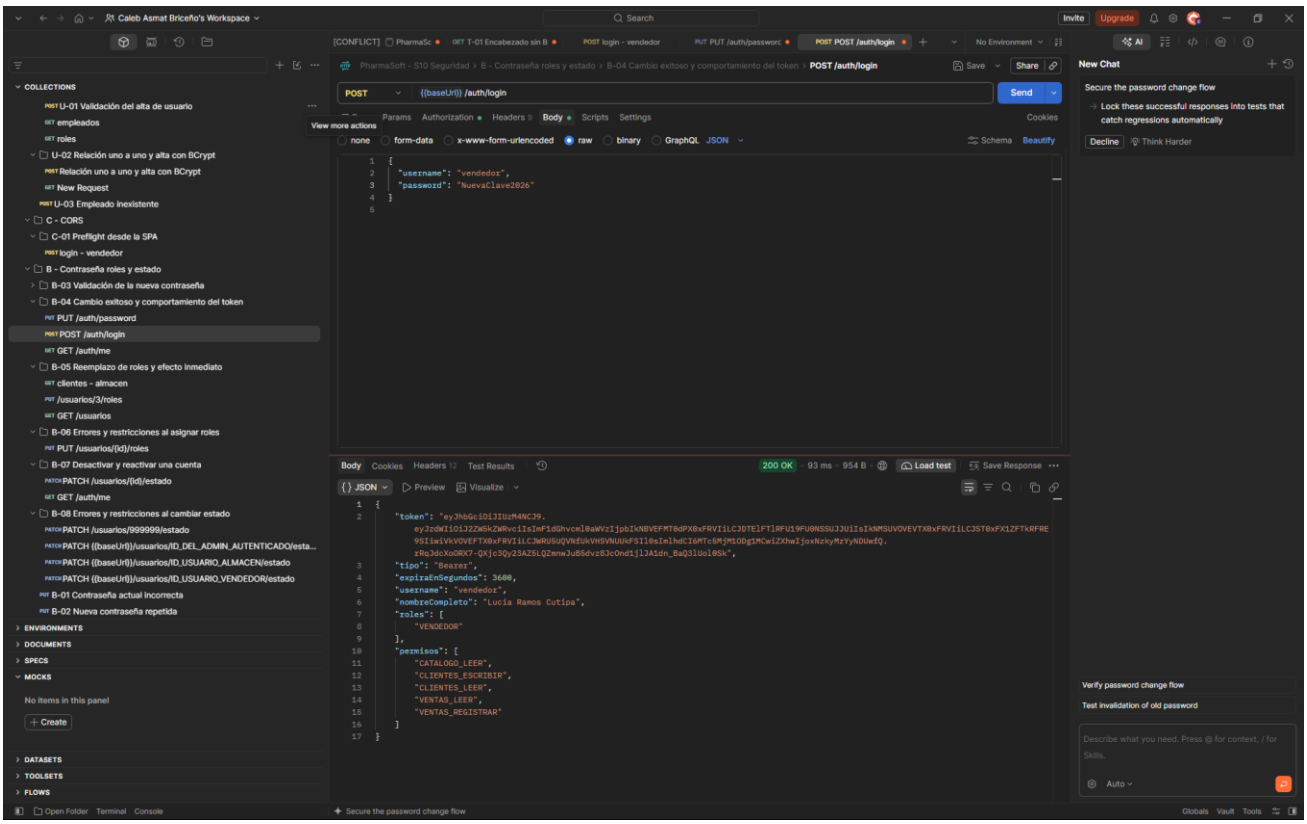

SELECT username, password, LENGTH(password) AS longitud_hash
FROM usuarios
WHERE username = 'vendedor';
USERNAME
PASSWORD
LONGITUD_HASH
vendedor
$2a$10$MYqRvfNBiw2BK/2wMp4peu7ysRp8cSAkWNHk4/NgT.YgUA8GpAZEC
60

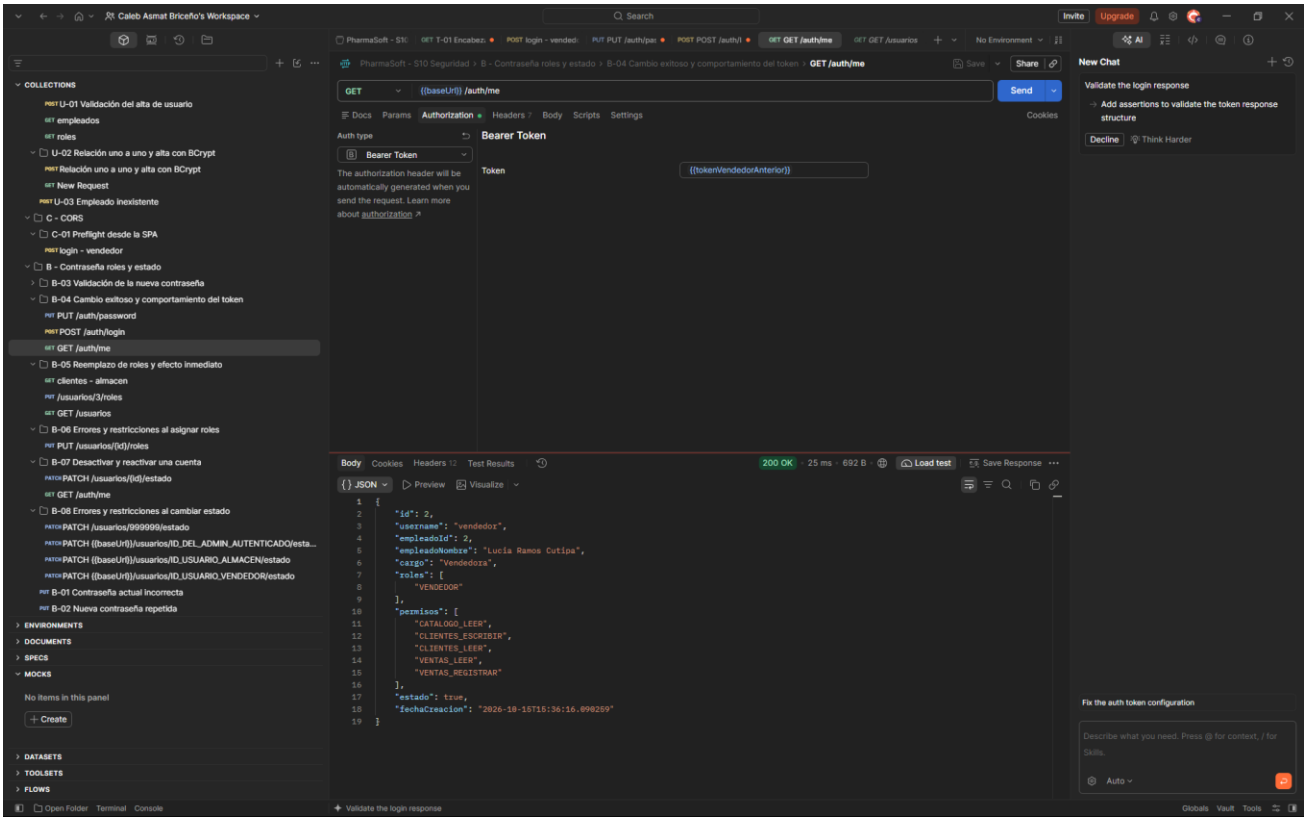



```
INFO 3728 --- [PharmaBackend] [nio-8080-exec-7] p.e.u.P.service.impl.AuthServiceImpl     : Contraseña actualizada: usuario=vendedor
```




POST {{baseUrl}} /auth/login
Send
Params Authorization Headers 9 Body Scripts Settings
none form-data x-www-form-urlencoded raw binary GraphQL JSON
{
"username": "vendedor",
"password": "Vendedor2026*"
}
Body Cookies Headers 12 Test Results
401 Unauthorized 101 ms 588 B
{
"timestamp": "2026-10-18T16:27:15.1777591",
"status": 401,
"error": "Unauthorized",
"message": "Usuario o contraseña incorrectos",
"path": "/api/v1/auth/login",
"validationErrors": null
}


POST {{baseUrl}} /auth/login
Send
Params Authorization Headers 9 Body Scripts Settings
none form-data x-www-form-urlencoded raw binary GraphQL JSON
{
"username": "vendedor",
"password": "NuevaClave2026*"
}
Body Cookies Headers 12 Test Results
200 OK 93 ms 954 B
{
"token": "eyJhbGciOiJIUzM4NCJ9.
eyJzdWIiOiJ2ZWSkZWRvciIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0xFRVIiLCJDTElFTlRFU19FU0NSSUJJUiIsIkNMSUVOVEVTX0xFRVIiLCJSTE9xFX1ZFTkRFRE9SIiwiVkVGVEFTX0xFRVIiLCJWRU5UQVNfUkVHSVNUUkFSIl0sImlhdCI6MTc5MjM1ODg1MCwiZXhwIjoxNzkyMzYyNDUwfQ.
zRoJdoXoO0X7-QXjc3Qy23A25LQZmnwJuB5dvz8JcOndjlJA1dn_BaQ3lOolB5k",
"tipo": "Bearer",
"expiraEnSegundos": 3600,
"username": "vendedor",
"nombreCompleto": "Lucia Ramos Cutipa",
"roles": [
"VENDEDOR"
],
"permisos": [
"CATALOGO_LEER",
"CLIENTES_ESCRIBIR",
"CLIENTES_LEER",
"VENTAS_LEER",
"VENTAS_REGISTRAR"
]
}


Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
U-01 Validación del alta de usuario
empleados
roles
U-02 Relación uno a uno y alta con BCrypt
Relación uno a uno y alta con BCrypt
New Request
U-03 Empleado inexistente
C - CORS
C-01 Preflight desde la SPA
login - vendedor
B - Contraseña roles y estado
B-03 Validación de la nueva contraseña
B-04 Cambio exitoso y comportamiento del token
PUT /auth/password
POST /auth/login
GET /auth/me
B-05 Reemplazo de roles y efecto inmediato
clientes - almacen
/usuarios/3/roles
GET /usuarios
B-06 Errores y restricciones al asignar roles
PUT /usuarios/{id}/roles
B-07 Desactivar y reactivar una cuenta
PATCH /usuarios/{id}/estado
GET /auth/me
B-08 Errores y restricciones al cambiar estado
PATCH /usuarios/999999/estado
PATCH {{baseUrl}}/usuarios/ID_DEL_ADMIN_AUTENTICADO/esta...
PATCH {{baseUrl}}/usuarios/ID_USUARIO_ALMACEN/estado
PATCH {{baseUrl}}/usuarios/ID_USUARIO_VENDEDOR/estado
B-01 Contraseña actual incorrecta
B-02 Nueva contraseña repetida
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
Open Folder
Terminal
Console
PharmaSoft - S10 Seguridad › B - Contraseña roles y estado › B-04 Cambio exitoso y comportamiento del token › GET /auth/me
Save
Share
GET
{{baseUrl}} /auth/me
Send
Docs
Params
Authorization
Headers 7
Body
Scripts
Settings
Cookies
Auth type
Bearer Token
The authorization header will be automatically generated when you send the request. Learn more about authorization
Bearer Token
Token
{{tokenVendedorAnterior}}
Body
Cookies
Headers 12
Test Results
200 OK
25 ms
692 B
Load test
Save Response
{ } JSON
Preview
Visualize
{
"id": 2,
"username": "vendedor",
"empleadoId": 2,
"empleadoNombre": "Lucia Ramos Cutipa",
"cargo": "Vendedora",
"roles": [
"VENDEDOR"
],
"permisos": [
"CATALOGO_LEER",
"CLIENTES_ESCRIBIR",
"CLIENTES_LEER",
"VENTAS_LEER",
"VENTAS_REGISTRAR"
],
"estado": true,
"fechaCreacion": "2026-10-15T15:36:16.690269"
}
AI
New Chat
Validate the login response
Add assertions to validate the token response structure
Decline
Think Harder
Fix the auth token configuration
Describe what you need. Press @ for context, / for Skills.
Auto
Validate the login response
Globals
Vault
Tools

B-05 Reemplazo de roles y efecto inmediato

Grupo: Roles
Usuario o token: admin y almacen

Petición: PUT /usuarios/{id}/roles; GET /clientes; SQL
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

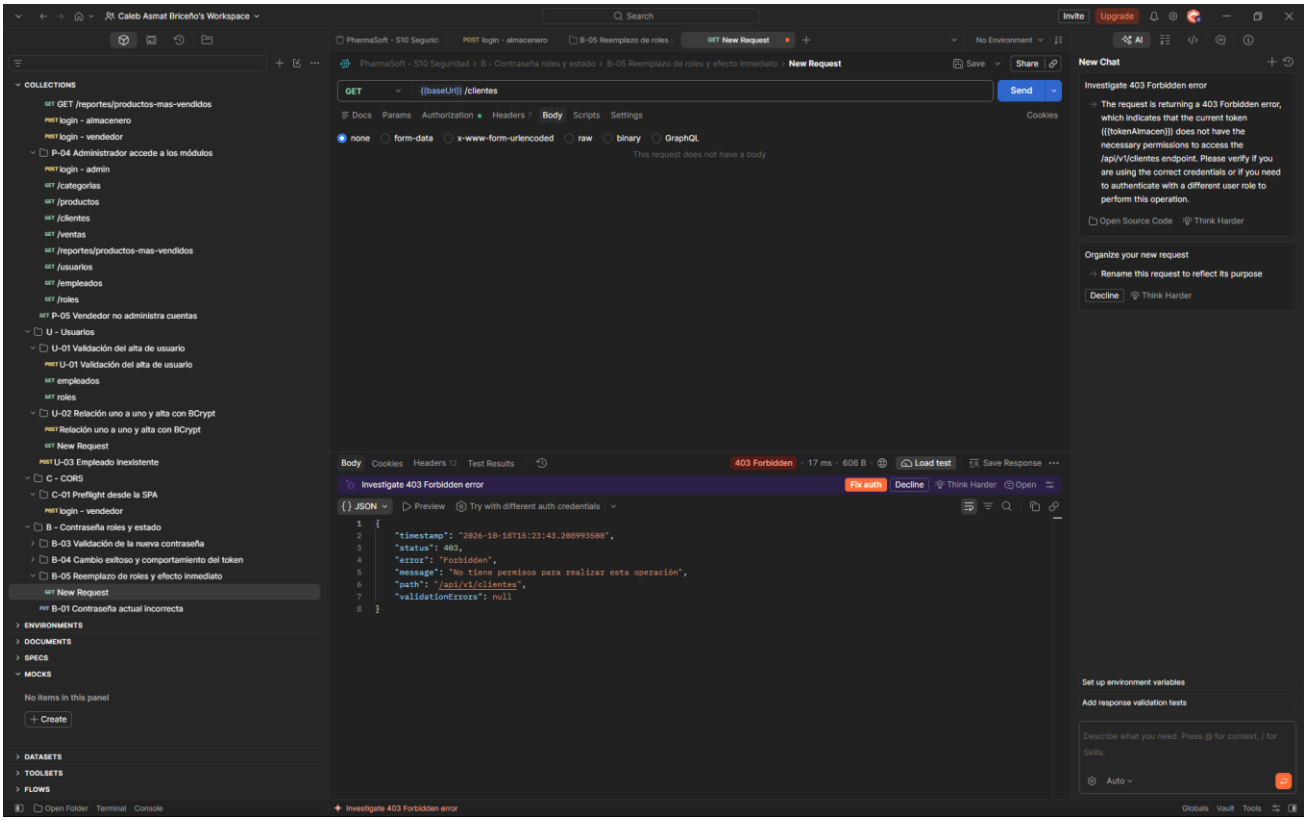
Resultado esperado: 200 con roles y permisos actualizados; mismo token de almacen obtiene CLIENTES_LEER tras añadir VENDEDOR; usuario_roles coincide.

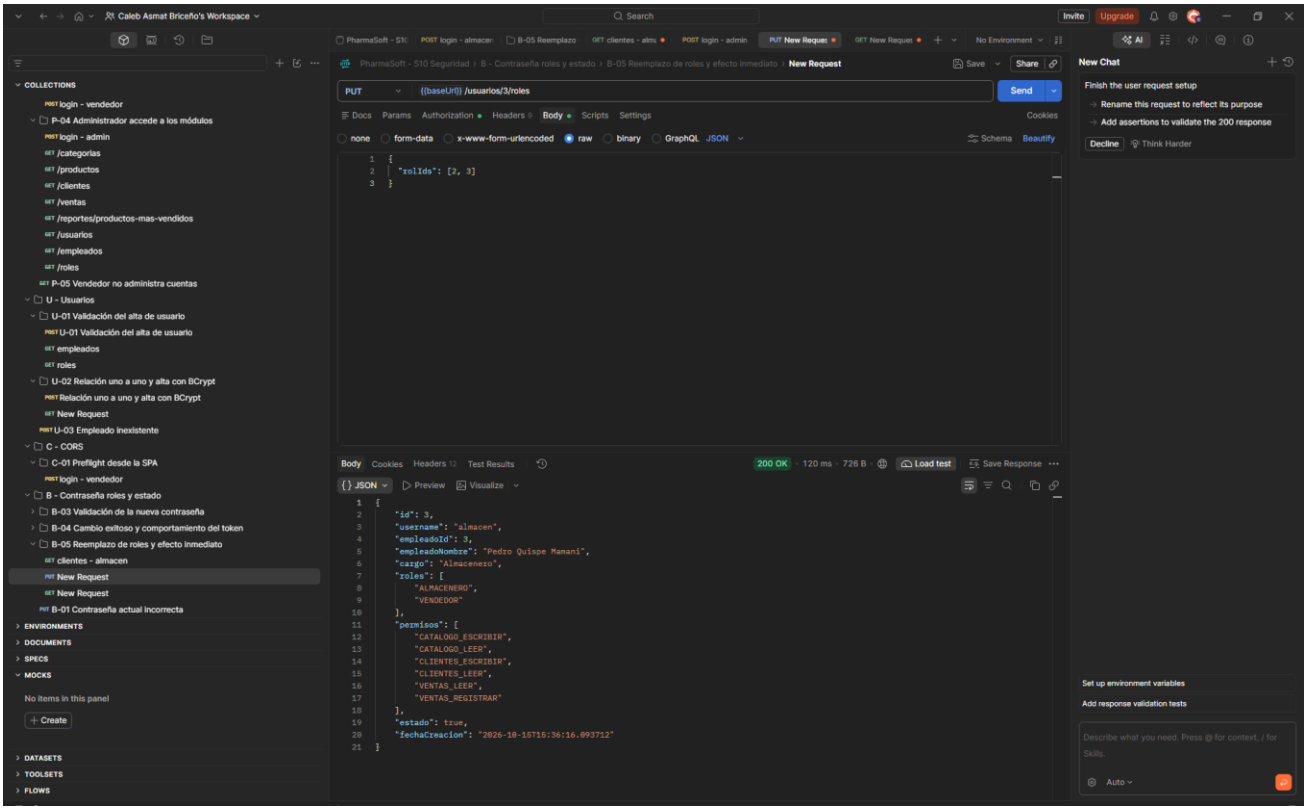
Precondición y datos utilizados: Usuario almacen 3, roles iniciales ALMACENERO. Admin envía rolIds 2 y 3. La consulta posterior usa la variable tokenAlmacen.

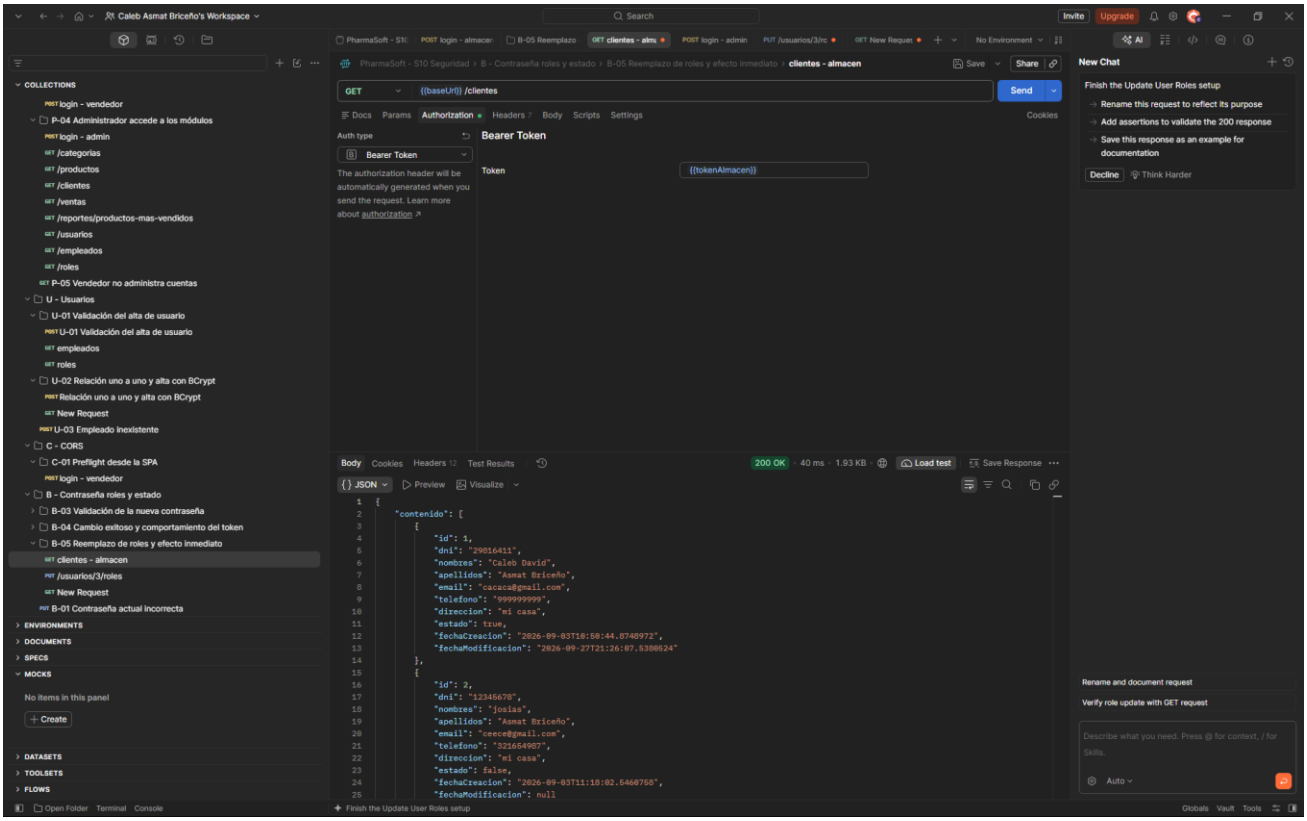
Resultado obtenido: GET /clientes pasó de 403 a 200 tras PUT /usuarios/3/roles con 200. La respuesta muestra ALMACENERO y VENDEDOR. Oracle confirma usuario 3 con roles 2 y 3.

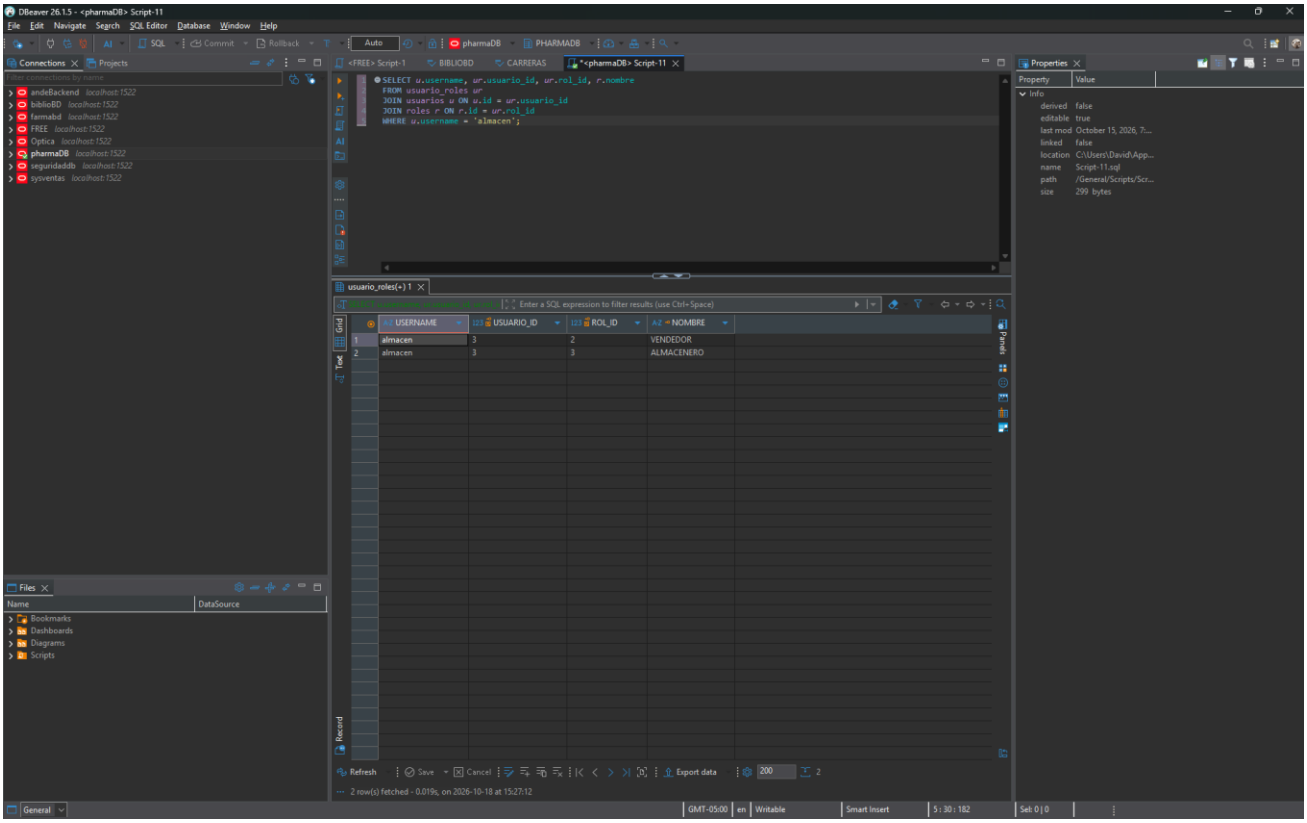
Estado: Pasa
Observaciones: La secuencia utiliza tokenAlmacen; no se adjunta una captura posterior de restauración de roles.

Evidencia: 4 capturas incrustadas en la sección B-05, en el orden de las operaciones.


GET {{baseUrl}} /clientes
Send
Body
none
form-data
x-www-form-urlencoded
raw
binary
GraphQL
This request does not have a body
403 Forbidden
Investigate 403 Forbidden error
Fix auth
Decline
{
"timestamp": "2026-10-18T15:23:43.20899350Ø",
"status": 403,
"error": "Forbidden",
"message": "No tiene permisos para realizar esta operación",
"path": "/api/v1/clientes",
"validationErrors": null
}
New Chat
Investigate 403 Forbidden error
The request is returning a 403 Forbidden error, which indicates that the current token ({{tokenAlmacen}}) does not have the necessary permissions to access the /api/v1/clientes endpoint. Please verify if you are using the correct credentials or if you need to authenticate with a different user role to perform this operation.
Organize your new request
Rename this request to reflect its purpose


PUT {{baseUrl}} /usuarios/3/roles
Send
raw
JSON
{
"rolIds": [2, 3]
}
200 OK
{
"id": 3,
"username": "almacen",
"empleadoId": 3,
"empleadoNombre": "Pedro Quispe Mamani",
"cargo": "Almacenero",
"roles": [
"ALMACENERO",
"VENDEDOR"
],
"permisos": [
"CATALOGO_ESCRIBIR",
"CATALOGO_LEER",
"CLIENTES_ESCRIBIR",
"CLIENTES_LEER",
"VENTAS_LEER",
"VENTAS_REGISTRAR"
],
"estado": true,
"fechaCreacion": "2026-10-15T15:36:16.893712"
}
New Chat
Finish the user request setup
Rename this request to reflect its purpose
Add assertions to validate the 200 response


Caleb Asmat Briceño's Workspace
COLLECTIONS
P-04 Administrador accede a los módulos
U - Usuarios
U-01 Validación del alta de usuario
C - CORS
C-01 Preflight desde la SPA
B - Contraseña roles y estado
B-03 Validación de la nueva contraseña
B-04 Cambio exitoso y comportamiento del token
B-05 Reemplazo de roles y efecto inmediato
clientes - almacen
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
DATASETS
TOOLSETS
FLOWS
GET {{baseUrl}} /clientes
Send
Bearer Token
Token
{{tokenAlmacen}}
200 OK
"contenido": [
"id": 1,
"dni": "29816411",
"nombres": "Caleb David",
"apellidos": "Asmat Briceño",
"email": "cacaca@gmail.com",
"telefono": "999999999",
"direccion": "mi casa",
"estado": true,
"fechaCreacion": "2026-09-03T18:58:44.8748972",
"fechaModificacion": "2026-09-27T21:26:07.6308624"
"id": 2,
"dni": "12345678",
"nombres": "josias",
"apellidos": "Asmat Briceño",
"email": "ceece@gmail.com",
"telefono": "321654987",
"direccion": "mi casa",
"estado": false,
"fechaCreacion": "2026-09-03T11:18:02.6460758",
"fechaModificacion": null
New Chat
Finish the Update User Roles setup
Rename this request to reflect its purpose
Add assertions to validate the 200 response
Save this response as an example for documentation
Decline
Think Harder
Rename and document request
Verify role update with GET request


DBeaver 26.1.3 - <pharmaDB> Script-11
SELECT u.username, ur.usuario_id, ur.rol_id, r.nombre
FROM usuario_roles ur
JOIN usuarios u ON u.id = ur.usuario_id
JOIN roles r ON r.id = ur.rol_id
WHERE u.username = 'almacen';
USERNAME
USUARIO_ID
ROL_ID
NOMBRE
almacen 3 2 VENDEDOR
almacen 3 3 ALMACENERO
2 row(s) fetched - 0.019s, on 2026-10-18 at 15:27:12

B-06 Errores y restricciones al asignar roles

Grupo: Roles
Usuario o token: admin y vendedor

Petición: PUT /usuarios/{id}/roles
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

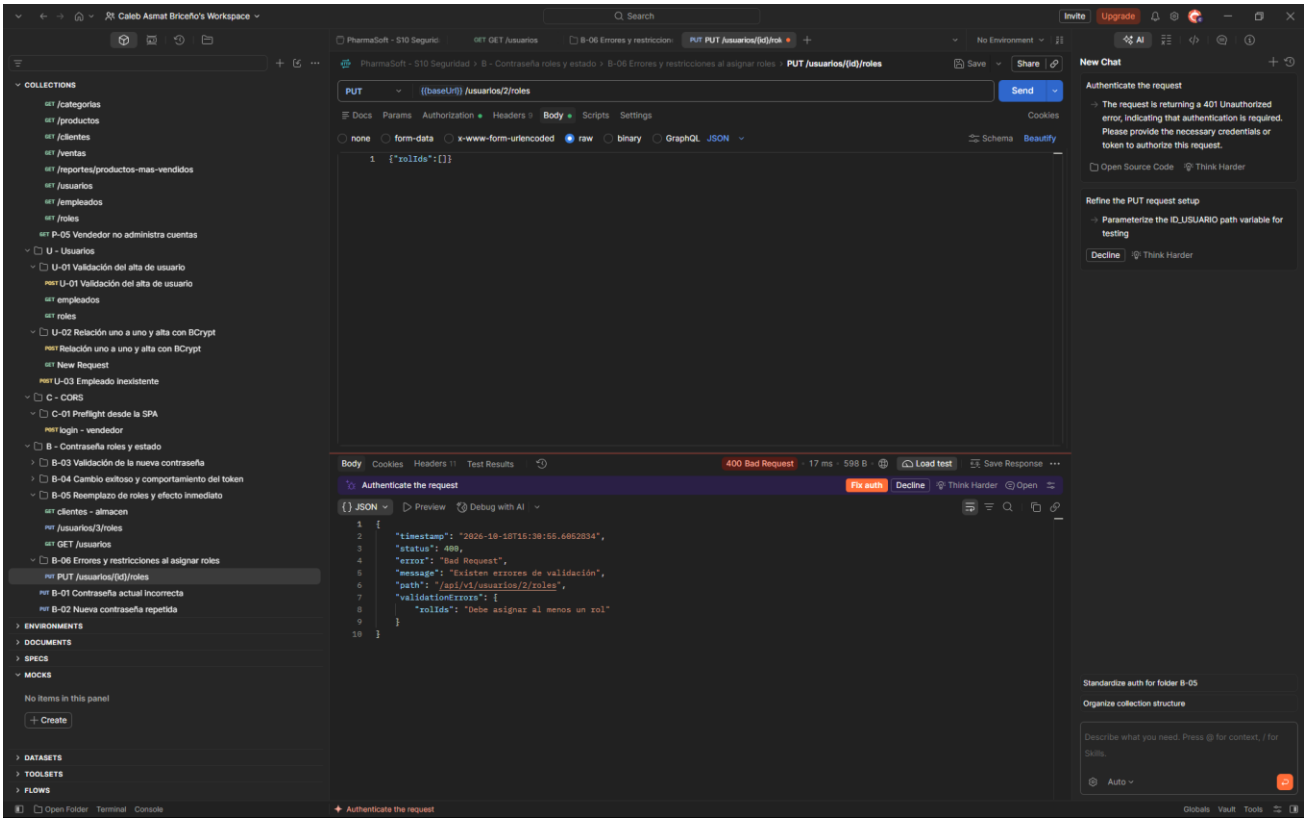
Resultado esperado: 400 por rolIds []; 404 por rol inexistente; 404 por usuario inexistente; 409 por quitarse ADMIN; 403 si opera vendedor.

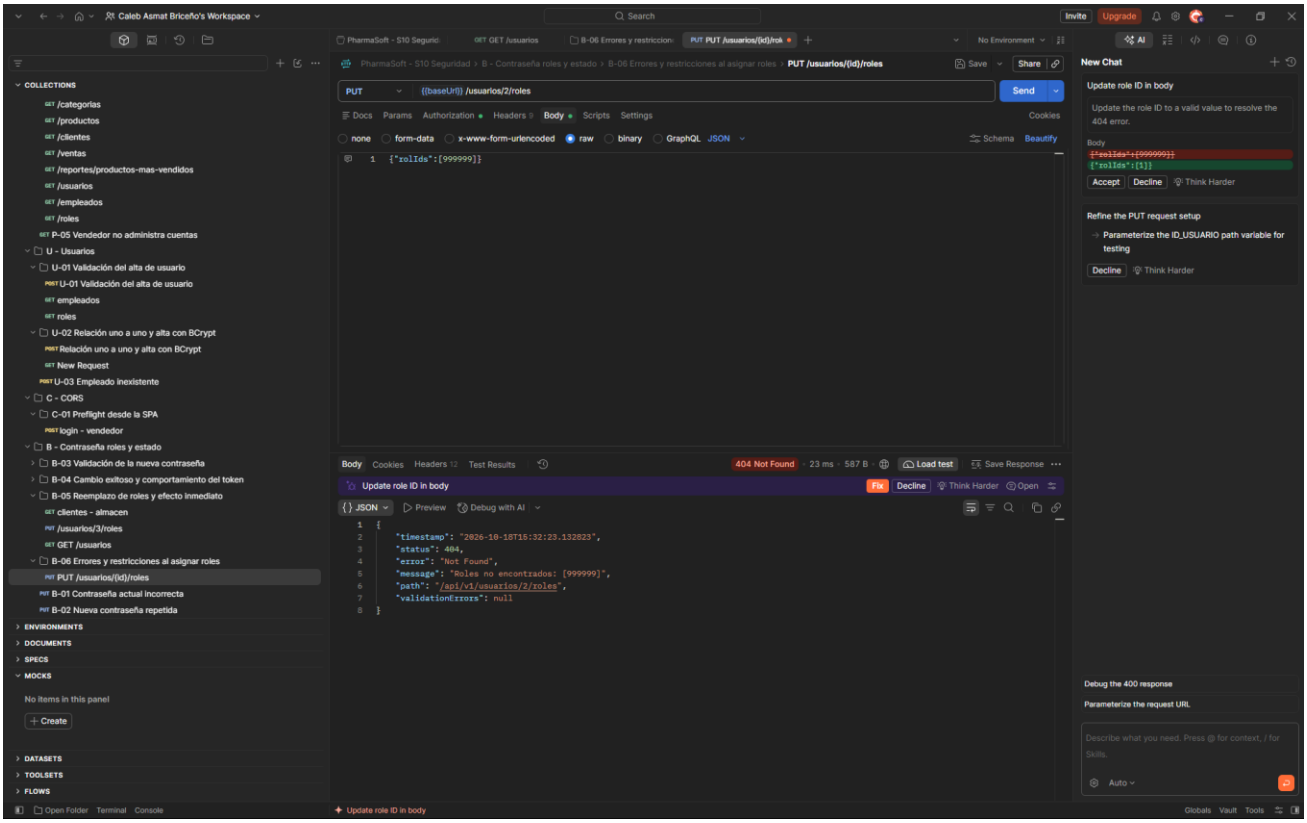
Precondición y datos utilizados: Usuarios 2 y 1 existentes. Se prueban rolIds vacío, rol 999999, usuario 999999, quitar ADMIN al usuario 1 y operar con vendedor sobre usuario 3.

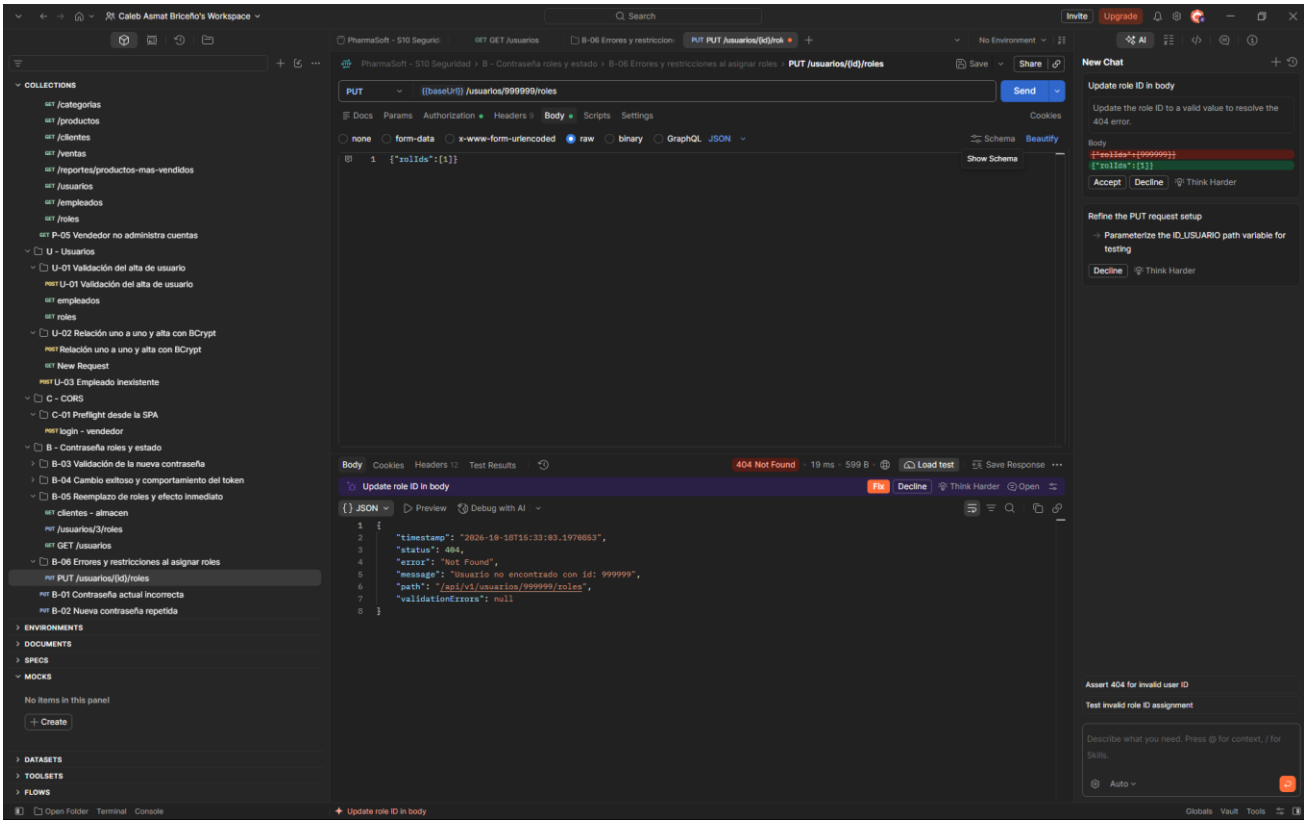
Resultado obtenido: 400 por roles vacíos; 404 Roles no encontrados: [999999]; 404 Usuario no encontrado con id: 999999; 409 No puede quitarse a sí mismo el rol ADMIN; 403 por falta de permisos.

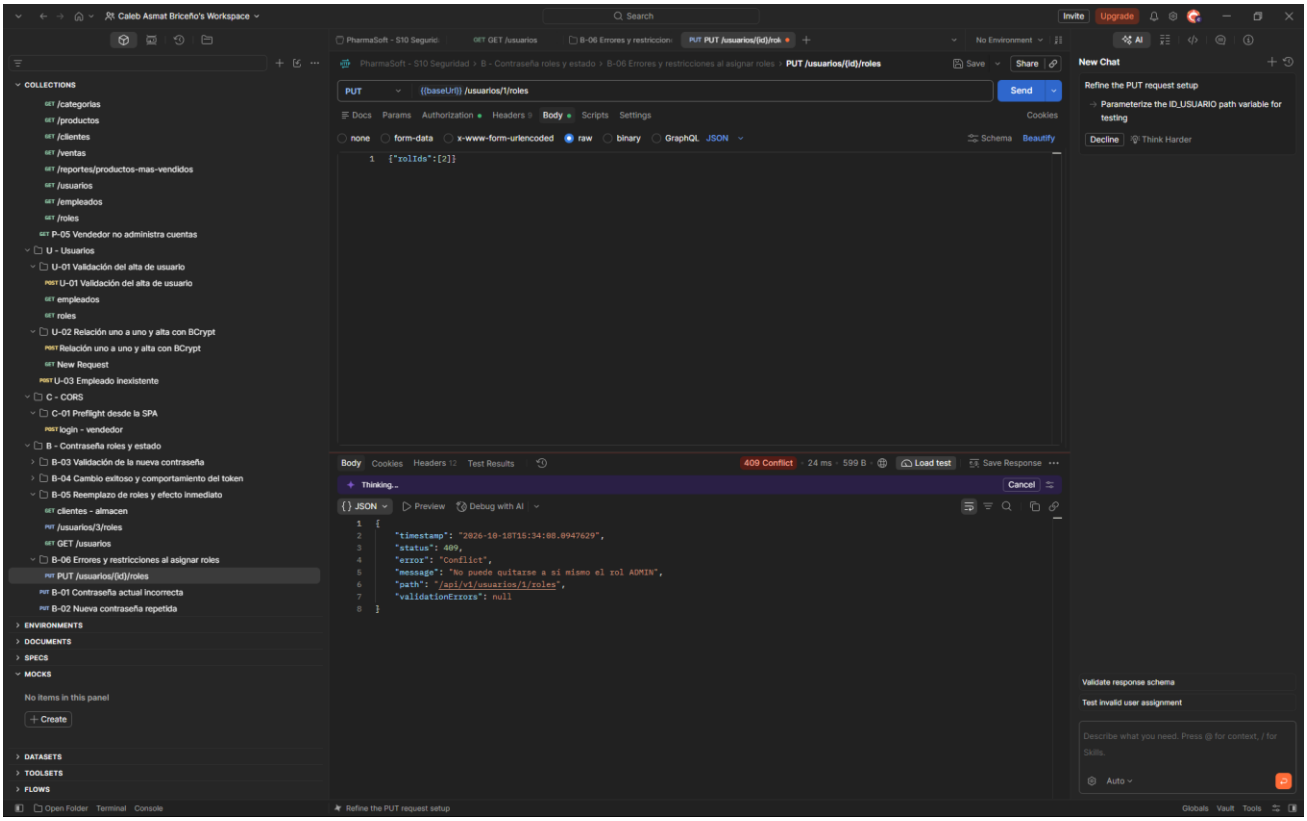
Estado: Pasa
Observaciones: Ninguna.

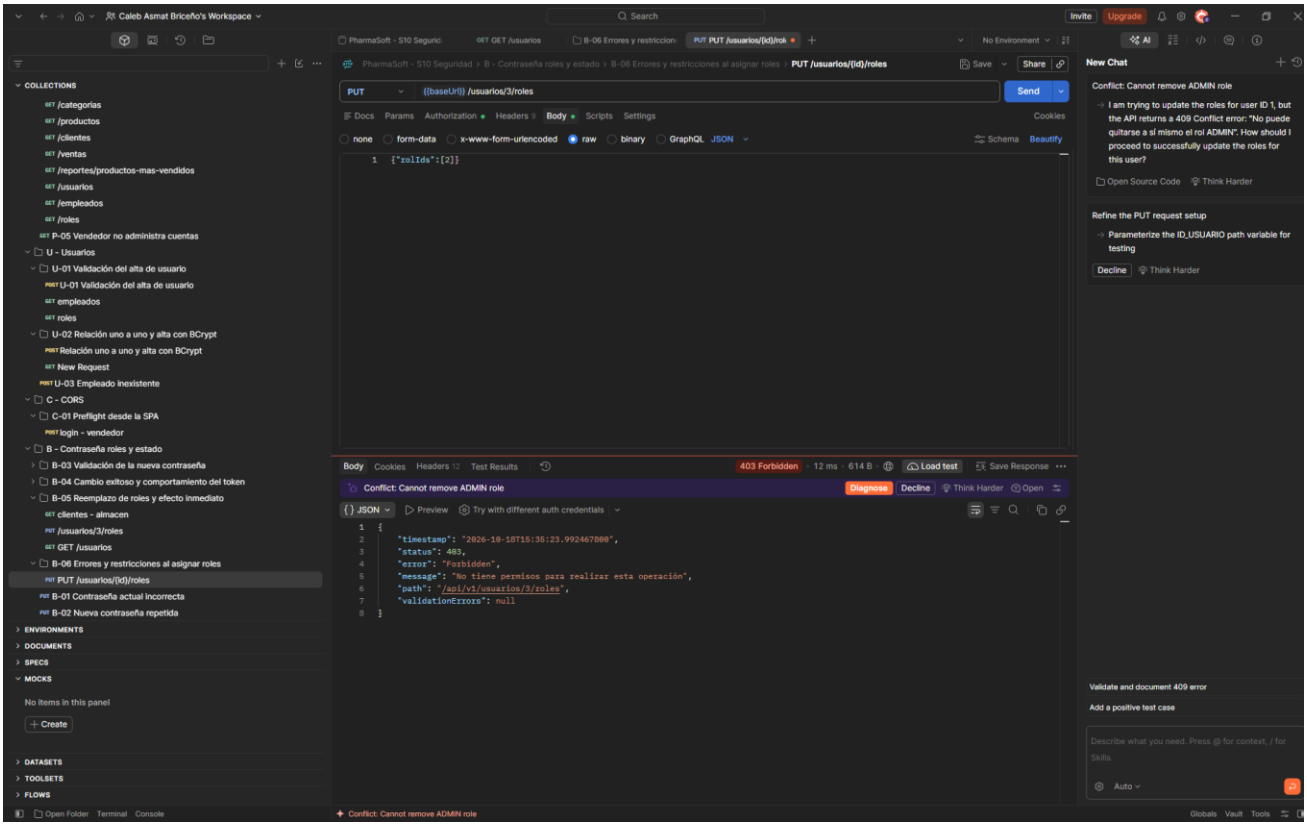
Evidencia: 5 capturas incrustadas en la sección B-06, en el orden de las operaciones.




PUT /usuarios/{id}/roles
PUT {{baseUrl}} /usuarios/2/roles
Send
{"rolIds":[999999]}
Body Cookies Headers 12 Test Results
404 Not Found · 23 ms · 587 B
Load test
Save Response
Update role ID in body
Fix Decline Think Harder Open
JSON Preview Debug with AI
{
"timestamp": "2026-10-18T15:32:23.132823",
"status": 404,
"error": "Not Found",
"message": "Roles no encontrados: [999999]",
"path": "/api/v1/usuarios/2/roles",
"validationErrors": null
}
New Chat
Update role ID in body
Update the role ID to a valid value to resolve the 404 error.
Body
{"rolIds":[999999]}
{"rolIds":[1]}
Accept Decline Think Harder
Refine the PUT request setup
Parameterize the ID_USUARIO path variable for testing
Decline Think Harder
Debug the 400 response
Parameterize the request URL
Describe what you need. Press @ for context, / for Skills.
Auto


PUT /usuarios/{id}/roles
PUT {{baseUrl}} /usuarios/999999/roles
Send
{"rolIds":[1]}
Show Schema
Body Cookies Headers 12 Test Results
404 Not Found · 19 ms · 599 B
Load test
Save Response
Update role ID in body
Fix Decline Think Harder Open
JSON Preview Debug with AI
{
"timestamp": "2026-10-18T15:33:03.1970853",
"status": 404,
"error": "Not Found",
"message": "Usuario no encontrado con id: 999999",
"path": "/api/v1/usuarios/999999/roles",
"validationErrors": null
}
New Chat
Update role ID in body
Update the role ID to a valid value to resolve the 404 error.
Body
{"rolIds":[999999]}
{"rolIds":[1]}
Accept Decline Think Harder
Refine the PUT request setup
Parameterize the ID_USUARIO path variable for testing
Decline Think Harder
Assert 404 for invalid user ID
Test invalid role ID assignment
Describe what you need. Press @ for context, / for Skills.
Auto


Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
GET /categorias
GET /productos
GET /clientes
GET /ventas
GET /reportes/productos-mas-vendidos
GET /usuarios
GET /empleados
GET /roles
GET P-05 Vendedor no administra cuentas
U - Usuarios
U-01 Validación del alta de usuario
POST U-01 Validación del alta de usuario
GET empleados
GET roles
U-02 Relación uno a uno y alta con BCrypt
POST Relación uno a uno y alta con BCrypt
GET New Request
POST U-03 Empleado inexistente
C - CORS
C-01 Preflight desde la SPA
POST login - vendedor
B - Contraseña roles y estado
B-03 Validación de la nueva contraseña
B-04 Cambio exitoso y comportamiento del token
B-05 Reemplazo de roles y efecto inmediato
GET clientes - almacen
PUT /usuarios/3/roles
GET GET /usuarios
B-06 Errores y restricciones al asignar roles
PUT PUT /usuarios/{id}/roles
POST B-01 Contraseña actual incorrecta
POST B-02 Nueva contraseña repetida
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
PharmaSoft - S10 Seguridad
B - Contraseña roles y estado
B-06 Errores y restricciones al asignar roles
PUT /usuarios/{id}/roles
Save
Share
PUT
{{baseUrl}} /usuarios/1/roles
Send
Docs
Params
Authorization
Headers 9
Body
Scripts
Settings
Cookies
none
form-data
x-www-form-urlencoded
raw
binary
GraphQL
JSON
Schema
Beautify
1 {"rolIds":[2]}
Body
Cookies
Headers 12
Test Results
409 Conflict
24 ms
599 B
Load test
Save Response
Thinking...
Cancel
JSON
Preview
Debug with AI
1 {
2 "timestamp": "2026-10-18T15:34:08.8947629",
3 "status": 409,
4 "error": "Conflict",
5 "message": "No puede quitarse a si mismo el rol ADMIN",
6 "path": "/api/v1/usuarios/1/roles",
7 "validationErrors": null
8 }
New Chat
Refine the PUT request setup
Parameterize the ID_USUARIO path variable for testing
Decline
Think Harder
Validate response schema
Test invalid user assignment
Describe what you need. Press @ for context, / for Skills.
Auto
Open Folder
Terminal
Console
Refine the PUT request setup
Globals
Vault
Tools


Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
GET /categorias
GET /productos
GET /clientes
GET /ventas
GET /reportes/productos-mas-vendidos
GET /usuarios
GET /empleados
GET /roles
GET P-05 Vendedor no administra cuentas
U - Usuarios
U-01 Validación del alta de usuario
POST U-01 Validación del alta de usuario
GET empleados
GET roles
U-02 Relación uno a uno y alta con BCrypt
POST Relación uno a uno y alta con BCrypt
GET New Request
POST U-03 Empleado inexistente
C - CORS
C-01 Preflight desde la SPA
POST login - vendedor
B - Contraseña roles y estado
B-03 Validación de la nueva contraseña
B-04 Cambio exitoso y comportamiento del token
B-05 Reemplazo de roles y efecto inmediato
GET clientes - almacen
PUT /usuarios/3/roles
GET GET /usuarios
B-06 Errores y restricciones al asignar roles
PUT PUT /usuarios/{id}/roles
PUT B-01 Contraseña actual incorrecta
PUT B-02 Nueva contraseña repetida
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
Open Folder
Terminal
Console
PharmaSoft - S10 Seguridad
GET GET /usuarios
B-06 Errores y restricciones
PUT PUT /usuarios/{id}/rol
No Environment
PharmaSoft - S10 Seguridad › B - Contraseña roles y estado › B-06 Errores y restricciones al asignar roles › PUT /usuarios/{id}/roles
Save
Share
PUT
{{baseUrl}} /usuarios/3/roles
Send
Docs
Params
Authorization
Headers 9
Body
Scripts
Settings
Cookies
none
form-data
x-www-form-urlencoded
raw
binary
GraphQL
JSON
Schema
Beautify
1 {"rolIds":[2]}
Body
Cookies
Headers 12
Test Results
403 Forbidden
12 ms
614 B
Load test
Save Response
Conflict: Cannot remove ADMIN role
Diagnose
Decline
Think Harder
Open
{ } JSON
Preview
Try with different auth credentials
{
"timestamp": "2026-10-18T15:35:23.992467800",
"status": 403,
"error": "Forbidden",
"message": "No tiene permisos para realizar esta operación",
"path": "/api/v1/usuarios/3/roles",
"validationErrors": null
}
Conflict: Cannot remove ADMIN role
Globals
Vault
Tools
AI
New Chat
Conflict: Cannot remove ADMIN role
I am trying to update the roles for user ID 1, but the API returns a 409 Conflict error: "No puede quitarse a sí mismo el rol ADMIN". How should I proceed to successfully update the roles for this user?
Open Source Code
Think Harder
Refine the PUT request setup
Parameterize the ID_USUARIO path variable for testing
Decline
Think Harder
Validate and document 409 error
Add a positive test case
Describe what you need. Press @ for context, / for Skills.
Auto

B-07 Desactivar y reactivar una cuenta

Grupo: Estado
Usuario o token: admin y vendedor

Petición: PATCH /usuarios/{id}/estado; GET /auth/me; POST /auth/login
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

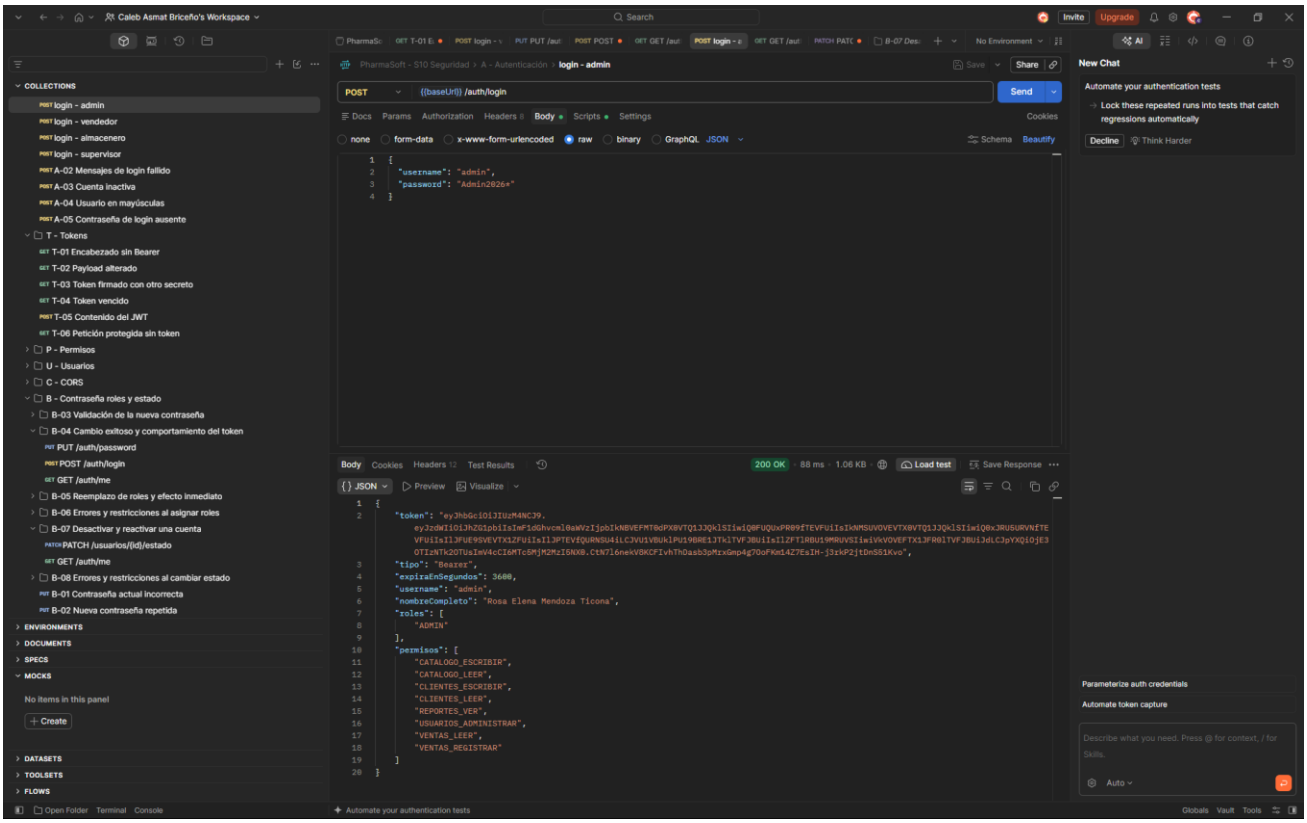
Resultado esperado: 200 al desactivar; token previo del desactivado 401 El usuario está deshabilitado; login 401 genérico; 200 al reactivar y login 200.

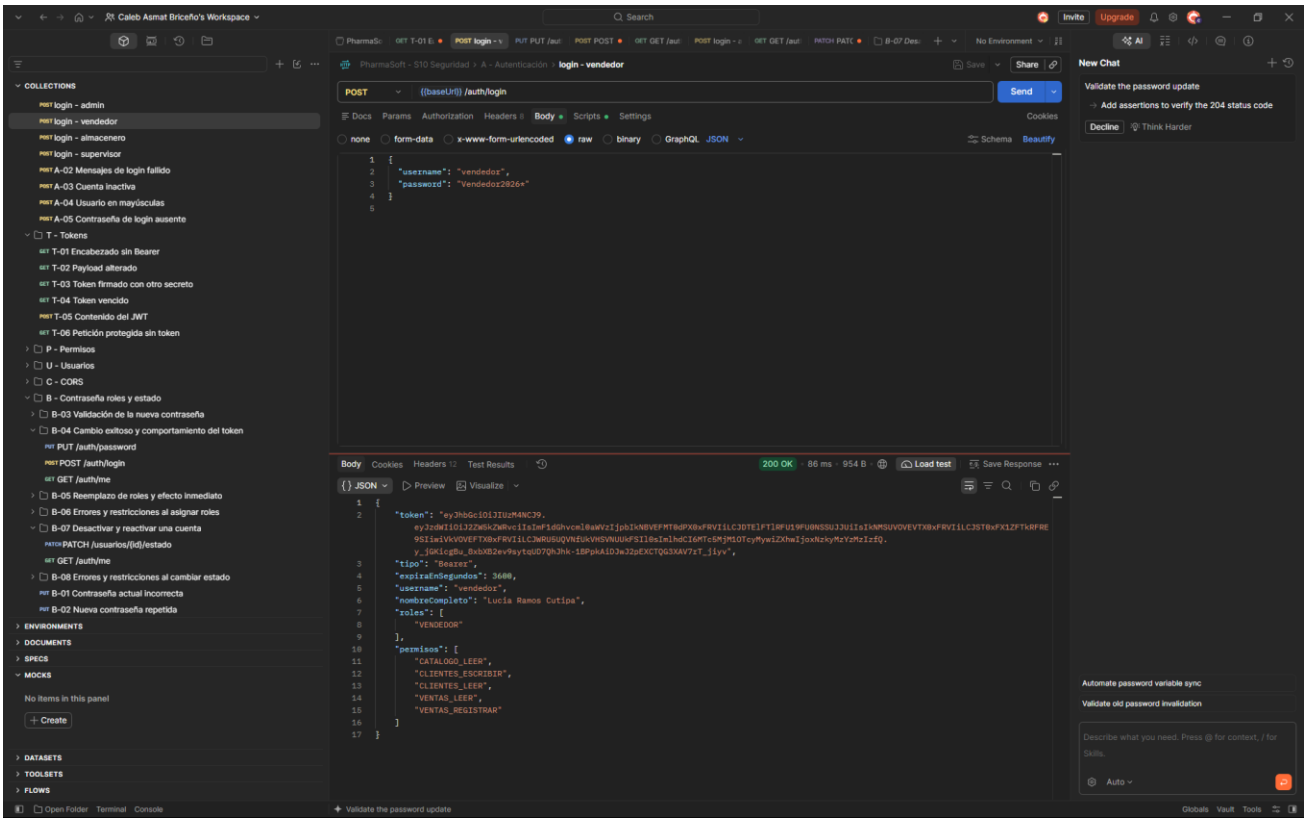
Precondición y datos utilizados: Admin y vendedor inician sesión con 200. La contraseña utilizada en esta nueva secuencia es Vendedor2026*, validada por el login inicial. GET /auth/me con tokenVendedor responde 200 antes de desactivar. Admin cambia el estado del usuario 2 a false y luego a true.

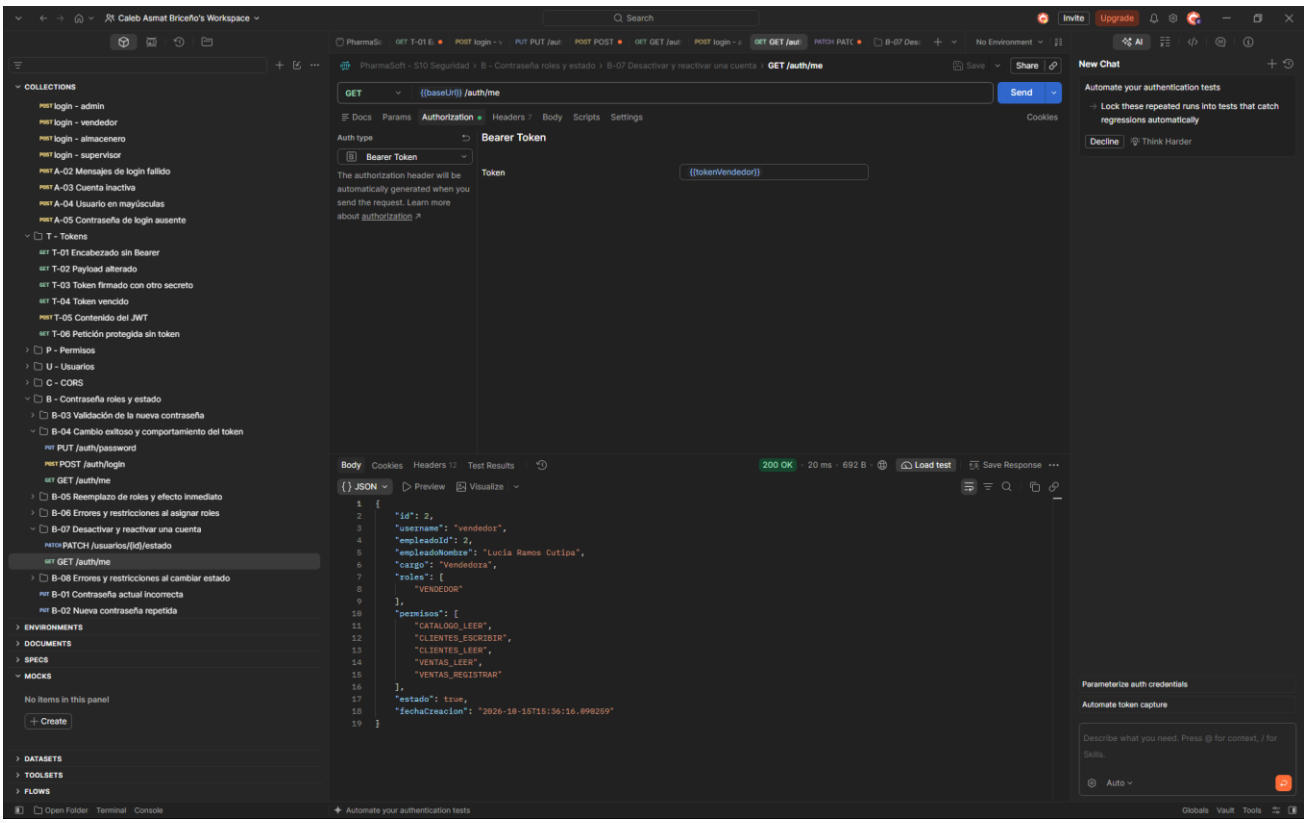
Resultado obtenido: Login de admin 200; login de vendedor 200; GET /auth/me inicial 200. Desactivación 200 con estado false; token rechazado con 401 El usuario está deshabilitado; login con la contraseña del acceso inicial rechazado con 401 genérico. Reactivación 200 con estado true y login posterior de vendedor con Vendedor2026* aceptado con 200.

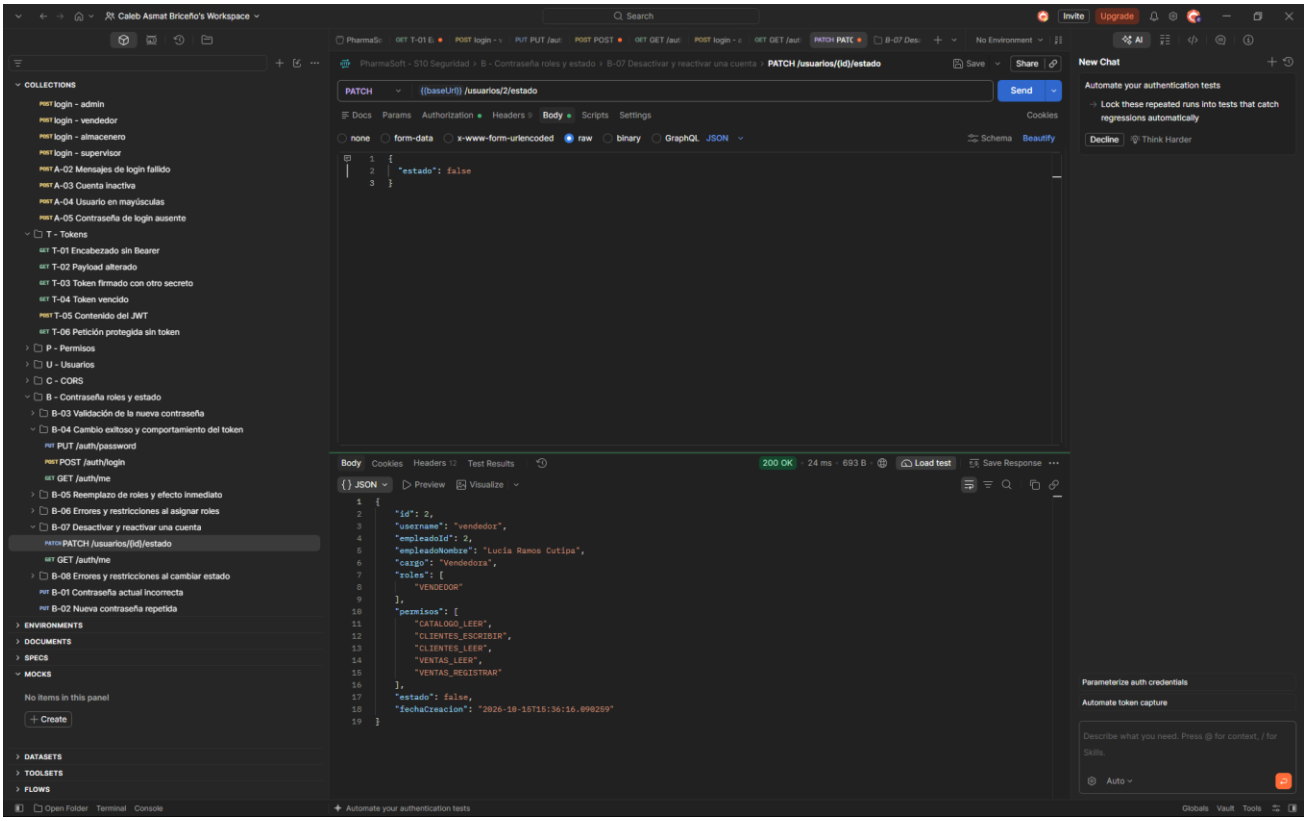
Estado: Pasa
Observaciones: La secuencia acredita el bloqueo durante la desactivación y la recuperación del login después de reactivar, utilizando la misma contraseña en ambos intentos. Esta secuencia corresponde a una ejecución distinta de B-04.

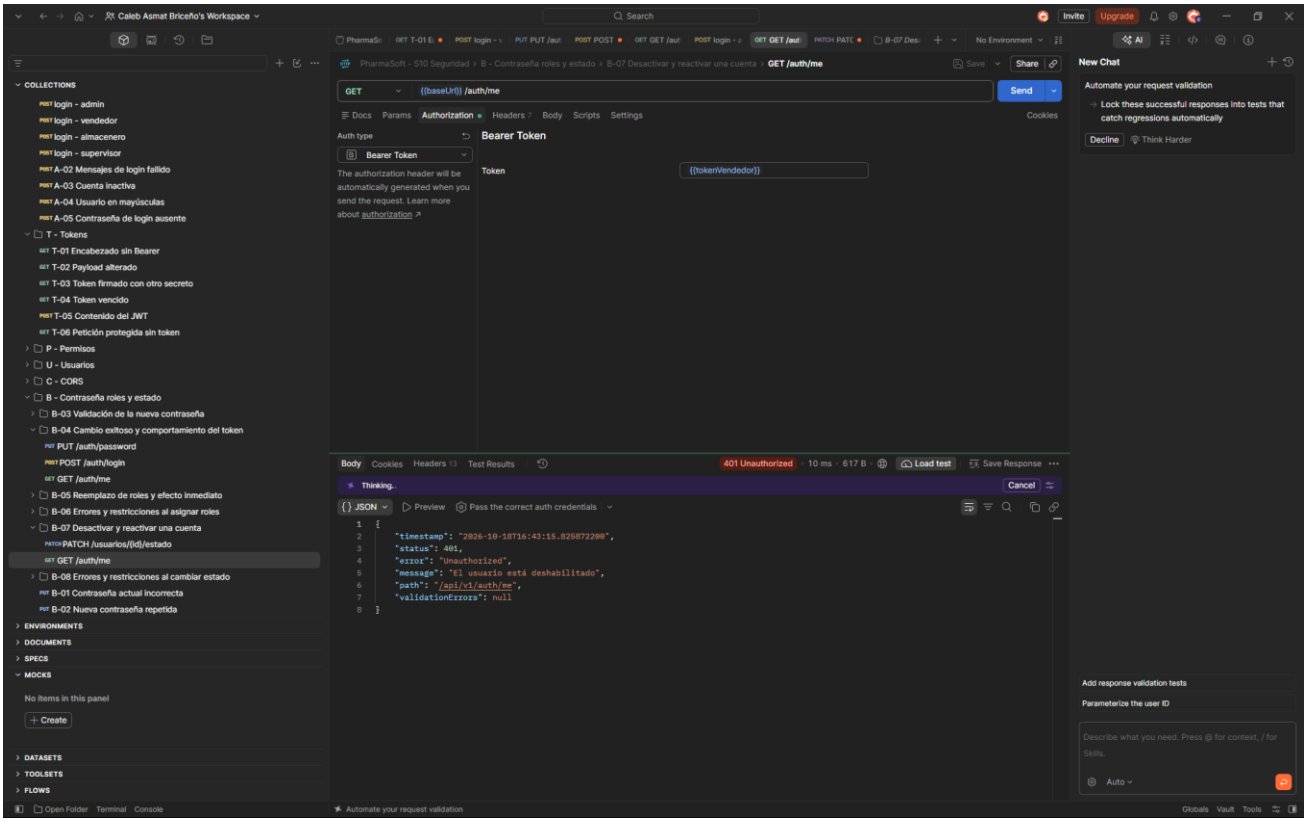
Evidencia: 8 capturas incrustadas en la sección B-07: login admin, login vendedor, acceso inicial, desactivación, rechazo del token, rechazo del login, reactivación y login posterior exitoso.

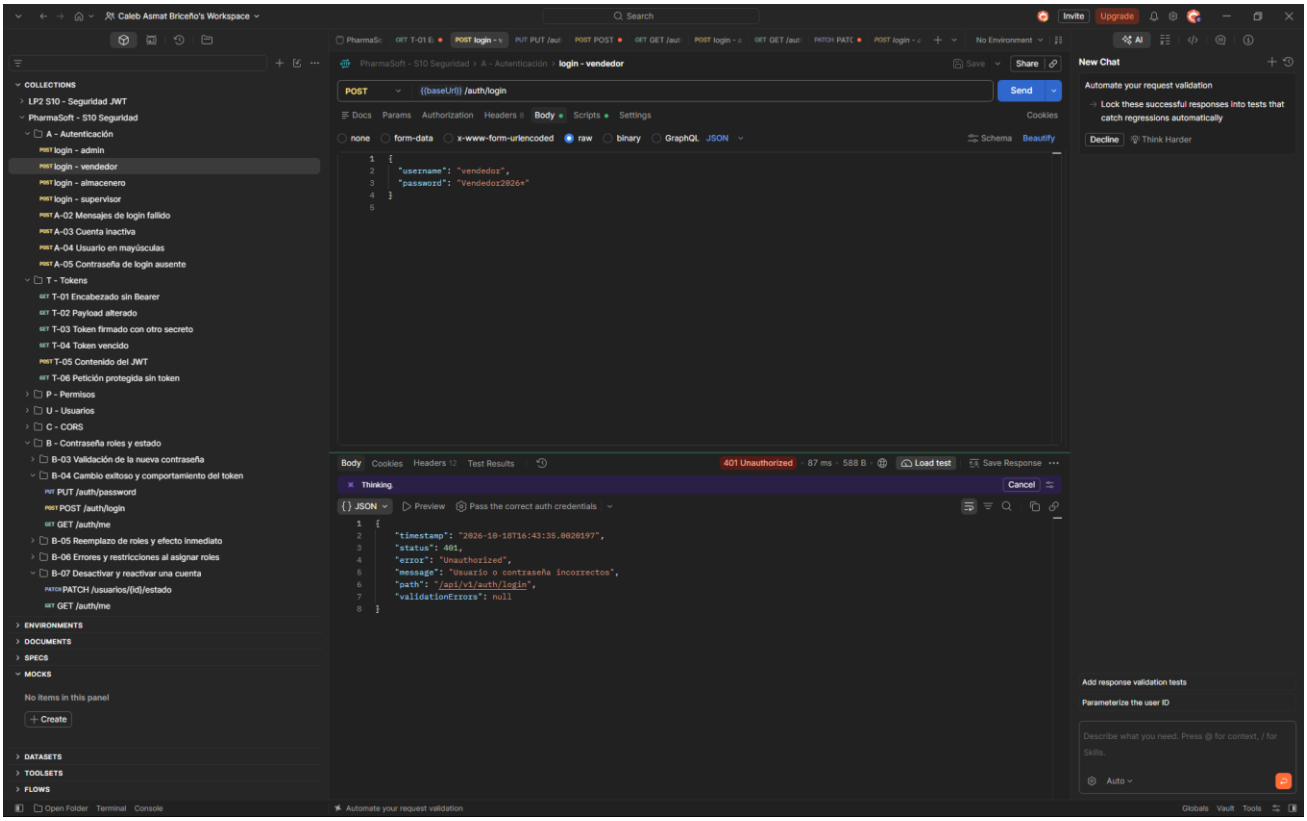


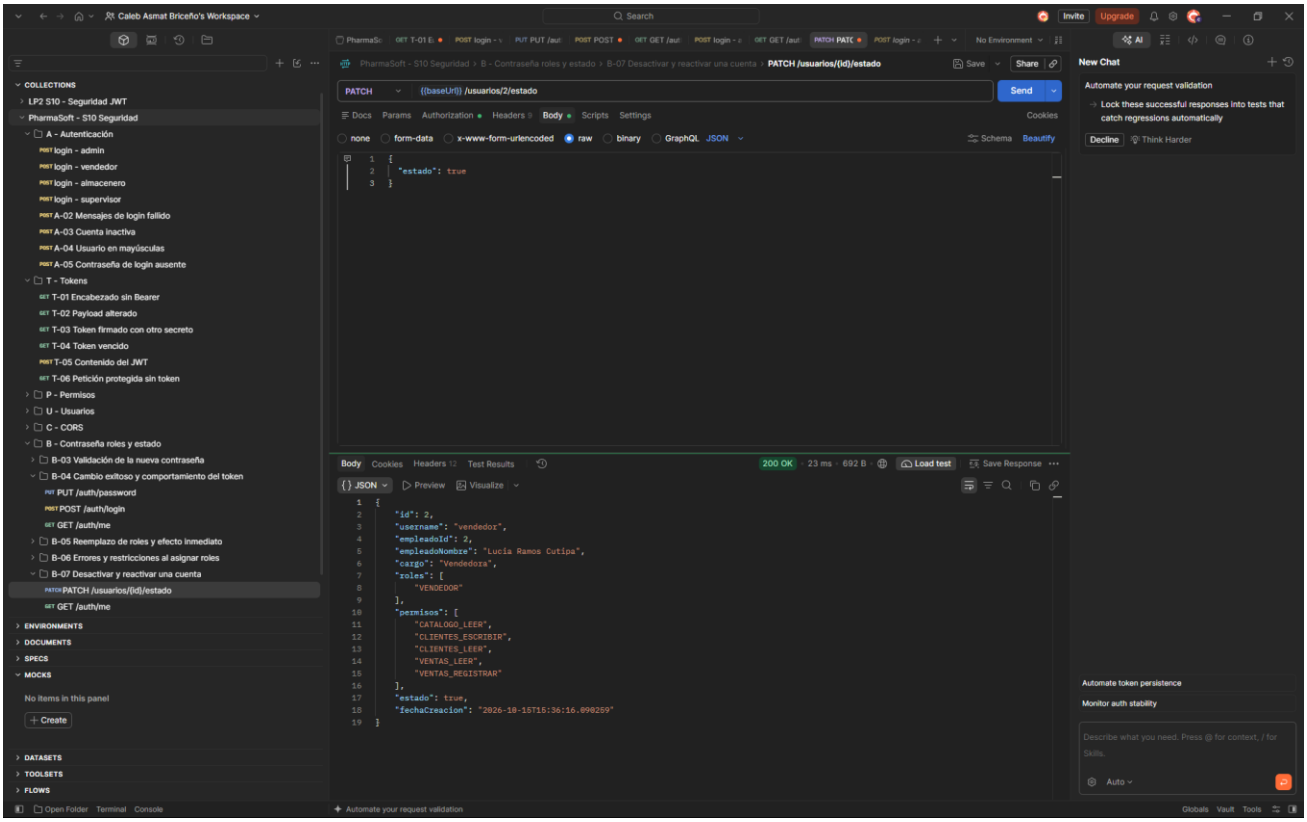

Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
PharmaSoft - S10 Seguridad › A - Autenticación › login - vendedor
Save
Share
POST
{{baseUrl}} /auth/login
Send
Docs Params Authorization Headers 8 Body Scripts Settings
Cookies
none form-data x-www-form-urlencoded raw binary GraphQL JSON
Schema Beautify
{
"username": "vendedor",
"password": "Vendedor2026*"
}
Body Cookies Headers 12 Test Results
200 OK · 86 ms · 954 B
Load test
Save Response
{ } JSON Preview Visualize
{
"token": "eyJhbGciOiJIUzM4NCJ9.
eyJzdWIiOiJ2ZW5kZWRvciIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0xFRVIiLCJDTElFTlRFU19FU0NSSUJJUiIsIkNMSUVOVEVTX0xFRVIiLCJST0xFX1ZFTkRFRE
9SIiwiVkVOVEFTX0xFRVIiLCJWRUSUQVNfUkVHSVNUUkFSIl0sImlhdCI6MTc5MjM1OTcyMywiZXhwIjoxNzkyMzYzMzIzfQ.
y_jGKicgBu_8xbXB2ev9aytqUD7Qh3hk-1BPpkAiDJwJ2pEXCTQG3XAV7rT_jiyv",
"tipo": "Bearer",
"expiraEnSegundos": 3600,
"username": "vendedor",
"nombreCompleto": "Lucia Ramos Cutipa",
"roles": [
"VENDEDOR"
],
"permisos": [
"CATALOGO_LEER",
"CLIENTES_ESCRIBIR",
"CLIENTES_LEER",
"VENTAS_LEER",
"VENTAS_REGISTRAR"
]
}
New Chat
Validate the password update
Add assertions to verify the 204 status code
Decline
Think Harder
Automate password variable sync
Validate old password invalidation
Describe what you need. Press @ for context, / for Skills.
Auto
COLLECTIONS
POST login - admin
POST login - vendedor
POST login - almacenero
POST login - supervisor
POST A-02 Mensajes de login fallido
POST A-03 Cuenta inactiva
POST A-04 Usuario en mayúsculas
POST A-05 Contraseña de login ausente
T - Tokens
GET T-01 Encabezado sin Bearer
GET T-02 Payload alterado
GET T-03 Token firmado con otro secreto
GET T-04 Token vencido
POST T-05 Contenido del JWT
GET T-06 Petición protegida sin token
P - Permisos
U - Usuarios
C - CORS
B - Contraseña roles y estado
B-03 Validación de la nueva contraseña
B-04 Cambio exitoso y comportamiento del token
PUT PUT /auth/password
POST POST /auth/login
GET GET /auth/me
B-05 Reemplazo de roles y efecto inmediato
B-06 Errores y restricciones al asignar roles
B-07 Desactivar y reactivar una cuenta
PATCH PATCH /usuarios/{id}/estado
GET GET /auth/me
B-08 Errores y restricciones al cambiar estado
POST B-01 Contraseña actual incorrecta
POST B-02 Nueva contraseña repetida
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
Open Folder Terminal Console
Validate the password update
Globals Vault Tools

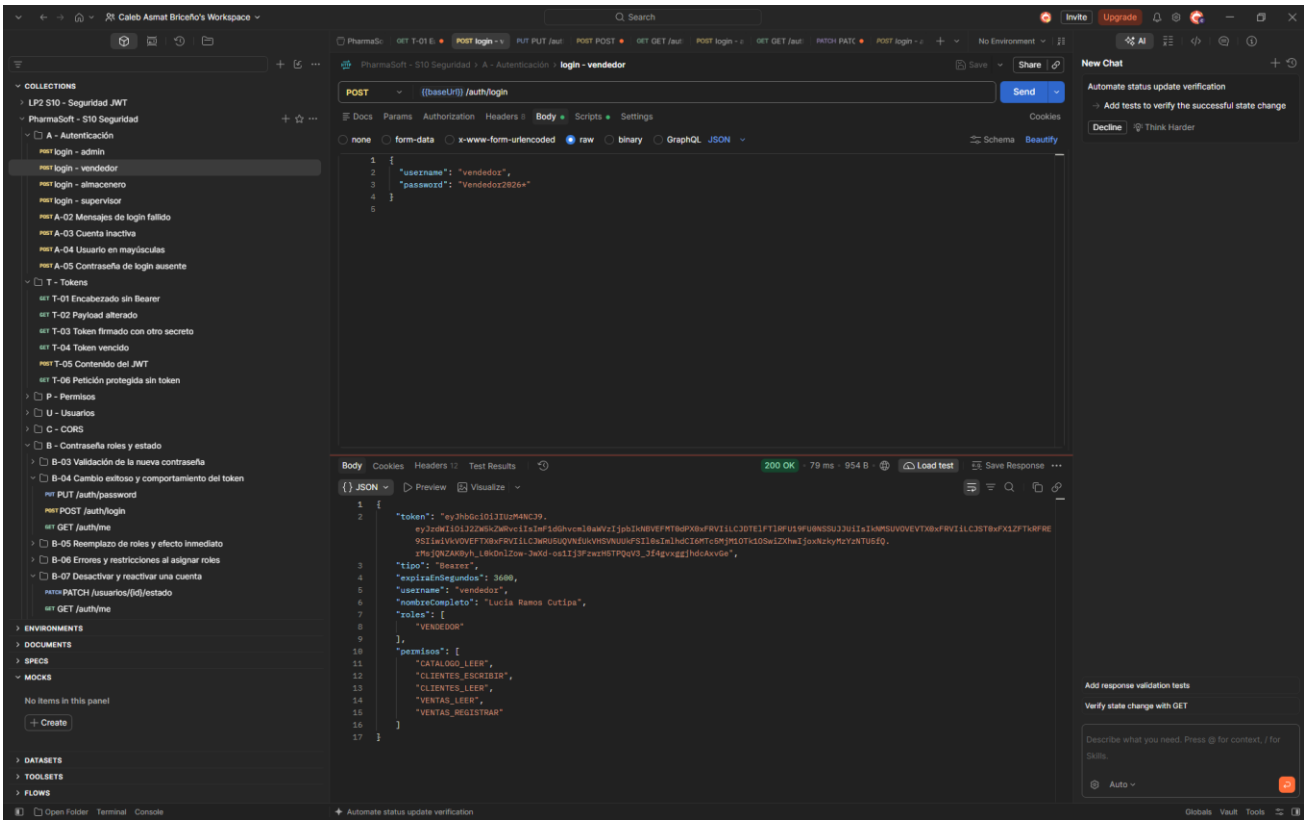

Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
PharmaSoft - S10 Seguridad › B - Contraseña roles y estado › B-07 Desactivar y reactivar una cuenta › GET /auth/me
Save
Share
GET
{{baseUrl}} /auth/me
Send
Docs Params Authorization Headers 7 Body Scripts Settings
Cookies
Auth type
Bearer Token
The authorization header will be automatically generated when you send the request. Learn more about authorization
Bearer Token
Token
{{tokenVendedor}}
Body Cookies Headers 12 Test Results
200 OK · 20 ms · 692 B
Load test
Save Response
{ } JSON Preview Visualize
{
"id": 2,
"username": "vendedor",
"empleadoId": 2,
"empleadoNombre": "Lucia Ramos Cutipa",
"cargo": "Vendedora",
"roles": [
"VENDEDOR"
],
"permisos": [
"CATALOGO_LEER",
"CLIENTES_ESCRIBIR",
"CLIENTES_LEER",
"VENTAS_LEER",
"VENTAS_REGISTRAR"
],
"estado": true,
"fechaCreacion": "2026-10-15T18:36:16.090269"
}
New Chat
Automate your authentication tests
Lock these repeated runs into tests that catch regressions automatically
Decline
Think Harder
Parameterize auth credentials
Automate token capture
Describe what you need. Press @ for context, / for Skills.
Auto
COLLECTIONS
POST login - admin
POST login - vendedor
POST login - almacenero
POST login - supervisor
POST A-02 Mensajes de login fallido
POST A-03 Cuenta inactiva
POST A-04 Usuario en mayúsculas
POST A-05 Contraseña de login ausente
T - Tokens
GET T-01 Encabezado sin Bearer
GET T-02 Payload alterado
GET T-03 Token firmado con otro secreto
GET T-04 Token vencido
POST T-05 Contenido del JWT
GET T-06 Petición protegida sin token
P - Permisos
U - Usuarios
C - CORS
B - Contraseña roles y estado
B-03 Validación de la nueva contraseña
B-04 Cambio exitoso y comportamiento del token
PUT PUT /auth/password
POST POST /auth/login
GET GET /auth/me
B-05 Reemplazo de roles y efecto inmediato
B-06 Errores y restricciones al asignar roles
B-07 Desactivar y reactivar una cuenta
PATCH PATCH /usuarios/{id}/estado
GET GET /auth/me
B-08 Errores y restricciones al cambiar estado
POST B-01 Contraseña actual incorrecta
POST B-02 Nueva contraseña repetida
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
Open Folder Terminal Console
Automate your authentication tests
Globals Vault Tools


PATCH /usuarios/{id}/estado
{{baseUrl}} /usuarios/2/estado
Send
{
"estado": false
}
200 OK
{
"id": 2,
"username": "vendedor",
"empleadoId": 2,
"empleadoNombre": "Lucia Ramos Cutipa",
"cargo": "Vendedora",
"roles": [
"VENDEDOR"
],
"permisos": [
"CATALOGO_LEER",
"CLIENTES_ESCRIBIR",
"CLIENTES_LEER",
"VENTAS_LEER",
"VENTAS_REGISTRAR"
],
"estado": false,
"fechaCreacion": "2026-10-15T15:36:16.690269"
}


GET /auth/me
{{baseUrl}} /auth/me
Send
Bearer Token
{{tokenVendedor}}
401 Unauthorized
{
"timestamp": "2026-10-18T16:43:15.826872200",
"status": 401,
"error": "Unauthorized",
"message": "El usuario está deshabilitado",
"path": "/api/v1/auth/me",
"validationErrors": null
}


POST
{{baseUrl}} /auth/login
Send
Body
raw
JSON
{
"username": "vendedor",
"password": "Vendedor2026*"
}
401 Unauthorized
{
"timestamp": "2026-10-18T16:43:35.0020197",
"status": 401,
"error": "Unauthorized",
"message": "Usuario o contraseña incorrectos",
"path": "/api/v1/auth/login",
"validationErrors": null
}


PATCH
{{baseUrl}} /usuarios/2/estado
Send
Body
raw
JSON
{
"estado": true
}
200 OK
{
"id": 2,
"username": "vendedor",
"empleadoId": 2,
"empleadoNombre": "Lucia Ramos Cutipa",
"cargo": "Vendedora",
"roles": [
"VENDEDOR"
],
"permisos": [
"CATALOGO_LEER",
"CLIENTES_ESCRIBIR",
"CLIENTES_LEER",
"VENTAS_LEER",
"VENTAS_REGISTRAR"
],
"estado": true,
"fechaCreacion": "2026-10-15T15:36:16.690259"
}


Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
LP2 S10 - Seguridad JWT
PharmaSoft - S10 Seguridad
A - Autenticación
login - admin
login - vendedor
login - almacenero
login - supervisor
A-02 Mensajes de login fallido
A-03 Cuenta inactiva
A-04 Usuario en mayúsculas
A-05 Contraseña de login ausente
T - Tokens
T-01 Encabezado sin Bearer
T-02 Payload alterado
T-03 Token firmado con otro secreto
T-04 Token vencido
T-05 Contenido del JWT
T-06 Petición protegida sin token
P - Permisos
U - Usuarios
C - CORS
B - Contraseña roles y estado
B-03 Validación de la nueva contraseña
B-04 Cambio exitoso y comportamiento del token
PUT /auth/password
POST /auth/login
GET /auth/me
B-05 Reemplazo de roles y efecto inmediato
B-06 Errores y restricciones al asignar roles
B-07 Desactivar y reactivar una cuenta
PATCH /usuarios/{id}/estado
GET /auth/me
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
PharmaSoft - S10 Seguridad › A - Autenticación › login - vendedor
Save
Share
POST
{{baseUrl}} /auth/login
Send
Docs
Params
Authorization
Headers 8
Body
Scripts
Settings
Cookies
none
form-data
x-www-form-urlencoded
raw
binary
GraphQL
JSON
Schema
Beautify
{
"username": "vendedor",
"password": "Vendedor2026+"
}
Body
Cookies
Headers 12
Test Results
200 OK
79 ms
954 B
Load test
Save Response
{ } JSON
Preview
Visualize
{
"token": "eyJhbGciOiJIUzM4NCJ9.
eyJzdWIiOiJJZWRkZW9vciIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0xFRVIiLCJDTElFTlRFU19FU0NSSUJJUiIsIkhMSUVOVEVTX0xFRVIiLCJST0xFX1ZFTkRFRE
9SIiwiVkVOVEFTX0xFRVIiLCJWRUSUQVNfUkVHSVNUUkFSIl0sImlhdCI6MTc5MjM1OTk1OSwiZXhwIjoxNzkyMzYzNTU5fQ.
rMsJQNZAKByh_L8kDnlZow-JwXd-os1Ij3FzwzHSTPQaV3_Jf4gvxggjhdcAxvGe",
"tipo": "Bearer",
"expiraEnSegundos": 3600,
"username": "vendedor",
"nombreCompleto": "Lucia Ramos Cutipa",
"roles": [
"VENDEDOR"
],
"permisos": [
"CATALOGO_LEER",
"CLIENTES_ESCRIBIR",
"CLIENTES_LEER",
"VENTAS_LEER",
"VENTAS_REGISTRAR"
]
}
New Chat
Automate status update verification
Add tests to verify the successful state change
Decline
Think Harder
Add response validation tests
Verify state change with GET
Describe what you need. Press @ for context, / for Skills.
Auto
Open Folder
Terminal
Console
Automate status update verification
Globals
Vault
Tools

B-08 Errores y restricciones al cambiar estado

Grupo: Estado
Usuario o token: admin y vendedor

Petición: PATCH /usuarios/{id}/estado
Base de la API: {{baseUrl}} = http://localhost:8080/api/v1

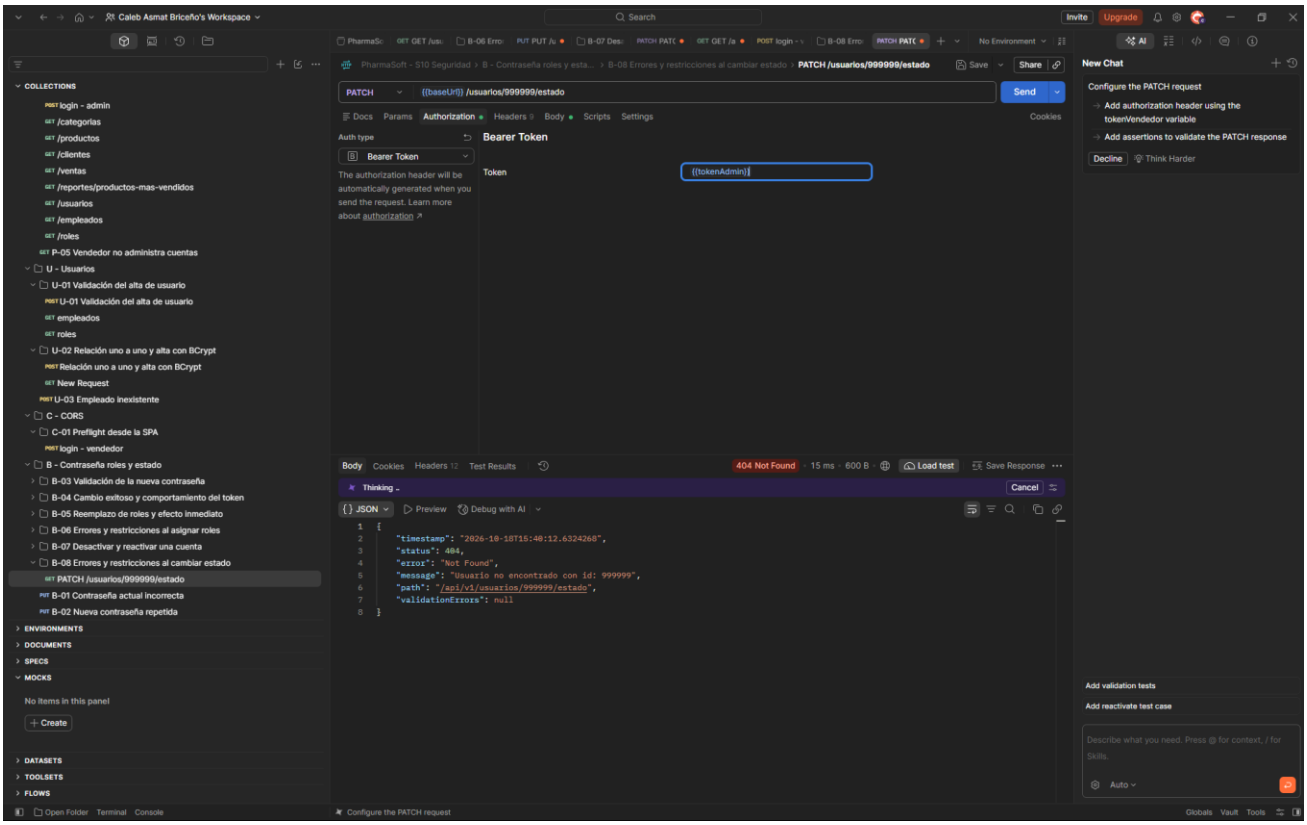
Resultado esperado: 404 por usuario inexistente; 409 por desactivarse el propio admin; 403 con vendedor; 400 si falta estado.

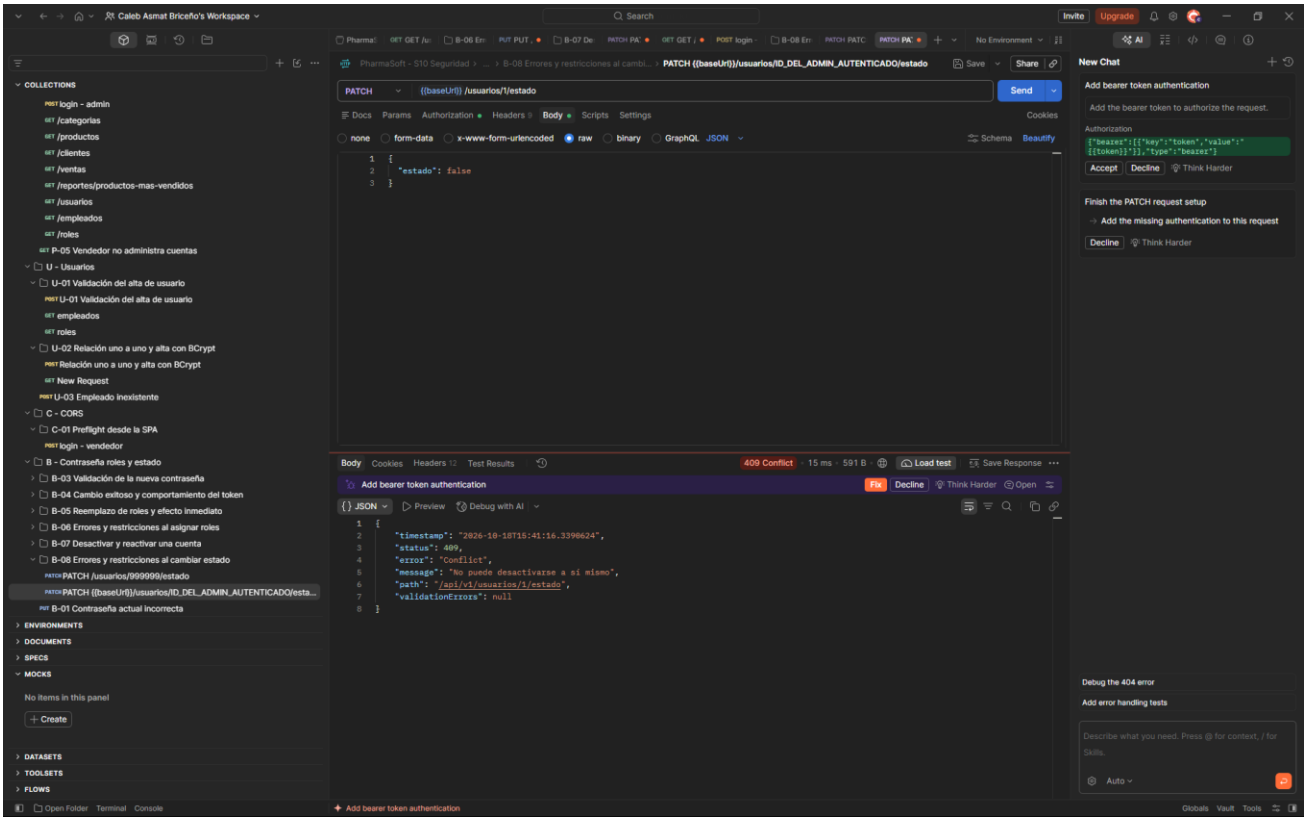
Precondición y datos utilizados: Admin prueba usuario 999999 y su propio usuario 1; vendedor intenta cambiar usuario 3; admin envía cuerpo vacío al usuario 2.

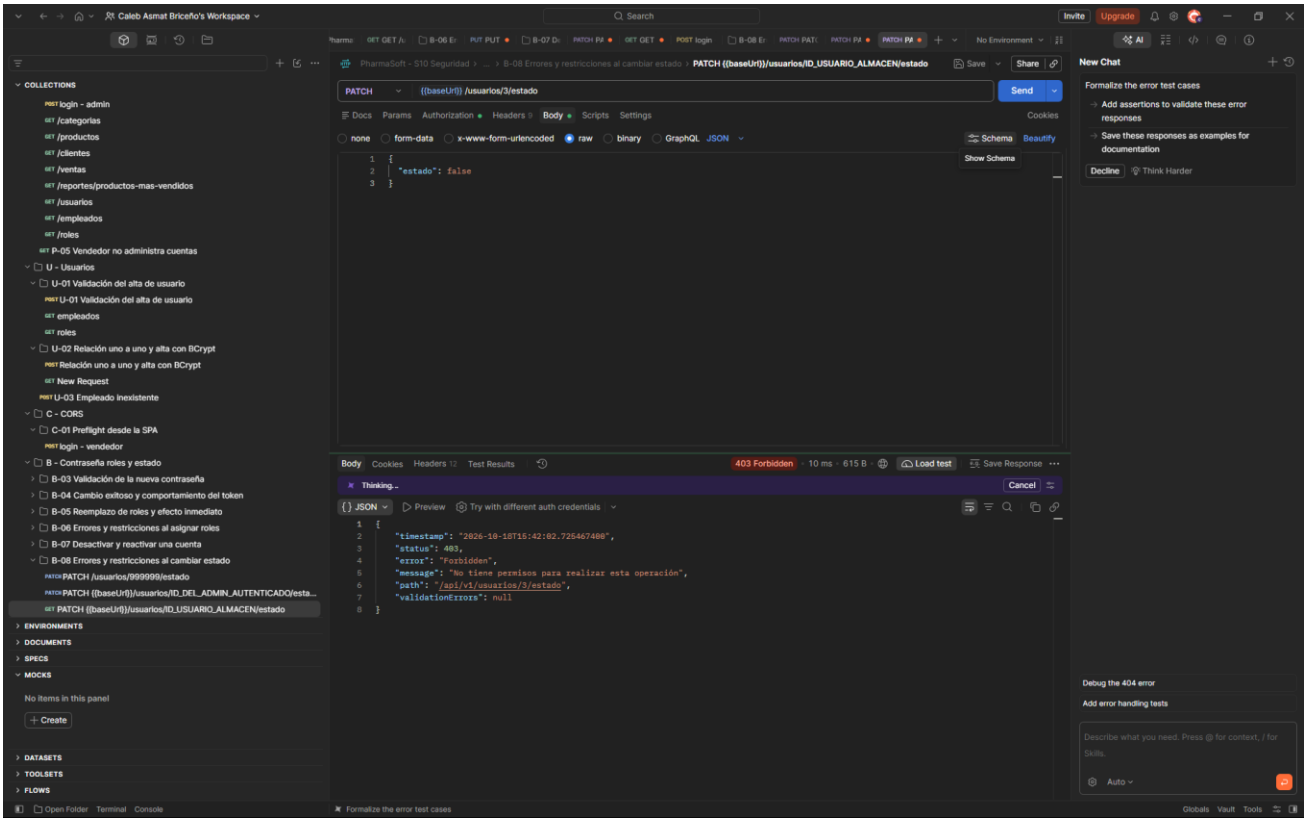
Resultado obtenido: 404 Usuario no encontrado con id: 999999; 409 No puede desactivarse a sí mismo; 403 No tiene permisos para realizar esta operación; 400 con validationErrors.estado: El estado es obligatorio.

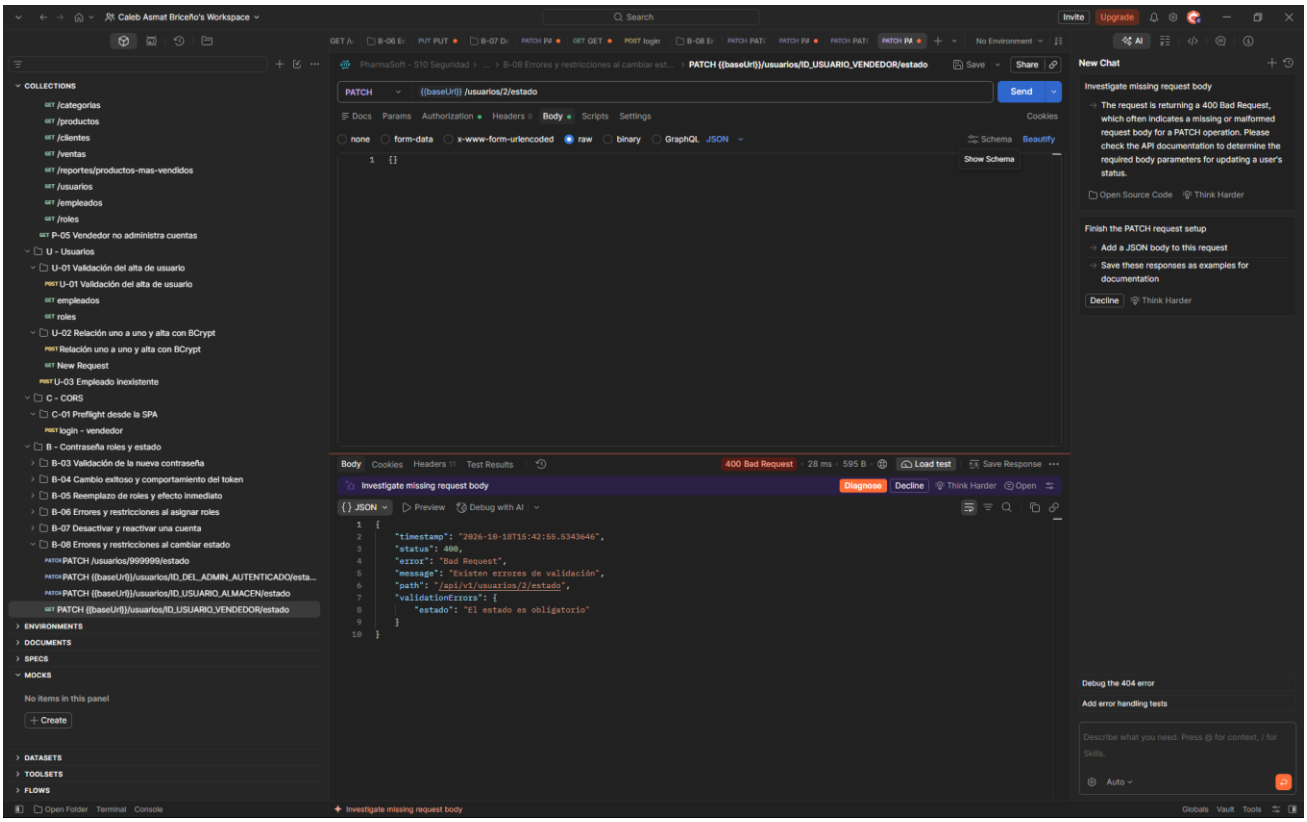
Estado: Pasa
Observaciones: Ninguna.

Evidencia: 4 capturas incrustadas en la sección B-08, en el orden de las operaciones.




Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
login - admin
/categorias
/productos
/clientes
/ventas
/reportes/productos-mas-vendidos
/usuarios
/empleados
/roles
P-05 Vendedor no administra cuentas
U - Usuarios
U-01 Validación del alta de usuario
U-01 Validación del alta de usuario
empleados
roles
U-02 Relación uno a uno y alta con BCrypt
Relación uno a uno y alta con BCrypt
New Request
U-03 Empleado inexistente
C - CORS
C-01 Preflight desde la SPA
login - vendedor
B - Contraseña roles y estado
B-03 Validación de la nueva contraseña
B-04 Cambio exitoso y comportamiento del token
B-05 Reemplazo de roles y efecto inmediato
B-06 Errores y restricciones al asignar roles
B-07 Desactivar y reactivar una cuenta
B-08 Errores y restricciones al cambiar estado
PATCH /usuarios/999999/estado
PATCH {{baseUrl}}/usuarios/ID_DEL_ADMIN_AUTENTICADO/esta...
B-01 Contraseña actual incorrecta
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
Open Folder
Terminal
Console
PharmaSoft - S10 Seguridad
B-08 Errores y restricciones al cambi...
PATCH {{baseUrl}}/usuarios/ID_DEL_ADMIN_AUTENTICADO/estado
Save
Share
PATCH
{{baseUrl}} /usuarios/1/estado
Send
Docs
Params
Authorization
Headers 9
Body
Scripts
Settings
Cookies
none
form-data
x-www-form-urlencoded
raw
binary
GraphQL
JSON
Schema
Beautify
{
"estado": false
}
Body
Cookies
Headers 12
Test Results
409 Conflict
15 ms
591 B
Load test
Save Response
Add bearer token authentication
Fix
Decline
Think Harder
Open
JSON
Preview
Debug with AI
{
"timestamp": "2026-10-18T15:41:16.3398624",
"status": 409,
"error": "Conflict",
"message": "No puede desactivarse a si mismo",
"path": "/api/v1/usuarios/1/estado",
"validationErrors": null
}
Add bearer token authentication
AI
New Chat
Add bearer token authentication
Add the bearer token to authorize the request.
Authorization
{"beazes":[{"key":"token","value":"{{token}}"}],"type":"beazer"}
Accept
Decline
Think Harder
Finish the PATCH request setup
Add the missing authentication to this request
Decline
Think Harder
Debug the 404 error
Add error handling tests
Describe what you need. Press @ for context, / for skills.
Auto
Add bearer token authentication
Globals
Vault
Tools


Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
POST login - admin
GET /categorias
GET /productos
GET /clientes
GET /ventas
GET /reportes/productos-mas-vendidos
GET /usuarios
GET /empleados
GET /roles
GET P-05 Vendedor no administra cuentas
U - Usuarios
U-01 Validación del alta de usuario
POST U-01 Validación del alta de usuario
GET empleados
GET roles
U-02 Relación uno a uno y alta con BCrypt
POST Relación uno a uno y alta con BCrypt
GET New Request
POST U-03 Empleado inexistente
C - CORS
C-01 Preflight desde la SPA
POST login - vendedor
B - Contraseña roles y estado
B-03 Validación de la nueva contraseña
B-04 Cambio exitoso y comportamiento del token
B-05 Reemplazo de roles y efecto inmediato
B-06 Errores y restricciones al asignar roles
B-07 Desactivar y reactivar una cuenta
B-08 Errores y restricciones al cambiar estado
PATCH /usuarios/999999/estado
PATCH PATCH {{baseUrl}}/usuarios/ID_DEL_ADMIN_AUTENTICADO/esta...
GET PATCH {{baseUrl}}/usuarios/ID_USUARIO_ALMACEN/estado
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
PharmaSoft - S10 Seguridad
B-08 Errores y restricciones al cambiar estado
PATCH {{baseUrl}}/usuarios/ID_USUARIO_ALMACEN/estado
Save
Share
PATCH
{{baseUrl}} /usuarios/3/estado
Send
Docs Params Authorization Headers 9 Body Scripts Settings
Cookies
none form-data x-www-form-urlencoded raw binary GraphQL JSON
Schema Beautify
Show Schema
{
"estado": false
}
Body Cookies Headers 12 Test Results
403 Forbidden · 10 ms · 615 B
Load test
Save Response
Thinking...
Cancel
{ } JSON Preview Try with different auth credentials
{
"timestamp": "2026-10-18T15:42:02.72546740",
"status": 403,
"error": "Forbidden",
"message": "No tiene permisos para realizar esta operación",
"path": "/api/v1/usuarios/3/estado",
"validationErrors": null
}
New Chat
Formalize the error test cases
Add assertions to validate these error responses
Save these responses as examples for documentation
Decline
Think Harder
Debug the 404 error
Add error handling tests
Describe what you need. Press @ for context, / for Skills.
Auto
Open Folder Terminal Console
Formalize the error test cases
Globals Vault Tools


Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
GET /categorias
GET /productos
GET /clientes
GET /ventas
GET /reportes/productos-mas-vendidos
GET /usuarios
GET /empleados
GET /roles
GET P-05 Vendedor no administra cuentas
U - Usuarios
U-01 Validación del alta de usuario
POST U-01 Validación del alta de usuario
GET empleados
GET roles
U-02 Relación uno a uno y alta con BCrypt
POST Relación uno a uno y alta con BCrypt
GET New Request
POST U-03 Empleado inexistente
C - CORS
C-01 Preflight desde la SPA
POST login - vendedor
B - Contraseña roles y estado
B-03 Validación de la nueva contraseña
B-04 Cambio exitoso y comportamiento del token
B-05 Reemplazo de roles y efecto inmediato
B-06 Errores y restricciones al asignar roles
B-07 Desactivar y reactivar una cuenta
B-08 Errores y restricciones al cambiar estado
PATCH /usuarios/999999/estado
PATCH PATCH {{baseUrl}}/usuarios/ID_DEL_ADMIN_AUTENTICADO/esta...
PATCH PATCH {{baseUrl}}/usuarios/ID_USUARIO_ALMACEN/estado
GET PATCH {{baseUrl}}/usuarios/ID_USUARIO_VENDEDOR/estado
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
PharmaSoft - S10 Seguridad
B-08 Errores y restricciones al cambiar est...
PATCH {{baseUrl}}/usuarios/ID_USUARIO_VENDEDOR/estado
Save
Share
PATCH
{{baseUrl}} /usuarios/2/estado
Send
Docs Params Authorization Headers 9 Body Scripts Settings
Cookies
none form-data x-www-form-urlencoded raw binary GraphQL JSON
Schema Beautify
Show Schema
{}
Body Cookies Headers 11 Test Results
400 Bad Request · 28 ms · 595 B
Load test
Save Response
Investigate missing request body
Diagnose
Decline
Think Harder
Open
{ } JSON Preview Debug with AI
{
"timestamp": "2026-10-18T15:42:55.5343646",
"status": 400,
"error": "Bad Request",
"message": "Existen errores de validación",
"path": "/api/v1/usuarios/2/estado",
"validationErrors": {
"estado": "El estado es obligatorio"
}
}
New Chat
Investigate missing request body
The request is returning a 400 Bad Request, which often indicates a missing or malformed request body for a PATCH operation. Please check the API documentation to determine the required body parameters for updating a user's status.
Open Source Code
Think Harder
Finish the PATCH request setup
Add a JSON body to this request
Save these responses as examples for documentation
Decline
Think Harder
Debug the 404 error
Add error handling tests
Describe what you need. Press @ for context, / for Skills.
Auto
Open Folder Terminal Console
Investigate missing request body
Globals Vault Tools

Anexo de cuerpos y consultas SQL

Venta válida

```
{"clienteId":1,"detalles":[{"productoId":28,"cantidad":1}]}
```

Alta de usuario para empleado libre

```
{
  "username":"s10_auxiliar",
  "password":"Auxiliar2026*",
  "empleadoId":41,
  "rolIds":[2]
}
```

Empleado adicional si no queda ninguno libre

```
INSERT INTO empleados
(dni,nombres,apellidos,cargo,email,estado,fecha_creacion)
VALUES ('99887765','Auxiliar','Pruebas S10','Auxiliar',
's10.auxiliar@pharmasoft.pe',true,systimestamp);
COMMIT;
SELECT id,dni,nombres,apellidos FROM empleados
WHERE dni='99887765';
```

Hash y asignación de roles

```
SELECT id,username,password,LENGTH(password) AS longitud_hash
FROM usuarios WHERE username='s10_auxiliar';

SELECT ur.usuario_id,ur.rol_id,u.username,r.nombre
FROM usuario_roles ur
JOIN usuarios u ON u.id=ur.usuario_id
JOIN roles r ON r.id=ur.rol_id
WHERE u.username='s10_auxiliar';
```

Anexo de JWT y comprobación CORS

Script para T 05

```
if (pm.response.code === 200) {
  const token = pm.response.json().token;
  const parte = token.split(".")[1]
    .replace(/-/g,"+").replace(/_/g,"/");
  const payload = JSON.parse(atob(parte));
  console.log(JSON.stringify(payload,null,2));
  console.log("Duración:",payload.exp-payload.iat);
  pm.test("JWT de vendedor dura 3600 segundos",()=>{
    pm.expect(payload.sub).to.eql("vendedor");
    pm.expect(payload.exp-payload.iat).to.eql(3600);
  });
}
```

Petición desde el origen de la SPA

Petición ejecutada desde la consola del navegador: GET http://localhost:8080/api/v1/productos con encabezado Authorization: Bearer y un JWT de desarrollo. Se añadió corsPrueba para observar un nuevo preflight; el token no se reproduce en el texto.

Otros cuerpos de la parte B

```
PUT /auth/password
{"passwordActual":"Vendedor2026*","passwordNueva":"NuevaClave2026"}

PUT /usuarios/{id}/roles
{"rolIds":[2,3]}

PATCH /usuarios/{id}/estado
{"estado":false}
```

Informe de seguridad resumen de resultados

Estudiante: Caleb David Asmat Briceño
Proyecto: PharmaBackend
Rama: feature/seguridad-pruebas-asmat

C1 Resumen

Se revisaron 28 casos distribuidos en ocho grupos, con 79 capturas de Postman, Oracle, navegador y consola del backend. Los 28 casos cuentan con las evidencias previstas y sus resultados coinciden con los esperados. No se observa en las capturas un acceso permitido indebidamente.

Autenticación: 5 casos revisados; 5 pasan.

Token: 6 casos revisados; 6 pasan.

Permisos: 5 casos revisados; 5 pasan.

Usuarios: 3 casos revisados; 3 pasan.

CORS: 1 caso revisado; 1 pasa.

Contraseña: 4 casos revisados; 4 pasan.

Roles: 2 casos revisados; 2 pasan.

Estado de cuentas: 2 casos revisados; 2 pasan.

Resultados por caso: detallados en las secciones de pruebas.
Evidencias: 79 capturas incrustadas en sus respectivas secciones.
Conclusión del resumen: los 28 casos documentados respaldan las validaciones, las restricciones de acceso y los cambios de contraseña, roles y estado. No quedan observaciones documentales pendientes en estos casos.

Informe de seguridad hallazgos

C2 Fichas de hallazgos

En los 28 casos ejecutados no se observaron diferencias entre los resultados obtenidos y los esperados. Por eso, no se presentan fichas de casos fallidos. Este resultado se limita a las pruebas realizadas y no garantiza la ausencia de otras vulnerabilidades.

Efecto de roles y estado sobre tokens existentes

JwtAuthenticationFilter.doFilterInternal extrae el username del JWT y vuelve a llamar a UsuarioDetailsService.loadUserByUsername en cada petición. Este servicio calcula las authorities desde los roles actuales y deshabilita la cuenta si usuario o empleado están inactivos. Por eso almacen pasó de 403 a 200 en clientes tras recibir VENDEDOR, y el token del vendedor desactivado recibió 401. Los permisos efectivos provienen de la base actual, no únicamente del claim authorities del token.

Informe de seguridad preguntas de análisis

C3 Análisis

1. ¿Por qué el login responde el mismo mensaje para usuario inexistente, contraseña incorrecta y cuenta deshabilitada? ¿Qué información daría un mensaje distinto a un atacante?

GlobalExceptionHandler.handleAuthentication devuelve Usuario o contraseña incorrectos para las excepciones de autenticación. Así se evita revelar si una cuenta existe o está deshabilitada. Mensajes distintos permitirían enumerar usuarios y orientar ataques contra cuentas conocidas. A-02 muestra el mismo 401 para usuario inexistente y contraseña errónea; la captura corregida de A-03 confirma ese mismo mensaje para la cuenta inactivo.

2. Después del cambio de contraseña, el token anterior sigue siendo válido hasta que vence. ¿Por qué sucede en una API sin estado? Propón una forma de invalidarlo.

El JWT ya emitido no cambia cuando AuthServiceImpl.cambiarPassword guarda un nuevo hash. JwtService.leerClaims comprueba firma y expiración, y el filtro verifica la existencia y el estado del usuario, pero no compara la fecha del token con el último cambio de contraseña. B-04 ahora muestra GET /auth/me con tokenVendedorAnterior y respuesta 200 después del cambio. Para invalidarlo se puede guardar una versión de credenciales en el usuario e incluirla en el JWT, rechazando versiones anteriores en el filtro. Esa comprobación de revocación no está implementada actualmente.

3. Si se publicara el secreto JWT en GitHub, ¿qué podría hacer un atacante? ¿Qué harías de inmediato?

Con el secreto de firma, un atacante podría fabricar JWT que suplantaran usernames existentes, incluido admin. En esta API, alterar authorities no asigna por sí solo permisos: el filtro los recarga de la base, pero suplantar un administrador sí daría su acceso. Rotaría el secreto inmediatamente para rechazar los tokens anteriores, revisaría accesos y acciones, retiraría la clave del repositorio y su historial y la movería a configuración externa. T-03 documenta que cambiar la clave hace fallar la firma de un token anterior.

4. ¿Qué ventaja tiene proteger reportes con @PreAuthorize en el controlador frente a una regla por URL en SecurityConfig? ¿Qué desventaja tiene?

ReporteController usa @PreAuthorize para asociar REPORTES_VER al controlador y conservar esa exigencia aunque cambie su URL. La seguridad por método también puede aplicarse a servicios, mientras que SecurityConfig centraliza reglas HTTP por ruta y verbo. La desventaja es que las anotaciones pueden dispersarse u omitirse y requieren la infraestructura de seguridad por método; las llamadas internas dentro del mismo objeto también requieren atención por el uso de proxies. P-03 muestra 403 para usuarios sin el permiso y P-04 el acceso permitido del administrador.

Referencia de la actividad: Lenguaje de Programación II, Actividad Autónoma de la Sesión 10, 15 de octubre de 2026, partes A a D. Plazo indicado: 21 de octubre de 2026 a las 23:59.